



Giáo trình an toàn và bảo mật thông tin

An toàn và an ninh mạng (Trường Đại học Công nghệ, Đại học Quốc gia Hà Nội)



messages.pdf_cover_qr_code_label

TRƯỜNG ĐẠI HỌC SƯ PHẠM KỸ THUẬT HƯNG YÊN
KHOA CÔNG NGHỆ THÔNG TIN



GIÁO TRÌNH
AN TOÀN VÀ BẢO MẬT
TRONG MẠNG MÁY TÍNH





MỤC LỤC

MỤC LỤC	3
LỜI NÓI ĐẦU	9
CHƯƠNG 1. NHỮNG VẤN ĐỀ CƠ BẢN VỀ AN TOÀN THÔNG TIN	11
1.1 Thông tin	11
1.1.1 Các định nghĩa về thông tin	11
1.1.2 Phương tiện truyền thông	11
1.2 Khái niệm hệ thống và tài nguyên thông tin	12
1.2.1 Khái niệm hệ thống thông tin	12
1.2.2 Tài nguyên thông tin trong hệ thống thông tin	12
1.3 An ninh hệ thống thông tin	12
1.4 An toàn bảo mật hệ thống thông tin	13
1.5 Các mối đe dọa đối với một hệ thống và các biện pháp bảo vệ	14
1.5.1 Các mối đe dọa đối với một hệ thống thông tin	14
1.5.2 Các đối tượng xâm hại hệ thống	14
1.5.3 Nguyên tắc và mục tiêu chung của an toàn bảo mật thông tin	14
1.5.4 Các biện pháp bảo vệ thông tin	14
1.5.5 Các biện pháp bảo vệ mạng	15
1.6 Các thành phần chính của an toàn tin học	16
1.6.1 An toàn mức vật lý	17
1.6.2 An toàn mức tác nghiệp	17
1.6.3 Quản trị và chính sách	19
1.7 Sự không an toàn trong các dịch vụ và các giao thức	23
1.8 An toàn đồ hình mạng	27



1.8.1	Mục đích của thiết kế	27
1.8.2	Vùng bảo mật	27
1.9	Quản lý rủi ro	28
1.10	Câu hỏi và bài tập	28
CHƯƠNG 2. MẬT MÃ HỌC		29
2.1	Sơ lược về lịch sử mật mã học	29
2.2	Những khái niệm cơ bản	30
2.3	Phân loại các thuật toán mật mã	32
2.4	Ứng dụng của mật mã học	32
2.5	Số học modulo	33
2.5.1	Định nghĩa modulo	33
2.5.2	Ước số	34
2.5.3	Các phép toán số học trên modulo	34
2.5.4	Vành Z_n (vành đồng dư modulo n)	35
2.5.5	Các số nguyên tố	35
2.5.6	Ước số chung lớn nhất (Greatest Common Divisor)	36
2.5.7	Nghịch đảo a^{-1} modulo n	37
2.5.8	Định lý Euler	39
2.6	Mã nén dữ liệu	41
2.6.1	Khái niệm cơ bản	41
2.6.2	Các phương pháp nén dữ liệu	41
2.6.3	Nén dữ liệu theo mô hình thống kê	42
2.6.4	Mã nén Huffman	43
2.6.5	Mã RLE (Run- Length- Encoding)	46



2.6.6	Mô hình từ điển	47
2.6.7	LZ77	48
2.6.8	LZ78	52
2.7	Câu hỏi và bài tập	55
2.7.1	Câu hỏi	55
2.7.2	Bài tập	55
CHƯƠNG 3.	CÁC HỆ MẬT MÃ ĐỐI XỨNG	57
3.1	Định nghĩa.....	57
3.2	Mật mã đối xứng cổ điển	58
3.2.1	Kỹ thuật mã hóa thay thế	58
3.2.2	Kỹ thuật mã hóa hoán vị cổ điển.....	63
3.2.3	Điểm yếu của mã cổ điển	64
3.3	Thăm mã đối xứng cổ điển	65
3.3.1	Khái niệm	65
3.3.2	Thăm mã Affine bằng phương pháp thống kê	66
3.4	Mật mã dòng hiện đại	67
3.5	Mật mã khối	68
3.5.1	Nguyên lý chung	68
3.5.2	Hệ mã hóa DES	70
3.6	Câu hỏi và bài tập	77
3.6.1	Câu hỏi	77
3.6.2	Bài tập	77
CHƯƠNG 4.	CÁC HỆ MẬT MÃ KHÓA CÔNG KHAI	79
4.1	Mã hóa khóa công khai	79



4.1.1	Những hạn chế của mã hóa khóa đối xứng	79
4.1.2	Mã hóa khóa công khai	79
4.2	Mã hóa khóa công khai RSA	82
4.2.1	Nguyên tắc thực hiện của RSA	83
4.2.2	Chứng minh tính đúng của RSA	84
4.2.3	Ví dụ về mã hóa bằng RSA	85
4.3	Độ phức tạp tính toán RSA	86
4.3.1	Phép tính mã hóa/giải mã	86
4.3.2	Phép tính sinh khóa	87
4.4	Độ an toàn của RSA	87
4.5	Bảo mật, chứng thực và không chối bỏ với mã hóa khóa công khai	88
4.6	Trao đổi khóa	89
4.6.1	Trao đổi khóa công khai	89
4.6.2	Dùng mã hóa khóa công khai để trao đổi khóa bí mật	90
4.7	Phương pháp trao đổi khóa Diffie – Hellman	91
4.8	Câu hỏi và bài tập	92
4.8.1	Câu hỏi	92
4.8.2	Bài tập	93
CHƯƠNG 5.	HÀM BẮM VÀ XÁC THỰC THÔNG TIN	94
5.1	Xác thực thông tin	94
5.1.1	Các khái niệm	94
5.1.2	Các yêu cầu bảo mật khi truyền văn bản trên mạng	94
5.1.3	Xác thực văn bản bằng mã hóa	95
5.1.4	Xác thực văn bản bằng Mã xác thực	95



5.1.5	Các hàm băm.....	97
5.1.6	Các hàm băm đơn giản.....	98
5.2	Các hàm băm SHA và MD5	99
5.2.1	Các hàm băm SHA.....	99
5.2.2	Hàm băm MD5.....	111
5.3	Câu hỏi và bài tập	117
5.3.1	Câu hỏi	117
5.3.2	Bài tập	117
CHƯƠNG 6. AN TOÀN VÀ BẢO MẬT HỆ THỐNG THÔNG TIN TRÊN INTERNET		118
6.1	Hạ tầng mạng và những điểm yếu	118
6.1.1	Mô hình OSI và TCP/IP	118
6.1.2	Một số điểm yếu của bộ giao thức TCP/IP	122
6.2	Phần mềm độc hại – Malware.....	128
6.2.1	Khái niệm	128
6.2.2	Trojan và Backdoor.....	128
6.2.3	Virus và Worm.....	132
6.3	Các hình thức tấn công WLAN	134
6.3.1	Một số khái niệm về WLAN.....	134
6.3.2	Tấn công giả mạo điểm truy cập	135
6.3.3	Giả mạo địa chỉ vật lý	136
6.3.4	Tấn công yêu cầu xác thực lại.....	137
6.3.5	Tấn công dựa trên sự cảm nhận sóng mang lớp vật lý.....	137
6.3.6	Tấn công ngắt kết nối.....	137
6.4	Firewall	138



6.4.1	Khái niệm.....	138
6.4.2	Nguyên lý hoạt động của tường lửa.....	139
6.4.3	Giải pháp tường lửa cho doanh nghiệp.....	140
6.5	Chính sách an toàn và bảo mật thông tin trong doanh nghiệp.....	141
6.5.1	Các chính sách an toàn và bảo mật.....	141
6.5.2	Quản lý rủi ro.....	143
6.6	Câu hỏi và bài tập.....	145
6.6.1	Câu hỏi.....	145
Phụ lục 1. Các hoán vị và hộp S của DES.....		146
Phụ lục 2. Ví dụ về hàm băm SHA512.....		154
TÀI LIỆU THAM KHẢO.....		162



LỜI NÓI ĐẦU

Ngày nay, thông tin đang trở thành một tài nguyên quý giá của hầu hết các quốc gia trên thế giới, đặc biệt trong bối cảnh của xu hướng toàn cầu hóa và phát triển nền kinh tế tri thức. Bảo vệ thông tin và bảo đảm môi trường làm việc với nguồn tài nguyên này là nhiệm vụ tất yếu của chúng ta. Các mạng tin học là một loại môi trường lao động mới ra đời và phát triển trong xã hội văn minh hiện đại, chúng đóng vai trò rất quan trọng vì càng ngày càng có nhiều người tham gia khai thác và cung cấp thông tin trên đó.

Hiện nay, môn học về bảo mật máy tính và mạng đã được đưa vào giảng dạy tại hầu hết các khoa Công nghệ Thông tin của các trường đại học và cao đẳng. Để đáp ứng yêu cầu học tập và tự tìm hiểu của sinh viên về lĩnh vực này, bộ môn Mạng máy tính và Truyền thông, khoa Công nghệ Thông tin thuộc trường Đại học Sư phạm Kỹ thuật Hưng Yên đã tổ chức biên soạn giáo trình “An toàn và bảo mật trong mạng máy tính”.

Nội dung của giáo trình được biên soạn dựa vào một số tài liệu, trong đó có cuốn sách của Giáo sư William Stallings “Cryptography and Network Security: Principles and Practice”. Đồng thời, giáo trình này cũng được hoàn thiện từng bước dựa trên các bài giảng và kinh nghiệm trong thực tế bảo vệ máy tính và mạng của các giảng viên thuộc bộ môn. Với mục đích trang bị các kiến thức cơ sở vừa đủ và giúp cho sinh viên hiểu được bản chất của bảo mật máy tính và mạng, trong giáo trình này, tập thể tác giả đã cố gắng trình bày tóm tắt các phần lý thuyết cơ bản và đưa ra các ứng dụng thực tế.

Giáo trình bao gồm 6 chương. Chương đầu trình bày những vấn đề cơ bản về an toàn thông tin, chương 2 giới thiệu tổng quan về mật mã học, chương 3 trình bày về các hệ mật mã đối xứng, chương 4 giới thiệu về các hệ mật mã khóa công khai, chương 5 trình bày về hàm băm và xác thực thông tin, cuối cùng, chương 6 bàn về an toàn và bảo mật hệ thông tin trên Internet.

Do lần đầu biên soạn và chưa có nhiều kinh nghiệm thực tế nên không tránh khỏi những sai sót và lỗi in ấn nhất định trong nội dung của giáo trình. Chúng tôi vui lòng tiếp nhận mọi sự đóng góp giúp cho giáo trình “An toàn và bảo mật trong mạng máy tính” ngày càng tốt hơn.



Cuối cùng, chúng tôi xin trân trọng cảm ơn Bộ môn Mạng máy tính và Truyền thông, khoa Công nghệ Thông tin và Trường ĐH Sư phạm Kỹ thuật Hưng Yên đã tạo điều kiện thuận lợi để chúng tôi có thể hoàn thành cuốn giáo trình này.

Thay mặt nhóm biên soạn

CHỦ BIÊN

PGS.TS Bùi Thế Hồng

Các tác giả

Bùi Thế Hồng

Phạm Minh Chuẩn

Nguyễn Đình Hân

Nguyễn Duy Tân

Vi Hoài Nam

Nguyễn Thị Thanh Huệ

Phạm Quốc Hùng



CHƯƠNG 1. NHỮNG VẤN ĐỀ CƠ BẢN VỀ AN TOÀN THÔNG TIN

1.1 Thông tin

1.1.1 Các định nghĩa về thông tin

Có khá nhiều định nghĩa về thông tin. Hai định nghĩa sau đây thường được sử dụng trong các tài liệu có liên quan đến thông tin.

- *Thông tin là những tính chất xác định của vật chất mà con người (hoặc hệ thống kỹ thuật) nhận được từ thế giới vật chất bên ngoài hoặc từ những quá trình xảy ra trong bản thân nó.*
- *Thông tin là sự phản ánh sự vật, sự việc, hiện tượng của thế giới tự nhiên và các hoạt động của con người trong đời sống xã hội. Điều cơ bản là con người thông qua việc cảm nhận thông tin làm tăng hiểu biết cho mình và tiến hành những hoạt động có ích cho cộng đồng.*

Thông tin được lưu trữ trên nhiều dạng vật liệu khác nhau như được khắc trên đá, được ghi lại trên giấy, trên bìa, trên băng từ, đĩa từ, đĩa cứng, thẻ nhớ,... Thông tin chính là tất cả những gì mang lại hiểu biết cho con người mà con người tri thức được. Con người luôn có nhu cầu thu thập thông tin bằng nhiều cách khác nhau: đọc báo, nghe đài, xem truyền hình, truy cập mạng Internet, giao tiếp với người khác một cách trực tiếp hoặc thông qua các diễn đàn điện tử và mạng xã hội,... Thông tin làm tăng hiểu biết của con người, là nguồn gốc của nhận thức và là cơ sở để đưa ra quyết định.

1.1.2 Phương tiện truyền thông

Môi trường vận động thông tin là môi trường truyền tin, nó bao gồm các kênh liên lạc tự nhiên hoặc nhân tạo như sóng âm, tia sáng, dây dẫn, sóng âm thanh, sóng hình, sóng vô tuyến,... Kênh liên lạc thường nối các thiết bị, máy móc lại với nhau hay nối với con người. Con người có hình thức liên lạc tự nhiên và cao cấp là tiếng nói, từ đó nghĩ ra chữ viết. Ngày nay nhiều công cụ hiển thị và truyền bá thông tin đã xuất hiện như bút viết, máy in, điện tín, điện thoại, phát thanh, truyền hình, phim ảnh rồi đến máy tính, mạng máy tính và đặc biệt là mạng Internet.

Về nguyên tắc, bất kỳ cấu trúc vật chất nào hoặc bất kỳ dòng năng lượng nào cũng có thể mang thông tin. Các vật có thể mang thông tin được gọi là giá mang tin. Thông tin luôn mang một ý nghĩa xác định nhưng hình thức thể hiện của thông tin thì rõ ràng mang tính quy ước. Chẳng hạn ký hiệu "V" trong hệ đếm La Mã mang ý nghĩa



là 5 đơn vị nhưng trong hệ thống chữ La tinh nó mang nghĩa là chữ cái V. Trong máy tính điện tử, nhóm 8 chữ số 01000001 nếu là số sẽ thể hiện số 65, còn nếu là chữ sẽ là chữ "A" theo bảng mã ASCII.

Có nhiều cách phân loại thông tin nhưng cách phân loại dựa vào đặc tính liên tục hay rời rạc của tín hiệu vật lý là hay được sử dụng hơn. Tương ứng, thông tin sẽ được chia thành thông tin liên tục và thông tin rời rạc.

1.2 Khái niệm hệ thống và tài nguyên thông tin

1.2.1 Khái niệm hệ thống thông tin

Hệ thống thông tin là một tập hợp các máy tính gồm phần cứng, phần mềm và dữ liệu làm việc, được tích lũy qua thời gian.

1.2.2 Tài nguyên thông tin trong hệ thống thông tin

Một hệ thống thông tin thường bao gồm những tài nguyên sau đây:

- Phần cứng;
- Phần mềm;
- Dữ liệu;
- Môi trường truyền thông;
- Môi trường làm việc;
- Con người.

1.3 An ninh hệ thống thông tin

ISO (International Organization for Standardization), Tổ chức quốc tế lớn nhất về tiêu chuẩn hóa mà Việt Nam đang tham gia, đã định nghĩa:

Định nghĩa: An ninh (security) là sự hạn chế khả năng lạm dụng tài nguyên (resources) và tài sản (assets).

Trong công nghệ thông tin, an ninh là việc sử dụng các công nghệ, quy trình, thiết bị,... để bảo vệ thông tin (information), tài nguyên và tài sản [1]. An ninh trở nên đặc biệt phức tạp trong quản lý, vận hành những hệ thống thông tin có sử dụng các công cụ tin học. Tại đây có thể xảy ra và lan tràn nhanh chóng việc lạm dụng tài nguyên (các thông tin di chuyển vô hình trên mạng hoặc lưu trữ hữu hình trong các vật liệu) và lạm dụng tài sản (các máy tính, thiết bị mạng, thiết bị ngoại vi, các loại phần mềm của cơ quan hoặc người sở hữu hệ thống). Trong bối cảnh rộng lớn như vậy, để bao hàm ý nghĩa của các thuật ngữ tiếng Anh “information security” (thiên về mặt tài nguyên), cũng như “computer security” và “network security” (thiên về mặt tài sản),



có thể định nghĩa an ninh tin học là những hoạt động nhằm hạn chế khả năng lạm dụng tài nguyên và tài sản tin học.

Trong định nghĩa trên, từ "hạn chế" hàm ý rằng không thể triệt phá hết ngay việc lạm dụng, cho nên cần sẵn sàng đề phòng mọi khả năng xấu với các phương cách thích hợp và chuẩn bị xử lý các sự cố nếu có việc lạm dụng xảy ra. Mà nói đến "lạm dụng" tức là đề cập đến yếu tố con người, do đó phải áp dụng các chính sách và biện pháp tổ chức tương ứng với từng loại đối tượng có khả năng cố tình hoặc vô ý vi phạm việc sử dụng đúng đắn những tài nguyên và tài sản tin học trên toàn bộ hệ thống.

1.4 An toàn bảo mật hệ thống thông tin

Định nghĩa: *Sự an toàn* (safety) của hệ thống thông tin thực chất là sự đảm bảo an ninh tin học ở mức độ chấp nhận được.

Những hoạt động đề phòng và xử lý sự cố đòi hỏi một loạt cố gắng tinh thần với các chi phí vật chất; chúng tỷ lệ thuận với khả năng và mức độ an toàn, nhưng nếu chúng ta không ý thức đầy đủ những điều nói trên thì mỗi nguy hiểm vẫn có thể vượt khỏi vòng kiểm soát, gây ra tai họa và sự lãng phí.

Muốn hệ thống thông tin an toàn thì trước hết phải có sự đảm bảo thông tin (information assurance) trên cơ sở hạ tầng mạng truyền dữ liệu thông suốt. Sau chữ an toàn thường có chữ bảo mật để mở rộng khía cạnh đảm bảo bí mật về nội dung thông tin.

Như vậy, an toàn bảo mật hệ thống thông tin là đảm bảo hoạt động lưu thông và nội dung bí mật cho những thành phần của hệ thống ở mức độ chấp nhận được.

Hai yếu tố an toàn và bảo mật đều rất quan trọng và gắn bó với nhau. Hệ thống mất an toàn thì không bảo mật được và ngược lại hệ thống không bảo mật được thì mất an toàn. Tuy nhiên, có thể phân biệt chúng rõ ràng hơn bằng những định nghĩa cụ thể như sau:

- Một hệ thống sẽ là an toàn khi các khiếm khuyết không thể làm cho các hoạt động chủ yếu của nó ngừng hẳn và các sự cố nếu xảy ra sẽ được khắc phục một cách kịp thời mà không gây thiệt hại đến mức độ nguy hiểm cho chủ sở hữu.
- Một hệ thống được coi là bảo mật (confident, secure) nếu tính riêng tư của nội dung thông tin được đảm bảo theo đúng các chỉ tiêu trong một thời gian xác định. Sở dĩ phải nêu những điều kiện như vậy bởi vì mọi sự việc đều chỉ có tính tương đối, thí dụ ngày nay đã có những máy tính rất mạnh và có thể giải mã được các bức điện mật trong thời gian khoảng một tuần.

Phân tích theo mô hình OSI của Tổ chức ISO, sự an toàn của hệ thống thông tin được thực hiện chủ yếu ở các tầng dưới (hạ tầng mạng phải đảm bảo lưu thông an toàn), còn việc bảo mật nội dung thông tin được thực hiện ở các tầng trên (các phần mềm ứng dụng phải đảm bảo việc mật mã hoá và giải mã). Thông tin có ý nghĩa đúng hay sai và sai đến mức nào là tùy thuộc vào việc đánh giá của con người chứ máy móc không thể tự quyết định.

1.5 Các mối đe dọa đối với một hệ thống và các biện pháp bảo vệ

1.5.1 Các mối đe dọa đối với một hệ thống thông tin

- *Phá hoại*: phá hỏng thiết bị phần cứng hoặc phần mềm trên hệ thống;
- *Sửa đổi*: tài sản của hệ thống bị sửa đổi trái phép;
- *Can thiệp*: tài sản bị truy cập bởi những người không có thẩm quyền, bị đánh cắp mật khẩu, bị mạo danh,...

1.5.2 Các đối tượng xâm hại hệ thống

Các đối tượng sau đây là các mối đe dọa đối với các hệ thống thông tin.

- *Từ bên trong hệ thống*: đây là những người có quyền truy cập hợp pháp đối với hệ thống;
- *Từ bên ngoài hệ thống*: tin tặc, bẻ khóa, ... ;
- *Phần mềm*: virus, do thám và các lỗ hổng trong các hệ điều hành và các chương trình ứng dụng.

1.5.3 Nguyên tắc và mục tiêu chung của an toàn bảo mật thông tin

Hai nguyên tắc của an toàn bảo mật thông tin là

- Việc thẩm định về bảo mật phải đủ khó và cần tính tới tất cả các tình huống, khả năng tấn công có thể được thực hiện.
- Tài sản phải được bảo vệ cho tới khi hết giá trị sử dụng hoặc hết ý nghĩa bí mật.

1.5.4 Các biện pháp bảo vệ thông tin

Khi người sử dụng hệ thống thông tin thay đổi một thông tin nào đó thì sẽ trở thành chủ sở hữu (owner) của thông tin đã thay đổi. Nhưng khi trao đổi một thông tin, thông tin đó chỉ có giá trị cao nhất đối với chủ sở hữu của nó và những đối tượng được phép truy cập nó hoặc những người nhận, nếu nó đảm bảo được 4 đặc điểm có tính chất nguyên tắc sau đây:



a) Tính sẵn sàng

Có tính sẵn sàng, hay truy cập được (availability, accessibility), nghĩa là thông tin phải có thể lấy được vào bất cứ lúc nào theo yêu cầu của chủ sở hữu và người sử dụng.

b) Tính toàn vẹn

Có tính toàn vẹn (integrity) nghĩa là thông tin không bị thay đổi (thêm, bớt, xoá bỏ) ngoài ý muốn của chủ sở hữu, trước khi sang tay người sử dụng.

c) Tính riêng tư

Có tính riêng tư, hay bí mật (privacy, confidentiality), nghĩa là nội dung thông tin của chủ sở hữu không bị người khác (trừ người sử dụng hợp pháp) đọc trộm, nghe trộm hoặc hiểu được.

d) Tính trách nhiệm

Có tính trách nhiệm, hay không chối bỏ (non-repudiation), nghĩa là chủ sở hữu và người sử dụng không thể phủ nhận việc đã gửi và nhận thông tin của nhau ở các thời điểm chính xác.

Bảo vệ thông tin là thực hiện mọi biện pháp cần thiết của quản trị để đảm bảo duy trì 4 tính chất vừa kể, làm cho hệ thống phục vụ được các yêu cầu chính đáng của chủ sở hữu và người sử dụng thông tin. Người quản lý tức người quản trị mạng và người quản trị việc bảo mật (nếu hệ thống nhỏ thì một nhân viên có thể kiêm cả hai nhiệm vụ này) không được vi phạm những nguyên tắc nói trên, cũng như không được lạm dụng quyền hạn và phương tiện của mình trong khi bảo vệ thông tin.

1.5.5 Các biện pháp bảo vệ mạng

Người quản lý phải cố gắng đảm bảo được 4 yêu cầu có tính chất cơ bản của mạng tin học là an toàn, tin cậy, dễ mở rộng và dễ quản trị. Những yêu cầu đó được giải thích cụ thể như sau.

a) Tính an toàn

An toàn (Safe): các luồng giao thông (traffic) trên mạng không bị tùy ý thay đổi tốc độ, chiều hướng, không bị va chạm, ách tắc và nhất là không bị đứt đoạn đường truyền. Trừ những trường hợp bất khả kháng (chiến tranh, thiên tai v.v...), một mạng được gọi là an toàn phải có khả năng làm việc như thế, liên tục suốt 24 giờ mỗi ngày và 7 ngày mỗi tuần mà không có sự cố nào kéo dài quá một giới hạn quy định (thí dụ 10 phút). Hiện nay, tin tặc chủ yếu dùng kiểu tấn công từ chối phục vụ (Deny of Service – DoS) để gây nghẽn mạng và do đó phá hoại tính an toàn.



b) Tính tin cậy

Tin cậy (Reliable): các thông tin được truyền đi theo thời biểu chính xác trong một giới hạn cho phép, gửi đến đúng địa chỉ người nhận và bảo toàn nội dung của mình y nguyên như khi xuất phát. Phải có đầy đủ các biện pháp theo dõi, kiểm tra, xử lý, ghi chép và báo cáo để mạng vận hành được như vậy.

c) Tính dễ mở rộng

Dễ mở rộng (Scaleable, Extendable): chủ sở hữu mạng và người quản trị mạng có thể mở rộng phạm vi hoạt động của mạng, dễ dàng lắp đặt, nâng cấp các thiết bị và phần mềm mạng mà ít gây ảnh hưởng đến những người sử dụng và thông tin lưu truyền trên đó.

d) Tính dễ quản trị

Dễ quản trị (Manageable): người quản trị mạng có thể quan sát, theo dõi, can thiệp việc sử dụng các tài nguyên mạng và quyền truy cập của những người sử dụng một cách đơn giản, thuận tiện và trực tuyến (online).

Thông tin (tài nguyên) và mạng tin học (tài sản) là hai bộ phận gắn bó rất chặt chẽ với nhau. Mạng tin học được hiểu như một hệ thống thông tin điện tử bao gồm những người sử dụng và quản lý, các máy tính xử lý dữ liệu, các thiết bị lưu trữ và kết nối, trao đổi dữ liệu. Dữ liệu được xử lý, lưu trữ và trao đổi qua lại giữa những thành phần trong mạng như vậy cho nên ở mọi nơi nó phải đối mặt với khả năng bị đọc trộm hoặc sao chép, thất thoát, thậm chí có thể bị thay đổi hoặc tăng thêm một cách trái phép vì nguyên nhân từ trong hoặc từ ngoài, dù vô tình hay cố ý.

Như đã nói, an ninh tin học chủ yếu bao gồm các hoạt động phát hiện, nghiên cứu, phân tích, đánh giá và thực hiện các biện pháp phòng chống sự lạm dụng thông tin trên mạng, cho nên cũng gần như đồng nghĩa với công tác an ninh mạng (Network Security). Ngày nay, số lượng các mạng tin học đã tăng lên hàng triệu và đạt tổng giá trị hàng trăm tỷ đô-la, vì vậy công tác này vừa hữu ích vừa mang lại lợi nhuận đáng kể.

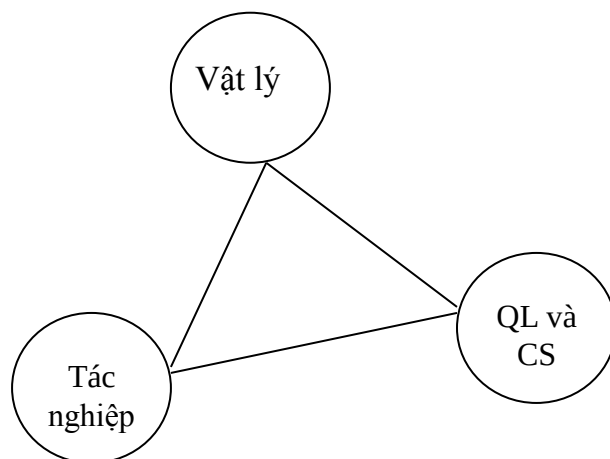
1.6 Các thành phần chính của an toàn tin học

Một hệ thống thông tin cần phải được trang bị một hệ thống an toàn, bảo mật bao gồm ba mức sau đây.

- An toàn mức vật lý;
- An toàn mức tác nghiệp;
- Quản lý và chính sách.

Các thành phần này tạo thành một tam giác an toàn thông tin cho hệ thống.





Hình 1-1: Tam giác an toàn thông tin

1.6.1 An toàn mức vật lý

An toàn ở mức vật lý là sự bảo vệ thông tin và tài sản của hệ thống chống lại các truy cập vật lý trái phép và không hợp lệ. Đảm bảo an toàn mức vật lý tương đối dễ thực hiện. Biện pháp bảo vệ đầu tiên là làm sao cho vị trí của tổ chức càng ít trở thành mục tiêu tấn công càng tốt. Biện pháp bảo vệ thứ hai là phát hiện và ngăn chặn các kẻ đột nhập và kẻ trộm bằng các hệ thống phát hiện từ xa như sử dụng máy quay phim và các thiết bị chống trộm cắp. Biện pháp bảo vệ thứ ba là các biện pháp trang bị các thiết bị dùng để khôi phục những dữ liệu hay hệ thống quan trọng sau khi bị trộm cắp hay mất mát.

1.6.2 An toàn mức tác nghiệp

Tác nghiệp (hoặc vận hành) hệ thống một cách an toàn liên quan đến những gì mà một tổ chức cần thực hiện để đảm bảo một chính sách an toàn. Việc vận hành này bao gồm cả hệ thống máy tính, mạng, hệ thống giao tiếp và quản lý thông tin. Vì vậy, vận hành an toàn bao hàm một lĩnh vực rộng lớn và cần phải được quan tâm một cách thích đáng.

a) Quy trình vận hành an toàn

Những vấn đề đặt ra cho vận hành an toàn bao gồm:

- Kiểm soát truy cập;
- Xác thực;
- An toàn topo mạng sau khi được thiết lập.

Các thao tác an toàn trên đây không liên quan đến việc bảo vệ ở mức vật lý và mức thiết kế.

Quy trình thao tác an toàn là sự kết hợp của tất cả các quá trình, các chức năng và các chính sách bao gồm cả yếu tố con người và yếu tố kỹ thuật. Yếu tố con người tập trung vào các chính sách được thực thi trong tổ chức. Yếu tố kỹ thuật bao gồm các công cụ được cài đặt vào hệ thống. Quá trình an toàn này được chia thành nhiều phần và được mô tả dưới đây.

– Phần mềm chống virus (Antivirus)

Virus máy tính là vấn đề phiền toái nhất hiện nay. Các phương thức chống virus mới ra đời cũng cần tiến kịp sự xuất hiện của chúng. Vì vậy, cần phải cài đặt và vận hành các chương trình phòng chống virus trực tuyến. Các chương trình và các tệp dữ liệu dùng để chống virus phải được cập nhật thường xuyên để đảm bảo hệ thống có thể chống lại những virus mới xuất hiện.

– Kiểm soát truy cập

Cần phải thiết lập một cơ chế kiểm soát những kiểu truy cập sau.

- + Kiểm soát truy cập bắt buộc (MAC – Mandatory Access Control) bằng cách sử dụng một tập các quyền truy cập được định nghĩa trước đối với các file trong hệ thống.
- + Kiểm soát truy cập tự do (DAC – Discretionary Access Control) bằng cách thiết lập một danh sách cấp quyền truy cập và kiểm soát truy cập tự do (ACL – Access Control List). Việc này do quản trị mạng thực hiện dưới sự chỉ đạo của lãnh đạo tổ chức.
- + Kiểm soát truy cập theo chức năng nhiệm vụ (RBAC-Role Based Access Control) được xác định trước theo đúng chức năng, nhiệm vụ, quyền hạn của từng người sử dụng trong hệ thống.

– Xác thực (Authentication)

Cần phải xây dựng, cài đặt và vận hành một hệ thống Định danh và Xác thực (Identification & Authentication - I&A) đối với tất cả những người sử dụng hệ thống.

Có thể sử dụng ba yếu tố sau đây để tiến hành thiết lập hệ thống I&A:

- + “Something you know” như mật mã hay số PIN (Personal Identification Number:);
- + “Something you have” như thẻ thông minh, thiết bị chứng thực;
- + “Something you own” như dấu vân tay, võng mạc mắt của người sử dụng.

Hiện tại có thể sử dụng những phương thức xác thực thông dụng sau đây:



- + Dùng Username/Password: Một tên truy cập và một mật khẩu là định danh duy nhất để đăng nhập. Máy chủ sẽ so sánh những thông tin này với những thông tin lưu trữ trong máy tính bằng các phương pháp xử lý bảo mật và sau đó quyết định chấp nhận hay từ chối sự đăng nhập.
- + Giao thức chứng thực CHAP – (Challenge HandShake Authentication Protocol)
- + Chứng chỉ (Certificate Authority - CA)
- + Bảo mật bằng Token
- + Phương pháp Kerberos
- + Chứng thực bằng thẻ thông minh (Smart Card)
- + Chứng thực bằng sinh trắc học (Biometric)

b) Những vấn đề cần lưu ý khi xây dựng quy trình an toàn bảo mật

- Cần xây dựng một quy trình phù hợp với trình độ và năng lực của nhân viên và hệ thống.
- Không nên tiêu tốn quá nhiều thời gian và tiền bạc vào những hệ thống an toàn phức tạp khi chưa có một chính sách an toàn phù hợp.
- Hãy cẩn thận với khuynh hướng sử dụng những tên người dùng thông dụng và những mật khẩu dễ đoán như :”123” hoặc “ abcd”...
- Sử dụng xác thực và đảm bảo an toàn đa yếu tố gồm một thẻ thông minh và một mật khẩu bí mật.

1.6.3 Quản trị và chính sách

Chính sách quản trị an toàn và an ninh thông tin cần phải thỏa mãn những yêu cầu sau đây:

- Cung cấp những hướng dẫn, những quy tắc, và những quy trình để thiết lập một môi trường thông tin an toàn.
- Hỗ trợ toàn diện và triệt để từ phía các nhà quản lý trong tổ chức.

Một số chính sách quan trọng sau đây cần phải được quán triệt trong toàn bộ tổ chức:

- Chính sách nhà quản lý và người sử dụng;
- Các yêu cầu thiết kế;



- Kế hoạch khôi phục sau một biến cố;
- Chính sách sử dụng thông tin;
- Chính sách an toàn;
- Chính sách về cách sử dụng.

Trong những chính sách trên đây, chính sách đối với người quản lý và người sử dụng là quan trọng nhất.

a) Chính sách người quản trị và người sử dụng

Công tác an ninh cho một mạng tin học bao gồm từ việc duy trì hoạt động trôi chảy của mọi thành phần mạng, đến việc tự giác tuân thủ quy trình thao tác của từng người sử dụng và người quản lý, để các dữ liệu trong khi lưu thông, xử lý hoặc lưu trữ, vẫn đảm bảo được tính toàn vẹn và riêng tư đối với chủ sở hữu của chúng. Muốn đạt được những điều nói trên, người sử dụng và người quản lý trước hết phải không ngừng theo dõi và phát hiện mọi nguy cơ tiềm ẩn trong mạng cũng như sự tấn công từ bên ngoài, đồng thời học hỏi và tuyên truyền để cùng nắm vững và thi hành những phương pháp phòng ngừa, sẵn sàng khắc phục tối đa các sự cố có thể xảy ra, thậm chí đủ khả năng phản công và phát hiện vị trí hoặc kỹ thuật của tin tặc.

Những nhiệm vụ như thế chỉ có thể làm tốt được bởi những con người vừa đáng tin cậy vừa có đủ tri thức cần thiết. Hơn thế nữa cần phải tạo lập được giữa họ một mối quan hệ tập thể, bao hàm cả sự phụ thuộc và giúp đỡ lẫn nhau trong tinh thần đồng đội.

Bảo vệ thiết bị, dữ liệu và phần mềm mới chỉ là một phần trong những biện pháp kỹ thuật của an ninh tin học. Kinh nghiệm thực tiễn cho thấy còn cần đặc biệt chú ý tới phương pháp làm việc công nghiệp và các biện pháp tổ chức.

An ninh tin học rất liên quan, thậm chí tùy thuộc vào ý thức và hành động của con người, nhất là trong điều kiện hiện nay của Việt Nam, nơi các phương pháp thủ công vẫn còn chiếm chỗ hàng đầu. Chương trình cải cách hành chính nhà nước giai đoạn 2001-2010 đang thay đổi các lề lối làm việc hiện hành, đa số những quy trình trong đó cần được tin học hoá và trở nên minh bạch nhằm có thể hội nhập khu vực và thế giới. Một trong những hành động cải cách là xây dựng hành lang pháp lý cho các giao dịch điện tử, chủ yếu sẽ dùng trong hành chính và thương mại. Điều này cũng tạo điều kiện và gắn liền với các nhiệm vụ đảm bảo an toàn hệ thống cho mạng thông tin.

Mục đích của mạng là để chia sẻ thông tin, vì vậy, chúng ta phải làm sao để việc thực hiện an ninh tin học không bị hiểu sai, lạm dụng hoặc biến nó thành lý do cát cứ



thông tin. Mặt khác lại không thể để chi phí cho nó tăng lên quá mức, giống như chi phí bảo vệ kho không thể đắt hơn giá trị hàng hóa chứa trong kho.

Những người sử dụng cần tích cực giúp đỡ, nhắc nhở lẫn nhau, nghiêm túc tuân theo nội quy cơ quan và mọi hướng dẫn hợp pháp của người quản lý. Trước hết họ phải cảnh giác, tự bảo vệ phần cứng, phần mềm, mật khẩu và thông tin, dữ liệu của chính mình và của mạng; không được tự tiện cho người khác biết mật khẩu hoặc đưa vào mạng những phần mềm, dữ liệu và thiết bị không rõ nguồn gốc.

Là người tham mưu và thực thi chính sách an ninh thông tin cho cơ quan hoặc chủ sở hữu mạng, người quản lý chịu trách nhiệm nắm vững tình hình cụ thể để kịp thời thông báo, nhắc nhở, quản trị, huấn luyện và phục vụ người sử dụng. Công việc quản trị bao gồm sao lưu dữ liệu, ghi nhật ký, viết báo cáo, phân loại người sử dụng, cấp phát, theo dõi hoặc cắt bỏ các chương khoản của người sử dụng và của các nhóm người sử dụng, v.v...

Người quản lý có quyền truy cập và phân phối mọi tài nguyên trên mạng nhưng phải tự giác không được soi mói vào các thông tin riêng của những người sử dụng hoặc tùy tiện cấm đoán, hạn chế những quyền lợi chính đáng của họ.

b) Các yêu cầu về thiết kế để đảm bảo an toàn cho hệ thống

Hệ thống cần phải được thiết kế để có thể đối phó với các rủi ro về an toàn. Những yêu cầu này là rất căn bản trong phần thiết kế ban đầu và nó có ảnh hưởng rất lớn đến các giải pháp được sử dụng. Các chính sách thiết kế phải được mô tả thật rõ ràng và phải đảm bảo được các yêu cầu bảo mật.

c) Kế hoạch khôi phục sau biến cố

Khôi phục lại hệ thống sau biến cố là một trong những vấn đề nhức đầu nhất mà các chuyên gia CNTT phải đối mặt. Cần phải bỏ rất nhiều công sức và tiền của để thực hiện việc kiểm tra, sao lưu, thiết lập hệ thống dự phòng sao cho có thể giữ cho hệ thống hoạt động liên tục. Hầu hết các công ty lớn đều đầu tư một số tiền lớn vào kế hoạch khôi phục bao gồm việc sao lưu dữ liệu và lập ra các địa điểm, gọi là “điểm nóng”, được thiết kế để cung cấp các dịch vụ nhanh chóng và thuận tiện nhất khi có sự cố xảy ra như hệ thống mạng bị sập hoặc bị “lụt”.

d) Chính sách thông tin

Cần phải xây dựng và ban hành một chính sách chi tiết về quyền truy suất, phân loại, đánh dấu và lưu trữ, chuyển giao và tiêu hủy những thông tin nhạy cảm. Để phát triển chính sách thông tin cần phải tiến hành xem xét, đánh giá, xếp loại các mức độ an toàn và bảo mật của từng loại thông tin.

e) Chính sách bảo mật

Xây dựng và thực hiện một chính sách bảo mật bao gồm những biện pháp sau đây:

- Cấu hình hệ thống và mạng tối ưu thông qua việc cài đặt và cấu hình một cách hợp lý các phần mềm, phần cứng và các kết nối mạng.
- Xác định và ủy quyền một cách rõ ràng quy chế điều khiển truy cập, kiểm toán và kết nối mạng.
- Cài đặt các phần mềm mã hóa và chống virus để thực thi chính sách bảo mật.
- Thiết lập các chức năng và các phương thức dùng để lựa chọn mật mã, thay đổi khóa bí mật, ngăn ngừa các truy cập bất hợp pháp và những tấn công gây hại cho hệ thống.

f) Chính sách sử dụng thông tin

Xây dựng và thực hiện một chính sách sử dụng thông tin liên quan đến những vấn đề sau:

- Thông tin về nguồn tài nguyên được sử dụng như thế nào, với mục đích gì.
- Những quy định về cách sử dụng máy tính như cách thức đăng nhập, các quy định về mật khẩu, về an toàn vật lý nơi làm việc,...
- Những quy định về sự riêng tư, quyền sở hữu và những hậu quả khi có những hành động không hợp pháp.
- Các quy định về việc sử dụng các chương trình truy cập Internet và Email.

g) Chính sách an toàn thông tin

Mục đích của an toàn thông tin rất rõ ràng và nó được lập thành một bộ khung để có thể căn cứ vào đó mà phát triển và duy trì một kết hoạch bảo vệ an toàn thông tin. Mục đích của an toàn thông tin bao gồm:

- Phòng ngừa
 - + Ngăn chặn các hành động xâm phạm máy tính hay thông tin một cách phạm pháp.
 - + Thiết lập các chính sách và các chức năng của hệ thống an toàn nhằm giảm thiểu nguy cơ bị tấn công. Chính sách ngăn chặn càng tốt thì mức độ thành công của các cuộc tấn công càng thấp.
- Phát hiện
 - + Xác định các sự kiện khi nó đang thực hiện. Trong nhiều trường hợp việc phát hiện này rất khó thực hiện.



- + Sử dụng một số công cụ đơn giản hoặc phức tạp, kiểm tra các logfile
- + Tiến hành thường xuyên liên tục các biện pháp trên.
- Đáp trả
 - + Phát triển các chiến lược và kỹ thuật yếu từ đơn giản đến phức tạp để có thể đáp trả các cuộc tấn công.
 - + Tạo ra các chức năng và phương thức cho việc khôi phục lại tài nguyên sau khi bị tấn công.

1.7 Sự không an toàn trong các dịch vụ và các giao thức

Mỗi dịch vụ và giao thức được sử dụng sẽ làm tăng tính dễ bị tấn công của hệ thống và làm cho xuất hiện các vấn đề tiềm năng về an ninh trong hệ thống. Hàng ngày người ta tìm được những lỗ hổng mới cho các dịch vụ và giao thức được sử dụng phổ biến trong hệ thống mạng máy tính.

Trong thực tiễn, để các hệ thống khác nhau từ nhiều nhà sản xuất khác nhau có thể nối kết được với nhau, thì những hệ thống này phải mở thông qua các giao diện và giao thức được chuẩn hóa. Mà chuẩn hoá cũng đồng nghĩa với việc công bố các đặc tả kỹ thuật cho mọi người đều biết. Nhưng việc công bố và áp dụng rộng rãi các tiêu chuẩn này cũng tạo ra một cơ hội cho tin tặc lợi dụng và khai thác chúng.

Đối chiếu từng công nghệ của những mạng tin học cụ thể với mô hình OSI, ta có thể thấy rằng các mối nguy hiểm có thể tiềm tàng ngay trong từng bộ phận, thành phần, đặc biệt ở các giao thức được sử dụng phổ biến nhất.

Bộ giao thức TCP/IP hiện đang được sử dụng rộng rãi nhất thế giới bởi mạng toàn cầu Internet và các mạng cục bộ kiểu Ethernet đều áp dụng nó. Sau đây là một số kẻ hở đã được phát hiện trong những giao thức chính thuộc họ TCP/IP. Rất may là phần lớn những kẻ hở này sau đó đã được khắc phục bởi các bản phần mềm nâng cấp. Dưới đây là một số kẻ hở bị lợi dụng đã được phát hiện trong các giao thức phổ dụng.

a) Kẻ hở trong giao thức SMTP

Trong giao thức chuyển thư điện tử đơn giản SMTP (Simple Mail Transfer Protocol) vốn không có cơ chế xác thực (Authentication), cho nên thư điện tử rất dễ bị kẻ xấu mạo danh (Spoofed). Nếu mail server được thiết lập để cho phép nối cổng SMTP thì bất cứ ai cũng có thể đưa đến đó những lệnh chuyển một bức thư điện tử với địa chỉ người gửi tùy ý, gây ra lộn lộn thật giả rất tai hại (trường hợp của phần lớn các virus mới).

b) *Kế hở trong giao thức LDAP*

Việc kết nối trong giao thức điều khiển truy cập các cấu trúc thư mục (LDAP - Lightweight Directory Access Protocol) được máy trạm thực hiện trực tiếp qua cổng 389, trước khi yêu cầu LDAP làm những việc như tìm kiếm (Search), bổ sung (Add),... Không có gì bảo đảm rằng máy trạm sẽ kết nối đến đúng máy chủ LDAP mà người dùng muốn truy cập đến bởi vì trong CSDL, tên miền (DNS) tin tặc có thể thay tên máy chủ LDAP thành máy chủ LDAP khác. Hoặc tin tặc cũng có thể cài đặt máy chủ LDAP của hắn lên máy chủ LDAP của người dùng. Mặt khác, mọi thông tin trao đổi giữa máy trạm và máy chủ LDAP đều ở dạng dữ liệu "rõ" (Plain Text), tức là chưa được mã hóa, nên tin tặc dễ dàng đọc và thay đổi được.

c) *Kế hở trong giao thức HTTP*

Giao thức chuyển siêu văn bản HTTP (HyperText Transfer Protocol) phiên bản 1.0 về cơ bản không cung cấp sơ đồ an toàn nào để trong phiên làm việc xác thực được những người sử dụng. Từ kế hở này sẽ nảy sinh ra các vấn đề sau:

- Thông tin ký tự ở máy chủ Web (Server Log Information) có thể bị lạm dụng và làm hại bởi những người sử dụng.
- Các công ty phần mềm viết các chương trình máy khách (Client) và tự đảm bảo độ an toàn của chúng. Người sử dụng đành phải tin vào sự tuyên truyền quảng cáo về năng lực của những công ty này.
- Thông tin chuyển tải không được an toàn mặc dù trong đó có thể chứa các nội dung cần giữ kín, thí dụ thư riêng hoặc mã số của thẻ tín dụng cá nhân, v.v...

d) *Kế hở trong giao thức DHCP*

Giao thức cấu hình động (Dynamic Host Configuration Protocol – DHCP) cung cấp cơ chế gán các địa chỉ IP động cho những thiết bị mạng để chúng có địa chỉ IP khác nhau mỗi khi nối vào mạng. Trong giao thức này tồn tại một kế hở gây ra lỗi tràn bộ đệm hướng ngăn xếp (Stack-Based) và nó có thể bị khai thác bằng cách gửi một thông điệp DHCP có chứa một giá trị tên máy chủ (Hostname) lớn.

e) *Kế hở trong giao thức FTP*

FTP (File Transfer Protocol) là một giao thức có nhiều kế hở lớn, kể cả khi được tăng cường bằng các cơ chế an ninh như IPsec (IP security) và SSH (Secure Socket Shell). Nhưng dù bất ổn như thế, cho đến nay trong thực tiễn FTP vẫn rất hay được dùng để tải các tệp tin lên máy chủ ở xa. Sau đây là một số trường hợp sơ hở của FTP:

- ***Khi gửi lệnh PASV***



Khi nạn nhân (client FTP) gửi lệnh truyền tệp thụ động (PASV), một tin tức có thể nhanh tay kết nối vào cổng TCP của máy chủ FTP trước nạn nhân này. Có thể so sánh địa chỉ đó với địa chỉ IP của máy khách để phát hiện tin tức, nhưng biện pháp này sẽ vô nghĩa nếu tin tức dùng chung (ở chế độ đa người dùng - multiuser) cùng một máy trạm hoặc máy proxy với nạn nhân (vì thế từ 1999 CERT đã khuyến nghị bỏ proxy FTP).

Có thể đề phòng bằng cách thiết lập cấu hình sao cho hệ điều hành từ chối mọi tín hiệu yêu cầu SYN sau yêu cầu đầu tiên, nhưng một số hệ điều hành lại không cho thiết lập như vậy.

Có thể cắt bỏ cuộc truyền nếu kiểm tra thấy có nhiều kết nối cùng được chấp nhận bằng ACK trên một cổng, nhưng biện pháp này không chắc chắn vì tín hiệu ACK cũng có khi bị mất hoặc trễ.

– ***Khi gửi lệnh PORT***

Khi máy khách FTP (nạn nhân) gửi lệnh PORT rồi chờ, một tin tức có thể kịp kết nối riêng với máy chủ và được máy chủ cho truy cập vào cổng TCP của máy khách. Nạn nhân không thể phân biệt vì nó là kết nối của máy chủ hợp pháp.

– ***Khi máy chủ kết nối***

Một tin tức có thể yêu cầu máy chủ FTP cho kết nối vào cổng TCP với địa chỉ IP bất kỳ và gửi một tệp được chọn bởi chính tin tức. Đó là kẻ hở nghiêm trọng nếu máy chủ này có quyền nối kết tường lửa hoặc các cổng đặc biệt khác.

f) Giao thức Telnet

Bản thân giao thức Telnet không có cơ chế đảm bảo an ninh. Khi cài đặt phần mềm thực hiện giao thức Telnet thường phải bổ sung các tùy chọn. Trong trường hợp phổ biến nhất, như một thiết bị đầu cuối (terminal) ở chế độ truy cập từ xa qua cổng TCP số 23, phần mềm thực hiện Telnet kết nối đến máy chủ, nó yêu cầu xác thực người sử dụng bằng cách kiểm tra tên và mật khẩu ở chế độ rõ, nhưng máy chủ lại không thể tự xác thực được cho mình.

Theo Microsoft, phần mềm thực hiện giao thức Telnet được cài đặt sẵn trong hệ điều hành Windows 2000 của họ, nhưng nó cũng không khắc phục được kẻ hở này của giao thức. Phần mềm Telnet trong hệ điều hành Windows 2000 thực sự đã chứa đựng tới 7 lỗi, bao gồm 4 lỗi không chống tấn công từ chối phục vụ, 2 lỗi không nâng được mức ưu tiên (Privilege Elevation) và 1 lỗi để lộ thông tin (Information Disclosure).



g) Giao thức IPsec và SSH

Các công nghệ an ninh lớp trên như IPsec (Internet Protocol security), SSL (Secure Socket Layer) và SSH (Secure Socket Shell) cung cấp cho các ứng dụng mạng một mức an ninh theo hướng đầu cuối (End-To-End Security), xét quan hệ giữa hai chủ thể bên gửi và bên nhận. Tuy nhiên trong thực tế, chúng phụ thuộc vào hai điều kiện sau:

- Một hạ tầng an toàn tương ứng, thí dụ có xác thực;
- Những người sử dụng có hiểu biết cao về tin học và luôn luôn thao tác đúng đắn kể cả trong những trường hợp bất thường.

Điều kiện thứ nhất có thể thực hiện được (thí dụ bằng hạ tầng mã hóa khóa công khai), nhưng điều thứ hai thì hiện nay không ai dám chắc. Mức an ninh từ bên gửi đến bên nhận được xây dựng ở tầng ứng dụng trên cùng và phụ thuộc vào sự an toàn của những tầng dưới. Nếu ở dưới là một mạng vô tuyến kiểu "Wi-Fi" với chế độ phát tán (Broadcast) thì không có gì đảm bảo rằng nhóm tin tặc không thu được tín hiệu trong vùng phủ sóng và không giải mã được.

h) Giao thức ICMP

Giao thức điều khiển thông điệp mạng Internet ICMP (Internet Control Message Protocol) là một giao thức liên mạng IP. ICMP cung cấp một cơ chế cho các thông báo điều khiển và thông báo lỗi. Thí dụ lệnh ping sử dụng các gói tin ICMP để kiểm tra việc kết nối giữa hai địa chỉ IP. Nhưng tin tặc có thể lợi dụng các gói tin ICMP không đến đích (Unreachable) để do thám một mạng. Nói chung cần phải ngăn cản hoặc phải lọc những gói tin ICMP không đến đích và những gói tin ICMP đổi hướng (Redirect) trong bộ định tuyến (Router).

i) Giao thức NTP v3

Giao thức NTP (Network Time Protocol) được dùng để đồng bộ và cập nhật thời gian trên các máy chủ và thiết bị mạng từ một số máy chủ NTP. Giao thức này có nhược điểm là tin tặc có thể tấn công bằng cách che dấu hoặc làm thay đổi giờ nhằm làm sai thời gian trong các tệp ký sự.

j) Giao thức SNMP

Giao thức SNMP (Simple Network Management Protocol) được dùng để quản trị, theo dõi và lập cấu hình cho việc quản trị các thiết bị mạng. Đáng tiếc là những tệp cấu hình mặc định (Default Configuration) của SNMP thường không mấy an toàn vì đã phát hiện được tin tặc có thể lợi dụng chúng để làm tê liệt tường lửa.



1.8 An toàn đồ hình mạng

An toàn của đồ hình (Topology) mạng phải được xác định trong quá trình thiết kế, triển khai và vận hành mạng. Bốn nội dung chính cần quan tâm là:

- Mục đích của việc thiết kế
- Vùng bảo mật
- Topology mạng
- Những yêu cầu kinh doanh

1.8.1 Mục đích của thiết kế

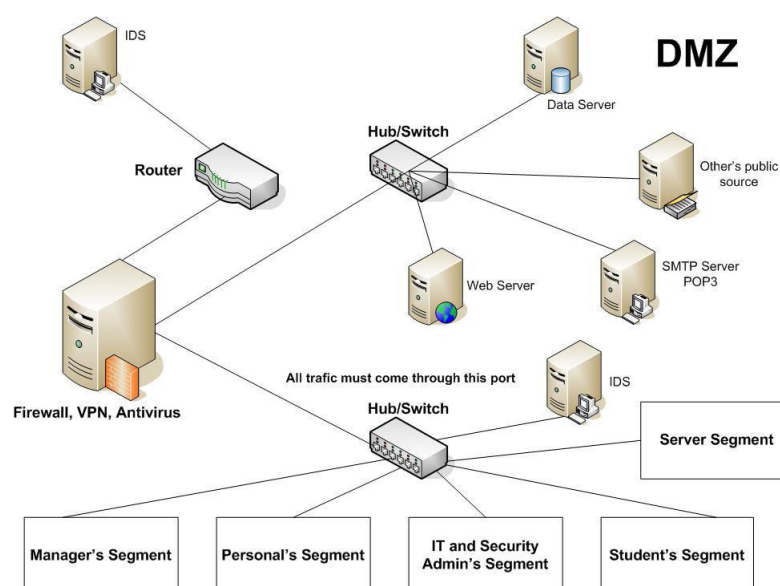
Mục đích của thiết kế là đảm bảo tính bí mật, tính toàn vẹn, tính hiệu lực và khả năng chịu trách nhiệm.

- *Tính bí mật*: ngăn cản hay hạn chế truy cập trái phép hoặc tiết lộ bí mật thông tin, dữ liệu.
- *Tính toàn vẹn*: đảm bảo dữ liệu đang làm việc không bị thay đổi so với dữ liệu gốc.
- *Tính sẵn sàng*: đảm bảo hệ thống sẵn sàng đối phó với mọi tình huống.
- *Chịu trách nhiệm*: ai chịu trách nhiệm trước mọi hoạt động của hệ thống.

1.8.2 Vùng bảo mật

Cần cách ly hệ thống để bảo vệ với những hệ thống hay mạng khác và khỏi những người truy cập không hợp lệ. Đây là một yêu cầu quan trọng khi thiết kế mạng.

Hình 1-2 là ví dụ về một mô hình bảo mật.



Hình 1-2: Mô hình bảo mật có một khu phi quân sự (DMZ)



1.9 Quản lý rủi ro

Để quản lý được các rủi ro cần phải thực hiện một qui trình bao gồm các bước sau đây:

- Xác định rủi ro, phát hiện các rủi ro tiềm ẩn đối với sự an toàn của hệ thống.
- Phân tích các mối đe dọa tiềm năng và các điểm yếu có thể gây tổn thất cho hệ thống.
- Đánh giá tổn thất có thể xảy ra trong quá trình sử dụng hoặc phụ thuộc vào hệ thống.
- Lựa chọn các giải pháp và các phương tiện tối ưu nhằm giảm thiểu rủi ro đến mức độ cho phép.
- Sử dụng các giải pháp bảo vệ nhằm giảm thiểu rủi ro và xác định mức độ rủi ro có thể chấp nhận được (rủi ro dư thừa) trong hệ thống.

1.10 Câu hỏi và bài tập

- 1.1) Thông tin là gì? Hệ thống thông tin bao gồm những thành phần nào?
Một hệ thống thông tin bao gồm những tài nguyên nào?
- 1.2) An ninh của một hệ thống thông tin là gì?
- 1.3) Sự an toàn của một hệ thống thông tin là gì?
- 1.4) Hãy nêu các mối đe dọa đối với một hệ thống thông tin và các biện pháp bảo vệ?
- 1.5) Các thành phần chính của an toàn tin học là những gì?



CHƯƠNG 2. MẬT MÃ HỌC

2.1 Sơ lược về lịch sử mật mã học

Mật mã học cổ điển: mật mã học là một ngành khoa học có một lịch sử khoảng 4000 năm. Các cổ vật của ngành khảo cổ học thu được đã cho thấy điều này. Người Ai Cập cổ đại đã sử dụng các chữ tượng hình như là một dạng mã hóa đơn giản nhất trên các bia mộ của họ [4]. Các tài liệu viết tay khác cũng cho thấy các phương pháp mã hóa đơn giản đầu tiên mà loài người đã sử dụng.

Mật mã học cổ điển hoạt động trên cơ sở bảng chữ cái (chẳng hạn các ký tự từ "A" tới "Z" trong tiếng Anh) và chúng được thực hiện bằng tay hay một số máy móc thô sơ sử dụng phương thức mã hóa cổ điển chủ yếu dựa trên *mật mã hóa hoán vị* và *mật mã hóa thay thế*. Phương thức này quá đơn giản nên vì vậy những kẻ tấn công có thể dễ dàng bẻ khóa thông qua nhiều phương thức như tấn công vét cạn (ví dụ dùng máy tính để thử hết mọi trường hợp) hay dựa trên tấn công thống kê (dựa trên tần suất xuất hiện của các chữ cái).

Người Hy Lạp cổ đại cũng được biết đến là đã sử dụng các kỹ thuật mật mã (chẳng hạn như mật mã scytale). Cũng có những bằng chứng rõ ràng chứng tỏ người La Mã nắm được các kỹ thuật mật mã (mật mã Caesar và các biến thể). Thậm chí đã có những đề cập đến một cuốn sách nói về mật mã trong quân đội La Mã; tuy nhiên cuốn sách này đã thất truyền.

Tại Ấn Độ, mật mã học cũng khá nổi tiếng. Trong cuốn sách Kama Sutra, mật mã học được xem là cách những người yêu nhau trao đổi thông tin mà không bị phát hiện.

Trong thế chiến II, các hệ thống mật mã cơ khí và cơ điện tử được sử dụng rộng rãi mặc dù các hệ thống thủ công vẫn được dùng tại những nơi không đủ điều kiện. Các kỹ thuật phân tích mật mã đã có những đột phá trong thời kỳ này, tất cả đều diễn ra trong bí mật. Cho đến gần đây, các thông tin này mới dần được tiết lộ do thời kỳ giữ bí mật 50 năm của chính phủ Anh đã kết thúc, các bản lưu của Hoa Kỳ dần được công bố cùng với sự xuất hiện của các bài báo và hồi ký có liên quan.

Các nhà mật mã học của Hải quân Mỹ (với sự hợp tác của các nhà mật mã học Anh và Hà Lan sau 1940) đã xâm nhập được vào một số hệ thống mật mã của Hải quân Nhật. Việc xâm nhập vào hệ thống JN-25 trong số chúng đã mang lại chiến thắng vẻ vang cho Mỹ trong trận Midway. Một nhóm trong quân đội Mỹ đã thành công trong



việc xâm nhập hệ thống mật mã ngoại giao tối mật của Nhật (một máy cơ điện dùng "bộ chuyển mạch dịch bước" được người Mỹ gọi là Purple) ngay cả trước khi thế chiến II bắt đầu. Người Mỹ đặt tên cho những bí mật mà họ tìm được từ việc thám mã, có thể đặc biệt là từ việc phá mã máy Purple, với cái tên "Magic". Người Anh sau này đặt tên cho những bí mật mà họ tìm ra trong việc thám mã, đặc biệt là từ luồng thông điệp được mã hóa bởi các máy Enigma, là "Ultra".

Mật mã học hiện đại: Lịch sử của mật mã học được đánh dấu vào năm 1949 khi Claude Shannon công bố bài báo *Lý thuyết truyền thông trong các hệ thống bảo mật* (Communication Theory of Secrecy Systems) trên *Tập san Kỹ thuật của Hệ thống Bell* (Bell System Technical Journal) và một thời gian ngắn sau đó, trong cuốn *Lý thuyết toán học trong truyền thông* (Mathematical Theory of Communication) cùng với tác giả Warren Weaver. Những công trình này cùng với những công trình nghiên cứu khác của ông về lý thuyết thông tin và truyền thông (Information and Communication Theory), đã thiết lập một nền tảng lý thuyết cơ bản cho mật mã học và thám mã học sau này.

Vào những năm đầu của thập kỷ 70 của thế kỷ trước, thế giới được chứng kiến hai công trình lớn, đó là công bố về *Tiêu chuẩn mật mã hóa dữ liệu DES* (Data Encryption Standard) của Mỹ năm 1975. DES là một phương thức mật mã hóa đầu tiên được một cơ quan quốc gia như NSA của Mỹ sử dụng. Nó đã khuyến khích sự quan tâm chú ý của công chúng cũng như của các tổ chức nghiên cứu về mật mã học. Tiếp theo, năm 1976 chứng kiến sự phát triển của các thuật toán mã hóa khóa công khai sau khi Whitfield Diffie và Martin Hellman công bố bài báo *New Directions in Cryptography* làm nền tảng cho sự ra đời của các hệ mã khóa công khai, hệ mã hóa khóa bất đối xứng (Asymmetric Key Algorithms).

Tuy nhiên, do nhược điểm của các hệ mã mật khóa công khai là chậm khi mã hóa các khối dữ liệu lớn, cho nên các hệ mã khối, mã đối xứng vẫn tiếp tục được phát triển. Một số hệ mã khối mới đã được phát triển để thay thế cho DES vào cuối thế kỷ 20 như IDEA, AES hoặc 3DES.

2.2 Những khái niệm cơ bản

Mã hóa: mã hóa (Encryption) là phương pháp biến đổi dữ liệu, thông tin (văn bản, hình ảnh, video,...) từ dạng bình thường, nguyên bản sang dạng thông tin không thể đọc, không thể hiểu được trực tiếp nếu không có phương tiện giải mã.



Giải mã: giải mã (Decryption) là phương pháp biến đổi dữ liệu, thông tin (văn bản, hình ảnh, video,...) từ dạng thông tin đã được mã hóa về dạng thông tin ban đầu, quá trình ngược của mã hóa.

Thám mã: thám mã (Cryptanalysis) là quá trình tìm những điểm yếu hoặc không an toàn trong phương thức mã hóa để từ đó tìm ra khóa giải mã hoặc tìm ra nguyên bản. Thám mã có thể được thực hiện bởi những kẻ tấn công ác ý, nhằm làm hỏng hệ thống; hoặc bởi những người thiết kế ra hệ thống (hoặc những người khác) với ý định đánh giá độ an toàn của hệ thống.

Hệ mật mã: một hệ mật mã là một bộ gồm 5 thành phần (P, C, K, E, D) thỏa mãn các điều kiện sau đây [2]:

P là tập hữu hạn các bản tin rõ, nguyên bản (Plain Text)

C là một tập hữu hạn các bản mã (Cipher Text)

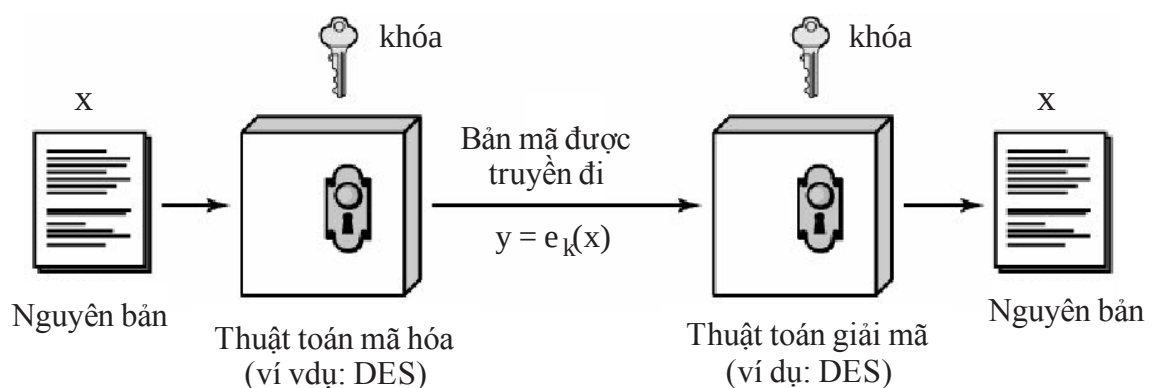
K là không gian hữu hạn các khóa (Key)

E là tập các thuật toán mã hóa (Encryption Algorithm)

D là tập hợp các thuật toán giải mã (Decryption Algorithm)

Với mỗi khóa $k \in K$, tồn tại một thuật toán mã hóa $e_k \in E$ và một thuật toán giải mã $d_k \in D$, trong đó $e_k: P \rightarrow C$ và $d_k: C \rightarrow P$ là các hàm sao cho $d_k(e_k(x)) = x$ với mọi $x \in P$.

Mô hình hệ mật mã: Mô hình hệ mật mã tổng quát được minh họa như trong Hình 2-1.



Hình 2-1: Mô hình hệ mật mã tổng quát

Mô hình trên sử dụng phương pháp mã hóa thông tin x ở dạng nguyên bản để tạo ra một văn bản được mã hoá y theo một quy luật riêng thông qua khóa k (k có thể là

khóa bí mật hoặc khóa riêng, tùy theo hệ mã), y được gửi qua kênh truyền tới bên nhận, người nhận dùng thuật toán giải mã và khóa để giải mã y và thu được x.

2.3 Phân loại các thuật toán mật mã

Các thuật toán mã hóa khóa bí mật: Các thuật toán mã hóa khóa bí mật được sử dụng trong các hệ mã hóa khóa đối xứng SKC (Symmetric Key Cryptosystems) do vai trò của người nhận và người gửi là như nhau. Cả hai bên đều có thể mã hóa và giải mã thông điệp bằng cùng một khoá, như Caesar, DES, AES. Do đó nó cần phải được giữ bí mật vì nếu bị lộ, hệ mã hóa không còn tác dụng mật hóa nữa.

Các thuật toán mã hóa khóa công khai: Các thuật toán mã hóa khóa công khai được sử dụng trong các hệ mã hóa khóa công khai PKC (Public Key Cryptosystems). Các hệ mã này còn được gọi là các hệ mã khóa bất đối xứng (Asymmetric Key Cryptosystems). Thay vì chỉ sử dụng một khóa như các thuật toán mã hóa khóa bí mật, các thuật toán mã hóa khóa công khai dùng một cặp khoá, một khóa cho mã hóa và một khóa cho giải mã. Trong cặp khóa này, có một khóa được công bố công khai tới các đối tác giao dịch và một khóa được giữ bí mật chỉ người sở hữu nó được biết.

Các thuật toán tạo chữ ký số: Các thuật toán tạo chữ ký số (Digital Signature Algorithms). Thông thường, mỗi hệ chữ ký số có cùng cơ sở lý thuyết với một hệ mật mã khóa công khai nhưng với các cách áp dụng khác nhau. Trong giáo trình này, chỉ đề cập đến hai hệ chữ ký số phổ biến là RSA và El Gamma.

Các hàm băm: (Hash functions) tương ứng với các thuật toán băm thường được sử dụng trong các hệ chữ ký số hoặc các hệ mã hoá khóa công khai để tạo ra bản băm cho một tập tin. Nó chính là một thông điệp hay một khối dữ liệu để xác thực nguồn gốc hoặc tính toàn vẹn của chúng sau khi truyền đi trong môi trường công cộng.

2.4 Ứng dụng của mật mã học

Ngày nay, các ứng dụng trên máy tính cá nhân hay các chương trình hệ thống như các hệ điều hành, các dịch vụ mạng hoặc các hệ cơ sở dữ liệu đều có sử dụng các thuật toán mã hóa để mã hóa mật khẩu người dùng hoặc tin nhắn bằng một hệ mật mã hoặc một hàm băm nào đó. Đặc biệt với sự phát triển mạnh mẽ của thương mại điện tử, các mô hình chữ ký số ngày càng đóng vai trò tích cực cho một môi trường an toàn cho người dùng. Tuy vậy chúng ta vẫn có thể chia các lĩnh vực ứng dụng của mật mã học thành các lĩnh vực nhỏ như sau:



- **Bảo mật** (Confidentiality): che dấu nội dung của các thông điệp được trao đổi trong một phiên truyền thông hoặc giao dịch hoặc các thông điệp trên một hệ thống máy tính (các file, dữ liệu trong một cơ sở dữ liệu...).
- **Xác thực** (Authentication): đảm bảo nguồn gốc của một thông điệp, người dùng.
- **Toàn vẹn** (Integrity): đảm bảo chỉ có các tổ chức đã được xác thực hóa mới có thể thay đổi các tài sản của hệ thống cũng như các thông tin trên đường truyền.
- **Không thể chối bỏ** (Non-Repudiation): các bên đã được xác thực không thể phủ nhận việc tham gia vào một giao dịch hợp lệ.
- Ngoài ra còn các dịch vụ quan trọng khác chẳng hạn như chữ ký điện tử, dịch vụ chứng thực danh tính (Identification) cho phép thay thế hình thức xác thực hóa người dùng dựa trên các mật khẩu bằng các kỹ thuật mạnh hơn hoặc dịch vụ thương mại điện tử cho phép tiến hành các giao dịch an toàn trên các kênh truyền thông không an toàn.

2.5 Số học modulo

2.5.1 Định nghĩa modulo

Cho số tự nhiên n và số nguyên a (n thuộc $\mathbb{N}$; a thuộc $\mathbb{Z}$). Ta định nghĩa **a modulo n** và viết tắt là **a mod n** là phần dư dương khi chia a cho n , nghĩa là

$$a = \lfloor a/n \rfloor * n + (a \bmod n) \quad (2.7)$$

Trong đó $\lfloor a/n \rfloor$ là số nguyên lớn nhất bé hơn hoặc bằng a/n . Số n được gọi là số modulo.

Hai số nguyên a và b được gọi là đồng dư modulo n , khi và chỉ khi a và b có cùng phần dư khi chia cho n . Tức là $a \bmod n = b \bmod n$ và được ký hiệu là

$$a \equiv b \bmod n \quad (2.8)$$

Ví dụ 2.1 $100 \bmod 11 = 1$; $34 \bmod 11 = 1$, nên $100 \equiv 34 \bmod 11$. Số b được gọi là đại diện của a theo modulo n nếu $a \equiv b \bmod n$, tức là $(a = q.n + b)$ và $0 \leq b < n$.

Ví dụ 2.2 $-12 \bmod 7 \equiv -5 \bmod 7 \equiv 2 \bmod 7 \equiv 9 \bmod 7$.

Ở đây 2 là đại diện của -12, -5, 2 và 9 theo modulo 7.

Suy rộng ra, trong modulo 7 ta có các lớp tương đương viết trên các hàng như sau:



Bảng 2-1: Các lớp tương đương theo modulo 7

-21	-20	-19	-18	-17	-16	-15
-14	-13	-12	-11	-10	-9	-8
-7	-6	-5	-4	-3	-2	-1
0	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30	31	32	33	34

Các phần tử trên cùng một cột có quan hệ đồng dư với nhau.

Tập các đại diện của các số nguyên theo modulo n bao gồm n phần tử cơ sở $\{0, 1, 2, \dots, n-1\}$ và được ký hiệu là tập Z_n :

$$Z_n = \{0, 1, 2, \dots, n-1\}$$

2.5.2 Ước số

Số b không âm được gọi là ước số của a , nếu tồn tại một số m sao cho $a = m \cdot b$, trong đó a, b, m đều là các số nguyên, dấu $*$ là ký hiệu của phép nhân số học. Tức là a chia hết cho b và được ký hiệu là $b|a$.

Ví dụ 2.3 1, 2, 3, 4, 6, 8, 12, 24 là các ước số của 24.

2.5.3 Các phép toán số học trên modulo

Cho trước một số nguyên dương n , ta muốn thực hiện các phép toán theo modulo của n . Ta có thể thực hiện các phép toán trên các số nguyên như các phép cộng, nhân các số nguyên thông thường sau đó rút gọn lại bằng phép lấy modulo hoặc cũng có thể vừa tính toán vừa rút gọn tại bất cứ thời điểm nào:

$$(a+b) \bmod n = [a \bmod n + b \bmod n] \bmod n \quad (2.9)$$

$$(a \cdot b) \bmod n = [a \bmod n \cdot b \bmod n] \bmod n \quad (2.10)$$

Như vậy khi thực hiện các phép toán ta có thể thay các số bằng các số tương đương theo modulo n hoặc đơn giản hơn có thể thực hiện các phép toán trên các đại diện của nó.

Các chú ý về tính chất rút gọn:

Nếu $(a+b) \equiv (a+c) \bmod n$, thì $b \equiv c \bmod n$.



Nhưng $(ab) \equiv (ac) \pmod n$, thì $b \equiv c \pmod n$ chỉ khi nếu a là nguyên tố cùng nhau với n .

Ví dụ 2.4 Áp dụng các tính chất của modulo, tính giá trị của biểu thức sau:

$$\begin{aligned}(11 \cdot 19 + 10^{17}) \pmod 7 &= \\ ((11 \cdot 19) \pmod 7 + 10^{17} \pmod 7) \pmod 7 &= \\ ((11 \pmod 7 \cdot 19 \pmod 7) \pmod 7 + (10 \pmod 7)^{17} \pmod 7) \pmod 7 &= \\ ((4 \cdot (-2)) \pmod 7 + (((3^2)^2)^2 \cdot 3 \pmod 7) \pmod 7) \pmod 7 &= \\ ((-1) \pmod 7 + ((2^2)^2 \cdot 3 \pmod 7) \pmod 7) \pmod 7 &= (-1 + 5) \pmod 7 = 4\end{aligned}$$

2.5.4 Vành Z_n (vành đồng dư modulo n)

Tập các số nguyên $Z_n = \{0, 1, \dots, n-1\}$ trong đó n là một số tự nhiên dương với hai phép toán cộng (+) và nhân (*) được định nghĩa như sau tạo thành một vành đồng dư modulo n (hay còn gọi là tập thặng dư đầy đủ theo modulo n):

$$\text{Phép cộng: } \forall a, b \in Z_n: a + b = (a + b) \pmod n. \quad (2.11)$$

$$\text{Phép nhân: } \forall a, b \in Z_n: a * b = (a * b) \pmod n. \quad (2.12)$$

Theo tính chất của modulo số học chúng ta dễ dàng nhận thấy Z_n là một vành giao hoán và kết hợp. Hầu hết các tính toán trong các hệ mã mật đều được thực hiện trên một vành Z_n nào đó.

Trên vành Z_n số 0 là phần tử trung hòa vì $a + 0 = 0 + a = a$, $\forall a \in Z_n$, số 1 được gọi là phần tử đơn vị vì $a * 1 = 1 * a = a$, $\forall a \in Z_n$.

Z_n với các phép toán theo modulo tạo thành vành giao hoán có đơn vị. Thực vậy tính đóng của các phép cộng và nhân dựa trên hai công thức (2.9) và (2.10). Các tính chất kết hợp, giao hoán và nghịch đảo được suy ra từ các tính chất tương ứng với các số nguyên.

2.5.5 Các số nguyên tố

Như chúng ta đã biết số nguyên tố là các số nguyên dương chỉ chia hết cho 1 và chính nó, chúng không thể được viết dưới dạng tích của các số khác.

Hợp số là các số nguyên dương có thể phân tích được ra thừa số. Trong các số nguyên nhỏ hơn 10, ta có các số 2, 3, 5, 7 là số nguyên tố, vì chúng không có ước số khác 1 và chính nó; còn các số 4, 6, 8, 9, 10 không phải là số nguyên tố. Số 2 là số nguyên tố chẵn duy nhất. Các số nguyên tố là trung tâm của lý thuyết số và số lượng của chúng là vô hạn.



Ví dụ 2.5 Sau đây là danh sách các số nguyên tố nhỏ hơn 200:

2 3 5 7 11 13 17 19 23 29 31 37 41 43 47 53 59 61 67 71 73 79 83 89 97 101 103
107 109 113 127 131 137 139 149 151 157 163 167 173 179 181 191 193 197 199

2.5.6 Ước số chung lớn nhất (Greatest Common Divisor)

Ước số chung lớn nhất của hai số nguyên dương a và b là số nguyên lớn nhất mà cả a và b cùng chia hết, và được ký hiệu là $\text{GCD}(a, b)$.

Ví dụ 2.6 $\text{GCD}(60, 24) = 12$; $\text{GCD}(6, 15) = 3$; $\text{GCD}(8, 21) = 1$.

Nguyên tố cùng nhau: Hai số nguyên a và b được gọi là nguyên tố cùng nhau nếu ước số chung lớn nhất của chúng bằng 1.

Ví dụ 2.7 Hai số 8 và 15 là nguyên tố cùng nhau vì $\text{GCD}(8, 15) = 1$.

Tìm ước chung lớn nhất: bây giờ chúng ta xét bài toán tìm ước số chung lớn nhất của hai số nguyên dương cho trước. Ta có các tính chất sau:

$$\text{GCD}(a, a) = a$$

$$\text{Nếu } b|a \text{ thì } \text{GCD}(a, b) = b$$

$$\text{GCD}(a, 0) = a \text{ vì } a|0 \text{ luôn luôn đúng (0 luôn chia hết cho } a)$$

$$\text{GCD}(a, b) = \text{GCD}(b, a \bmod b)$$

Thật vậy, với hai số nguyên dương $a > b$ bất kỳ, có thể được biểu diễn dưới dạng:

$$a = q \cdot b + r \quad \text{hay} \quad a \bmod b = r$$

trong đó, $q \geq 1$ và $r \geq 0$. Do đó, nếu d là ước số chung lớn nhất của a và b thì d cũng là ước số chung lớn nhất của b và r . Ngược lại, nếu d là ước số chung lớn nhất của b và r thì d cũng là ước số chung lớn nhất của a và b .

Ví dụ 2.8 $\text{GCD}(55, 22) = \text{GCD}(22, 55 \bmod 22) = \text{GCD}(22, 11) = 11$;

Như vậy để tìm ước số chung của một cặp số cho trước, ta đưa về bài toán tìm ước chung của cặp số gồm số nhỏ hơn trong hai số đó và phần dư của số lớn khi chia cho số nhỏ hơn. Thuật toán Euclide tạo nên một vòng lặp, ở mỗi bước ta áp dụng tính chất trên cho đến khi phần dư đó bằng 0.

Thuật toán Euclide tìm $\text{GCD}(a, b)$

```
A = a, B = b
while B > 0 do
    R = A mod B
    A = B, B = R
return A
```



Ví dụ 2.9 $\text{GCD}(1970, 1066)$;

$$1970 = 1 \times 1066 + 904 \quad \text{GCD}(1066, 904)$$

$$1066 = 1 \times 904 + 162 \quad \text{GCD}(904, 162)$$

$$904 = 5 \times 162 + 94 \quad \text{GCD}(162, 94)$$

$$162 = 1 \times 94 + 68 \quad \text{GCD}(94, 68)$$

$$94 = 1 \times 68 + 26 \quad \text{GCD}(68, 26)$$

$$68 = 2 \times 26 + 16 \quad \text{GCD}(26, 16)$$

$$26 = 1 \times 16 + 10 \quad \text{GCD}(16, 10)$$

$$16 = 1 \times 10 + 6 \quad \text{GCD}(10, 6)$$

$$10 = 1 \times 6 + 4 \quad \text{GCD}(6, 4)$$

$$6 = 1 \times 4 + 2 \quad \text{GCD}(4, 2)$$

$$4 = 2 \times 2 + 0$$

$$\text{GCD}(1970, 1066) = 2 \text{ (trong đó dấu } \times \text{ là ký hiệu của phép nhân số học)}$$

2.5.7 Nghịch đảo a^{-1} modulo n

Cho a và n là hai số nguyên, nguyên tố cùng nhau. Số d được gọi là nghịch đảo của a modulo n khi và chỉ khi $(a \cdot d) \bmod n = 1$. Số d được ký hiệu là a^{-1} .

Ví dụ 2.10

$$11^{-1} \bmod 7 = 4^{-1} \bmod 7 = 2 \text{ vì } 2 \cdot 4 \bmod 7 = 1. \text{ Suy ra nghịch đảo của}$$

$$11^{-1} \bmod 7 = 2$$

$$7^{-1} \bmod 11 = 8, \text{ vì } 7 \cdot 8 \bmod 11 = 56 \bmod 11 = 1.$$

Ta mở rộng thuật toán Euclide tìm ước chung lớn nhất của n và a để tính nghịch đảo trong trường hợp $\text{GCD}(n, a) = 1$. Giải thuật sau chỉ thực hiện với các số nguyên $n > a > 0$, biểu diễn bằng giả mã:

Thuật toán tìm giá trị nghịch đảo modulo

Đầu vào: a, n nguyên

Đầu ra: giá trị nghịch đảo của a mod n hoặc không có

Bước 1: $y_0=0, y_1=1; r=0; q=0; y=0;$

Bước 2: while (a>=1) do {

$r = n \bmod a;$

if (r = 0) then break;

$q = n \div a;$

$y = y_0 - y_1 * q;$

$n = a;$

$a = r; y_0 = y_1; y_1 = y;$

}

Bước 3: if (a < 1) thì quay lại bước 2, ngược lại thì sang bước 4.

Bước 4: if (a > 1) then return "a không có nghịch đảo theo modulo n"

Bước 5 : if (y > 0) then return y

else return (n + y);

Ví dụ 2.11 Tìm số nghịch đảo nếu có của 30 theo modulo 101 dựa vào thuật toán Euclid mở rộng: $\text{GCD}(30, 101) = 1$

Bảng 2-2: Minh họa các bước tìm nghịch đảo của 30 modulo 101

Bước i	n	a	r	q	y ₀	y ₁	y
1	101	30	11	3	0	1	-3
2	30	11	8	2	1	-3	7
3	11	8	3	1	-3	7	-10
4	8	3	2	2	7	-10	27
5	3	2	1	1	-10	27	-37
6	2	1	0				

Kết quả tính toán trong bảng cho ta -37. Vậy $30^{-1} \bmod 101 = -37 + 101 = 64$.



Ví dụ 2.12 Tìm nghịch đảo của 550 trong $GL(1759)$.

Bảng 2-3: Minh họa các bước tìm nghịch đảo của 550 modulo 1759

Bước i	n	a	r	q	y0	y1	y
1	1759	550	109	3	0	1	-3
2	550	109	5	5	1	-3	16
3	109	5	4	21	-3	16	-339
4	5	4	1	1	16	-339	355
5	4	1	0				

Sau 4 bước, ta có $a = 1$, khi đó thuật toán dừng, $GCD(1759, 550) = 1$ và $550^{-1} \bmod 1759 = 355$.

2.5.8 Định lý Euler

Nếu n là số nguyên dương bất kỳ và a là số nguyên tố cùng nhau với n thì

$$a^{\Phi(n)} \bmod n = 1 \quad (2.13)$$

trong đó, $\Phi(n)$ là số các số nguyên $\in \mathbb{Z}_n$ nguyên tố cùng nhau với n , được gọi là hàm Euler. Chẳng hạn, nếu p là một số nguyên tố thì giá trị của hàm Euler của p :

$\Phi(p) = p - 1$ hoặc nếu $n = p \cdot q$ trong đó p và q là hai số nguyên tố thì $\Phi(n) = (p-1) \cdot (q-1)$, $a^{\Phi(n)}$ chính là giá trị nghịch đảo của a trên $\mathbb{Z}_n$.

Chứng minh: Giả sử $x_1, x_2, \dots, x_{\Phi(n)}$ là các số tự nhiên khác nhau, nhỏ hơn n và nguyên tố cùng nhau với n .

Xét tất cả các khả năng của tích $x_i \cdot a$ với $i = 1, \dots, \Phi(n)$. Bởi vì a là nguyên tố cùng nhau với n và x_i là nguyên tố cùng nhau với n , nên tích $x_i \cdot a$ cũng nguyên tố cùng nhau với n , do đó có

$$x_i \cdot a \equiv x_i \bmod n. \quad (2.14)$$

Chú ý rằng các phần dư của phép chia $x_i \cdot a$ cho n là khác nhau. Nếu điều này không đúng, có nghĩa là tồn tại $i_1 \neq i_2$, sao cho: $x_{i_1} \cdot a \equiv x_{i_2} \bmod n$.

Cho nên $(x_{i_1} - x_{i_2}) \equiv 0 \bmod n$. Bởi vì a nguyên tố cùng nhau với n , nên biểu thức cuối cùng tương đương với: $x_{i_1} - x_{i_2} \equiv 0 \bmod n$

Điều này là mâu thuẫn, bởi các số $x_1, x_2, \dots, x_{\Phi(n)}$ là các cặp khác nhau theo modulo n .



Hãy nhân tất cả các đẳng thức $x_i * a \equiv x_j \pmod n$ lại với nhau, ta thu được $x_1 \dots x_{\Phi(n)} a^{\Phi(n)} \equiv x_1 \dots x_{\Phi(n)} \pmod n$.

Hay: $x_1 \dots x_{\Phi(n)} (a^{\Phi(n)} - 1) \equiv 0 \pmod n$

Bởi vì số $x_1 \dots x_{\Phi(n)} \pmod n$ là nguyên tố cùng nhau với n nên đẳng thức cuối cùng tương đương với:

$a^{\Phi(n)} - 1 \equiv 0 \pmod n$ hay $a^{\Phi(n)} \equiv 1 \pmod n$.

Ví dụ 2.13

Cho $a = 3$; $n = 10$: chỉ có 4 số nhỏ hơn 10 là 1, 3, 7, 9 nguyên tố cùng nhau với 10 nên suy ra $\Phi(10) = 4$; Do $3^4 = 81 = 1 \pmod{10}$ tức là $3^{\Phi(10)} = 1 \pmod{10}$, đúng như khẳng định của định lý Euler

Cho $a = 2$; $n = 11$: vì 11 là số nguyên tố nên $\Phi(11) = 11-1=10$; Do $2^{10} = 1024 = 1 \pmod{11}$ tức là $2^{\Phi(10)} = 1 \pmod{11}$.

Ví dụ 2.14

Với $n = 10$:

- Tập đầy đủ các phần dư là: $\{0, 1, 2, 3, 4, 5, 6, 7, 8, 9\}$
- Tập rút gọn các phần dư nguyên tố cùng nhau với 10 là: $\{1, 3, 7, 9\}$ Số các phần tử của tập rút gọn trên được gọi là giá trị của hàm Euler và được ký hiệu là $\Phi(n)$. Trong ví dụ trên thì $\Phi(10) = 4$.
- Muốn tính $\Phi(n)$ cần phải đếm được số các số nguyên tố cùng nhau với n và nhỏ hơn n . Đây là một bài toán khó.
- Nói chung có thể tính hàm Euler của một số dựa trên biểu thức phân tích ra thừa số của số đó.

+ $\Phi(1) = 1$

+ Nếu p là số nguyên tố thì $\Phi(p) = p - 1$. Nếu p và q là hai số nguyên tố khác nhau thì: $\Phi(p*q) = (p - 1)(q - 1)$. Nếu p là số nguyên tố, thì

+ $\Phi(p^n) = p^n - p^{n-1}$

+ Nếu s và t là hai số nguyên tố cùng nhau, thì $\Phi(s.t) = \Phi(s)*\Phi(t)$

Ví dụ 2.15

$\Phi(37) = 37 - 1 = 36$

$\Phi(21) = (3-1) \times (7-1) = 2 \times 6 = 12$



$$\begin{aligned}\Phi(72) &= \Phi(8 \cdot 9) = \Phi(8) \cdot \Phi(9) = \Phi(2^3) \cdot \Phi(3^2) = \\ &= (2^3 - 2^2)(3^2 - 3^1) = 4 \cdot 6 = 24\end{aligned}$$

Định lý Euler là tổng quát hoá của định lý Ferma.

Ví dụ 2.16: Các số 5 và 7 là các số nguyên tố, 2 và 3 không là bội tương ứng của 7 và 5, nên theo định lý Ferma ta có:

$$2^{7-1} \bmod 7 = 1 \quad (= 2^6 \bmod 7 = 64 \bmod 7 = 1)$$

$$3^{5-1} \bmod 5 = 1 \quad (= 3^4 \bmod 5 = 81 \bmod 5 = 1)$$

$$(-2)^{11-1} \bmod 11 = 1 \quad (= 2^{10} \bmod 11 = 1024 \bmod 11 = 1)$$

Ví dụ 2.17 Một số giá trị của hàm Euler $\Phi(n)$

n	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18
$\Phi(n)$	1	1	2	2	4	2	6	4	6	4	10	4	12	6	8	8	16	6

Hàm Euler được dùng trong các hệ mã hóa khoá công khai. Nó cũng được sử dụng để kiểm tra tính nguyên tố của một số nguyên p nào đó, bằng cách lấy ngẫu nhiên các số a và kiểm tra xem có tính chất nêu trên không, kết luận p là nguyên tố sẽ càng thuyết phục nếu phép thử trên đúng với nhiều lần chọn ngẫu nhiên các số a .

2.6 Mã nén dữ liệu

2.6.1 Khái niệm cơ bản

Nén dữ liệu là quá trình biến đổi dữ liệu từ dạng có dung lượng lớn trở thành dạng dữ liệu có dung lượng nhỏ hơn: từ $X \rightarrow X'$ mà X' có dung lượng nhỏ hơn dung lượng của X .

Giải nén là quá trình làm ngược lại của quá trình nén dữ liệu, nghĩa là từ $X' \rightarrow X$ (trở về dạng dữ liệu nguyên thủy)

Nén dữ liệu rất có lợi cho việc truyền thông trên mạng, vấn đề bảo mật thông tin, tiết kiệm dung lượng bộ nhớ lưu trữ,...

2.6.2 Các phương pháp nén dữ liệu

a) Nén bảo toàn

Đó là mô hình nén dữ liệu cho phép người sử dụng bảo toàn (không mất) thông tin khi giải nén. Điều này được giải thích như sau:

Với D là dữ liệu ban đầu, Z là hàm nén, U là hàm giải nén:

$$D' = Z(D) \quad \text{và} \quad D'' = U(D') \quad \text{thì} \quad D'' = D$$

Thông thường phương pháp này được áp dụng với dữ liệu văn bản. Nén bảo toàn dựa trên hai mô hình khác nhau:

- *Mô hình thống kê*: Nén dựa vào xác suất xuất hiện của các ký hiệu trong tệp cần nén.
- *Mô hình từ điển*: Mã hoá một chuỗi ký hiệu chỉ bằng một từ mã

b) Nén không bảo toàn

Nén không bảo toàn là mô hình nén dữ liệu mà tính bảo toàn của dữ liệu không được coi trọng.

$$D' = Z(D) \text{ và } D'' = U(D') \text{ nhưng có thể } D'' \neq D$$

Kỹ thuật này thường áp dụng cho việc nén dữ liệu là các tệp ảnh vì nói chung nó cũng không ảnh hưởng gì nhiều đến chất lượng ảnh.

Hầu hết các kỹ thuật nén không bảo toàn thường được dùng để điều chỉnh sự cân bằng giữa độ chính xác của quá trình nén và hiệu quả nén.

Các phương pháp nén ảnh: CompuSever GIF (Graphics Interchange Format) và JPEG (Join Photographic Experts Group). Ngoài ra còn có nén MPEG (The Moving Picture Experts Group).

Các phương pháp nén âm thanh: hai thông số quan trọng nhất của âm thanh số hoá là tốc độ lấy mẫu và độ phân giải mẫu. Tốc độ lấy mẫu thường là 8 KHz, độ phân giải mẫu thường là 8 bit. Nén âm thanh cũng gồm cả nén bảo toàn và nén không bảo toàn, tuy nhiên nén bảo toàn không hiệu quả bằng nén không bảo toàn. Tốc độ lấy mẫu và độ phân giải mẫu xác định hệ số mất mát cho phép của phương pháp nén không bảo toàn để tín hiệu sau quá trình nén - giải không bị méo dạng. Phương pháp mã hoá phổ biến để nén tiếng nói là phương pháp mã hoá dự đoán tuyến tính (LPC- Linear Predictive Coding). LPC dựa trên các phương pháp ước tính bình phương bé nhất cổ điển và sự tương hợp ngẫu nhiên giữa một mô hình toán học lý tưởng (mô hình dự đoán tuyến tính) với các đặc trưng riêng của tiếng nói con người. Một hệ thống LPC hoàn chỉnh bao gồm hai khâu là phân tích và tổng hợp. Một cải tiến rất quan trọng của LPC là thuật toán nén tổn hao thông dụng ADPCM (Adaptive Difference Pulse Code Modulation).

2.6.3 Nén dữ liệu theo mô hình thống kê

a) Mô hình thống kê tĩnh



Dạng đơn giản nhất của mô hình thống kê tĩnh là một bảng tĩnh liệt kê các giá trị xác suất theo cách tính thông thường. Trước đây, do việc phân tích và xây dựng mã Huffman rất tốn thời gian, nên người ta chỉ phân tích một lần đối với các dữ liệu điển hình để có được một bảng đếm số lần xuất hiện của từng ký hiệu. Dựa vào kết quả đó, một cây mã Huffman tĩnh được xây dựng và lưu trữ để có thể sử dụng nhiều lần. Mô hình như vậy được gọi là mô hình thống kê tĩnh (Static Statistical Model).

Việc sử dụng một mô hình tĩnh vạn năng cho nhiều kiểu dữ liệu rõ ràng có nhiều hạn chế. Nếu dữ liệu vào không thích hợp với mô hình thì hiệu quả nén sẽ giảm, thậm chí sẽ có kích thước lớn hơn dữ liệu vào (gọi là nở đầu vào). Do đó một cải tiến tiếp theo là xây dựng mô hình tĩnh cho nhiều kiểu dữ liệu.

Việc xây dựng mô hình tĩnh riêng sẽ có thuận lợi là mang lại hiệu suất nén cao. Nhưng nhược điểm là lại cần lưu trữ thêm một lượng dữ liệu nhất định (cấu trúc của cây mã) trước khi lưu trữ bản mã. Nếu cấu trúc của cây mã vào không lớn lắm vào khoảng 256B so với lượng số lượng dữ liệu cần nén vài trăm KB thì mô hình tĩnh riêng là hiệu quả. Nhưng nếu cấu trúc của cây mã tăng lên mức không thể chấp nhận được so với mục tiêu nén dữ liệu (cỡ khoảng 64KB) thì mô hình tĩnh riêng không phù hợp.

b) Mô hình thống kê động

Để khắc phục những nhược điểm của mô hình thống kê tĩnh, mô hình thống kê động ra đời với số liệu thống kê đối với dữ liệu cần mã hoá không phải lưu trữ trước mà liên tục được tích lũy và sửa đổi trong suốt quá trình mã hoá và giải mã.

Điểm đáng chú ý trong mô hình thống kê động là sau khi một ký hiệu hoặc một nhóm ký hiệu đọc vào, nó sẽ được mã hoá dựa trên mô hình hiện thời, sau đó mô hình mới được cập nhật dựa trên ký hiệu hoặc nhóm ký hiệu đó. Tương tự như vậy, sau khi một từ mã được đọc vào nó sẽ được giải mã theo mô hình hiện thời rồi sau đó mô hình mới được cập nhật theo ký hiệu đã được giải mã.

Với mô hình thống kê động, ban đầu nó chưa biết gì về dữ liệu cần được mã hoá cho nên hiệu ứng nén chưa thể xuất hiện ngay. Hiệu ứng nén chỉ xuất hiện rõ rệt khi làm việc với cỡ vài nghìn ký hiệu. Ưu điểm của mô hình động ở chỗ nó có khả năng thích ứng với nhiều kiểu dữ liệu khác nhau.

2.6.4 Mã nén Huffman

Thực chất thuật toán Huffman (giống với Fano- Shannon) là phương pháp mã hoá dựa trên cơ sở thống kê tần suất xuất hiện của từng ký hiệu trong nguồn dữ liệu.

Mã Huffman có một tính chất quan trọng là thỏa mãn tính phân tách.

❖ **Thuật toán tạo mã Huffman**

- **Đầu vào:** tệp tin nguồn chưa nén f_n
- **Đầu ra:** tệp tin nén f_g

Bắt đầu: + Mở tệp tin nguồn để đọc

+ Mở tệp tin nén để ghi

Bước 1: Thống kê tạo ra bảng tần suất xuất hiện của các ký hiệu có trong nguồn.

Bước 2: Sắp xếp các ký hiệu trong bảng theo chiều không giảm hoặc không tăng.

Bước 3: Coi mỗi ký tự trong bảng là 1 cây, tìm hai cây có trọng số nhỏ nhất ghép lại thành một cây; trọng số của cây mới bằng tổng trọng số của hai cây con đem ghép.

Bước 4: Tiếp tục ghép cây cho đến khi trong danh sách còn 1 cây.

Bước 5: Đánh số các nhánh trên cây với quy ước nhánh bên trái ghi mã 0, bên phải ghi mã 1.

Bước 6: Gán mã cho các ký tự bằng cách ghép các số trên nhánh từ gốc đến lá.

Bước 7: Thay thế ký tự trong file f_n bằng mã tương ứng và ghi ra file f_g .

Ví dụ 2.17 Áp dụng thuật toán Huffman, nén chuỗi “go go gophers”.

Chúng ta thực hiện các bước sau.

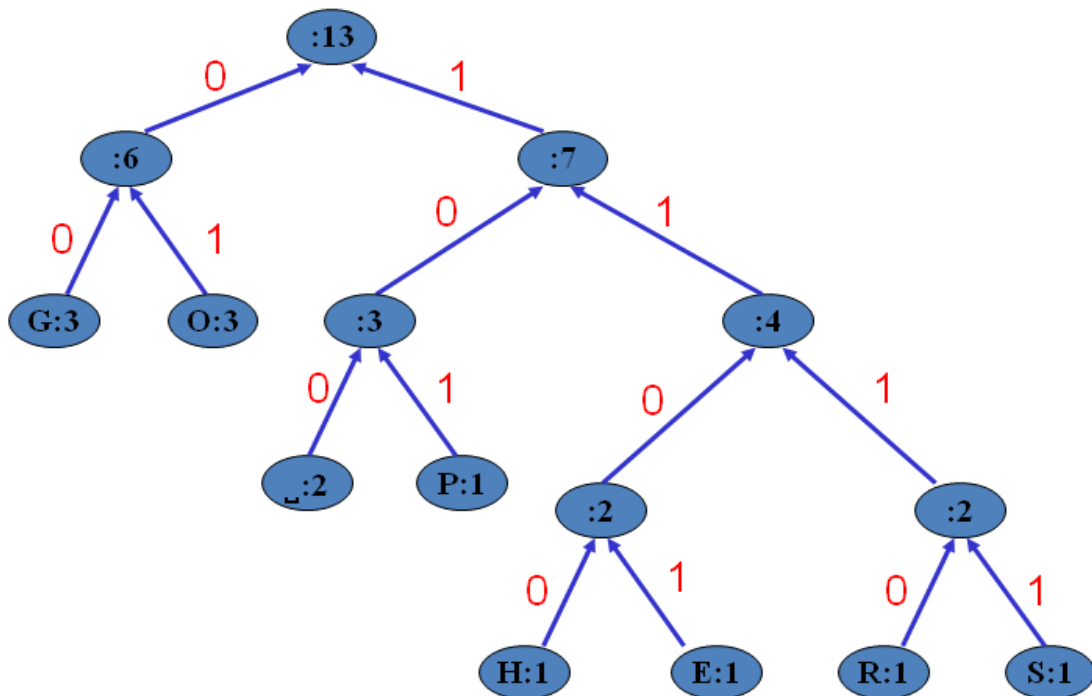
Bước 1:

Kí tự	Tần xuất	Từ mã
G	3/13	00
O	3/13	01
‘ ‘	2/13	100
P	1/13	101
H	1/13	1100
E	1/13	1101
R	1/13	1110
S	1/13	1111

Bước 2,3, 4: Ta có cây như hình 2.2 dưới

Bước 5: Xuất phát từ gốc đi tới các nút lá trên cây và tạo cây nhị phân với quy ước đi sang trái ghi mã 0, đi bên phải ghi mã 1 ta được cây như hình 2-2.





Hình 2-2: Các bước xây dựng cây mã Huffman

Bước 6: Xâu “go go gophers” sẽ được mã hoá như sau (dấu - cho dễ đọc)

00-01-100-00-01-100-00-01-1110-1101-101-1111-1100

Mã Huffman được tạo ra theo thuật toán trên là mã có tính phân tách, có độ dài từ mã tối ưu và thoả mãn các tính chất sau:

- Chữ cái với xác suất lớn hơn thì có độ dài từ mã nhỏ hơn
- Từ mã của hai chữ cái có xác suất nhỏ nhất có cùng độ dài và chỉ khác nhau bit cuối cùng.

So với mã Fano Shannon thì mã Huffman có hiệu suất nén cao hơn một chút nên trong thực tế nó được sử dụng nhiều hơn

Phương pháp này từ khi mới ra đời được sử dụng rộng rãi, nhất là trong lĩnh vực cơ sở lý thuyết thông tin. Nó là cơ sở để sản sinh ra nhiều phương pháp nén khác tốt hơn. Tuy nhiên phương pháp này lại trở nên công kềnh khi số chữ cái quá lớn. Để giải quyết vấn đề này phải dùng một biện pháp khắc phục để giảm nhẹ quá trình mã hoá như sau:

Liệt kê các chữ cái của văn bản nguồn theo thứ tự xác suất giảm dần. Sau đó ghép thành nhiều nhóm chữ cái có xác suất xấp xỉ nhau. Dùng một mã đều để mã hoá các chữ cái trong cùng một nhóm. Sau đó xem các nhóm chữ cái như là một khối chữ cái và dùng phương pháp Huffman để mã hoá các khối chữ cái. Từ mã cuối cùng



tương ứng với mỗi chữ cái của văn bản gồm hai phần: một phần là mã Huffman, một phần là mã đều.

2.6.5 Mã RLE (Run- Length- Encoding)

Đây là một phương pháp nén ảnh phổ biến hiện nay. Nguyên tắc của mã RLE rất đơn giản là thay thế một chuỗi kí tự lặp lại bằng một kí tự duy nhất của chuỗi lặp lại cùng với một biến đếm số lần kí tự đó được lặp lại.

a) Thuật toán mã hoá

Trong văn bản nguồn có thể có một số kí tự giống nhau, thuật toán sẽ nhóm lại thành một nhóm 2 thành phần (L, C), trong đó C là kí tự được lặp lại L lần.

❖ Thuật toán nén RLE như sau:

- **Đầu vào:** Tập tin nguồn f
- **Đầu ra:** Tập tin nén fn

Các biến: C1, C2 là hai kí tự, L là một số nguyên

Bước 1: + Mở tập tin nguồn f (để đọc)

+ Mở tập tin nén fn (để ghi)

Bước 2: + Đặt L=1;

+ Đọc kí tự trong f gán vào C1;

Bước 3: Thực hiện khi C1 $\neq$ end of file(f)

b1. Đọc kí tự tiếp theo trong f gán vào C2

b2. Kiểm tra, nếu C1 = C2 thì

+ Tăng L lên 1;

+ Quay lên thực hiện tiếp b1;

Ngược lại thì:

+ Ghi cặp (L, C1) ra tập nén fn.

+ Quay lên thực hiện tiếp Bước 2:

Ngược lại, (nếu C1 là ký tự cuối cùng trong tập f) thì thực hiện **Bước 4**.

Bước 4: Kết thúc.

Ví dụ 2.18: Có một văn bản sau: aaaabbbaabbbbbbcccccccdabcbbaabbbbcccd. Theo phương pháp mã RLE thì văn bản này được mã hoá như sau:



4a3b2a5b8c1d1a1b1c1b3a4b3c1d

b) Thuật toán giải mã RLE như sau:

- **Đầu vào:** Tập tin nén fn
- **Đầu ra:** Tập tin giải nén fg

Bước 1: + Mở tập tin nén fn (để đọc)

+ Mở tập tin giải nén fg (để ghi)

Bước 2: Khi nào cặp (L, C) không phải là ký tự cuối cùng trong tập fn thì thực hiện:

b1. Đọc cặp (L, C) trong tập nén fn

b2. + For i=1 to L do ghi ký tự C ra tập giải nén fg

+ Quay lên thực hiện tiếp Bước 2:

Ngược lại, (L, C là cặp ký tự cuối cùng trong tập nén fn) thì thực hiện

Bước 3: Kết thúc.

Ví dụ 2.19:

Cho bản mã kết quả của Ví dụ 2.18: 4a3b2a5b8c1d1a1b1c1b3a4b3c1d. Quá trình giải mã như sau: Đọc cặp mã đầu tiên là 4a thì ta viết aaaa, tiếp theo là cặp mã 3b thì ta viết ra tiếp bbb. Cứ lặp lại như vậy cho đến khi đọc hết các cặp mã ta được văn bản ban đầu là aaaabbbbaabbbbbbcccccccdabcbbaabbbbcccd.

Nhận xét: Thuật toán trên có hạn chế là nếu ký tự không lặp lại thì lại tốn ít nhất 2B (1B số, 1B ký tự) để mô tả một ký tự 1B. Lúc này thuật toán không “nén” mà là “bung”.

2.6.6 Mô hình từ điển

a) Tổng quát

Kỹ thuật từ điển là kỹ thuật sử dụng phương pháp phân đoạn văn bản thành các đoạn nhỏ hơn sao cho nó đạt được độ dài nhất có thể được mà nó đã xuất hiện ở trong quá khứ.

Giả sử chúng ta có từ điển D thì tồn tại một ánh xạ $f: D \rightarrow \Omega$ trong đó Ω là tập các đoạn bit 0/1. Việc nén sẽ tối ưu khi chúng ta phân được đoạn văn bản có độ dài lớn nhất mà sao cho khi đi tìm trong quá khứ thì chúng ta được đoạn 0/1 trong Ω là nhỏ nhất.



Trong kỹ thuật từ điển, tương tự như kỹ thuật thống kê, ta cũng có hai phương án sau:

b) Từ điển tĩnh

Mã có từ điển cố định được gọi là mã tĩnh hay nói cách khác là từ điển tĩnh.

Nhược điểm của từ điển tĩnh:

- Kích thước của từ điển tĩnh không thể mở rộng ra, để cập nhật các thông tin mới so với các loại dữ liệu khác.
- Quá trình nghiên cứu thiết kế từ điển đòi hỏi nhiều công sức.
- Các thuật toán sử dụng từ điển tĩnh chạy tương đối chậm.
- Tốn không gian lưu trữ dữ liệu.

Tuy nhiên bên cạnh những nhược điểm này thì từ điển tĩnh cũng có ưu điểm là: Thiết kế các thuật toán áp dụng cho việc tìm kiếm trên từ điển tĩnh đơn giản tốn ít thời gian.

Do những đặc tính hạn chế của từ điển tĩnh, kết hợp với những đặc điểm nổi bật của thuật toán nén là "sự cứng nhắc" đã làm cho người dùng chương trình dễ tiết kiệm bộ nhớ nhằm chán không thích sử dụng các chương trình nén nữa. Vậy phải có cách để khắc phục những hạn chế đó và làm cho chương trình nén dữ liệu trở nên mềm dẻo hơn. Chính vì vậy những thuật toán nén chỉ đạt hiệu quả cao nếu chúng ta xử lý tốt "từ điển" được sử dụng trong các thuật toán nói chung.

c) Từ điển động

Để khắc phục những hạn chế của từ điển tĩnh, biện pháp được xét đến là:

Chúng ta không thiết kế một từ điển sẵn mà "từ điển" đó được xây dựng trong quá trình chạy chương trình. Một từ điển như vậy người ta gọi là từ điển động.

Đặc điểm chính của từ điển động:

- Kích thước của từ điển có thể thay đổi tùy theo kích thước của tập tin.
- Không tốn thời gian lưu trữ từ điển.
- Thời gian thực hiện quá trình nén nhanh.
- Từ điển không phụ thuộc vào kiểu dữ liệu.
- Thời gian thực hiện quá trình giải nén chậm.

2.6.7 LZ77

Ý tưởng của phương pháp này là sử dụng phần đã xét trước đó như là một từ điển. Mã hóa duy trì một cửa sổ gắn với luồng vào và dịch đầu vào trong cửa sổ từ



phải sang trái theo đúng cách các chuỗi ký tự được mã hóa. Phương thức này dựa trên một cửa sổ trượt. Cửa sổ dưới được chia làm hai phần:

- Phần bên trái gọi là bộ đệm tìm kiếm – search buffer. Đây là từ điển hiện hành và nó bao gồm các ký hiệu mới được duyệt ở đầu vào và được mã hóa.
- Phần bên phải là bộ đệm nhìn trước - look-ahead buffer, chứa văn bản chưa được mã hóa.

Thực tế, bộ đệm search dài hàng nghìn byte trong khi bộ đệm look-ahead chỉ dài khoảng 10 byte. Thanh dọc ở giữa t và e bên dưới biểu diễn dòng phân chia hiện hành giữa hai bộ đệm. Bởi vậy ta thấy văn bản “sir sid eastman easily t” đã được nén, trong khi văn bản “eases sea sick seals” cần được nén.

search buffer	look-ahead buffer
sir sid eastman easily t	eases sea sick seals

Mã hóa quét quay lui bộ đệm search (từ phải sang trái) để tìm ký tự trùng với ký tự e đầu tiên trong bộ đệm look-ahead. Nó tìm thấy một ký tự e trong từ easily. Từ e này nằm tại offset 8 tính từ phần cuối của bộ đệm search. Sau đó, mã hóa tìm ký tự e tiếp theo có thể có. Ba ký tự eas trùng nhau trong trường hợp này, vì vậy độ dài của chuỗi hợp là 3. Mã hóa tiếp tục quay lui quét, cố gắng tìm thấy các chuỗi hợp dài hơn. Trong trường hợp này chỉ có ký tự e trong từ eastman, tại offset 16 và có độ dài như vậy. Mã hóa chọn chuỗi hợp dài nhất hoặc nếu chúng có độ dài như nhau, chuỗi hợp cuối cùng được tìm thấy và chuẩn bị xâu (16,3, “e”).

Việc chọn chuỗi hợp cuối cùng hơn là chuỗi hợp đầu tiên làm đơn giản hóa bộ mã hóa, khi nó chỉ phải theo dõi chuỗi hợp cuối cùng được tìm thấy. Thú vị để ghi nhớ việc chọn lựa chuỗi hợp đầu tiên trong khi làm chương trình có phần phức tạp hơn cũng là một lợi thế. Nó chọn lựa offset nhỏ nhất. Dường như điều này không lợi thế khi một xâu nên có chỗ cho offset có thể lớn nhất. Tuy nhiên, đi theo LZ77 với Huffman, hoặc mã thống kê khác của các xâu mà các offset nhỏ được gán các mã ngắn hơn. Phương thức này, được đề xướng bởi Bernd Herd, gọi là LZH.

Một câu hỏi mà có thể xảy ra tại điểm này là việc giải mã bằng cách nào trong khi mã hoá chọn chuỗi hợp đầu tiên hoặc cuối cùng? Câu trả lời dễ hiểu là việc giải mã không được biết nhưng nó không cần để biết. Giải mã đơn giản là đọc các xâu và sử dụng mỗi offset để tìm chuỗi văn bản mà không cần biết chuỗi là chuỗi hợp đầu tiên hay cuối cùng.

Cấu tạo một xâu LZ77: gồm có 3 phần:

- + Offset: vị trí của xâu trong bộ đệm search.
- + Length: độ dài xâu.
- + Ký hiệu kế tiếp trong bộ đệm look-ahead.

Trong ví dụ trên, xâu được ghi là (16,3, “e”) (e – ký tự e thứ hai trong từ teases). Xâu này được ghi trên luồng ra và cửa sổ được dịch sang phải (hay nói cách khác, luồng vào được dịch sang trái) bốn vị trí: ba vị trí cho chuỗi hợp và một vị trí cho ký tự kế tiếp.

Nếu khi quay lui, không tìm được ký tự trùng thì một xâu LZ77 có trường offset và length là bằng 0 và trường thứ ba là ký tự không được hợp. Đây cũng là nguyên nhân một xâu phải có ba thành phần. Các xâu với trường offset và length bằng 0 phổ biến tại phần bắt đầu công việc nén, khi mà bộ đệm search là rỗng hoặc hầu như rỗng.

Ví dụ 2.20:

	sir sid eastman	(0,0, “s”)
S	sir sid eastman	(0,0, “i”)
Si	r sid eastman ea	(0,0, “r”)
Sir	sid eastman eas	(0,0, “ ”)
Sir	sid eastman easi	(4,2, “d”)

a) Thuật toán nén

Giả sử cửa sổ có: bộ đệm search có kích thước N byte và bộ đệm look-ahead có kích thước là F byte.

Bước 1: Đọc 1 ký tự đầu tiên giữ nguyên.

Bước 2: Cho cửa sổ dịch sang phải. Mỗi lần đếm số ký tự trùng nhau liên tiếp kể từ đầu của bộ đệm look-ahead về bộ đệm search và ghi nhớ con số tương ứng với vị trí offset của nó. Tìm số lớn nhất trong tất cả các con số ấy.

Bước 3: Ghi ra mã [i, j, w] trong đó:

- i: khoảng cách từ vị trí hiện tại đến vị trí tương ứng với số lớn nhất vừa tìm được.
- j: số các ký tự trùng nhau hay chính là số lớn nhất vừa tìm được.
- w: ký tự ở vị trí thứ j + 1 trong bộ đệm look-ahead.

Bước 4: Lặp lại bước 2 cho đến khi hết văn bản.

Bước 5: Kết thúc.



Ví dụ 2.21:

Cho văn bản sau: “sire sire eastman easily” với $N = 24$, $F = 16$.

Bảng 2-4: Quá trình nén văn bản “sire sire eastman easily” dùng LZ77

STT	Search buffer	vị trí hiện tại	Look-ahead buffer	Ghi ra
1		1	sire sire eastma	(0,0, “s”)
2	s	2	ire sire eastman	(0,0, “i”)
3	si	3	re sire eastman_	(0,0, “r”)
4	sir	4	e sire eastman e	(0,0, “e”)
5	sire	5	_sire eastman ea	(0,0, “_”)
6	sire_	6	sire eastman eas	(5,5, “e”)
7	sire sire_e	12	astman easily	(0,0, “a”)
8	sire sire ea	13	stman easily	(7,1, “t”)
9	sire sire east	15	man easily	(0, 0, “m”)
10	sire sire eastm	16	an easily	(4, 1, “n”)
11	sire sire eastman	18	_easily	(8,4, “i”)
12	sire sire eastman easi	23	ly	(0,0, “l”)
13	sire sire eastman easil	24	y	(0,0, “y”)

Vậy bản nén là:

(0,0,“s”)(0,0,“i”)(0,0,“r”)(0,0,“e”)(0,0,“_”)(5,5,“e”)(2,1,“a”)(7,1,“t”)(0,0,“m”)
(4,1,“n”)(8,4,“i”)(0,0,“l”)(0,0,“y”)

b) Thuật toán giải nén

Bước 1: Đọc bộ đệm look-ahead, 1 ký tự đầu tiên của bản mã ghi ra bản giải mã.

Bước 2: Đọc một bộ mã $[i, j, w]$. Lùi về đoạn văn bản đã giải mã i vị trí và copy j ký tự từ vị trí thứ i đó để ghi ra bản giải mã, sau đó ghi tiếp w ra.

Bước 3: Nếu còn bộ mã thì quay lại bước 2. Nếu không còn thì sang bước 4

Bước 4: Kết thúc

Ví dụ 2.32

Bảng 2-5: Quá trình giải nén văn bản dùng LZ77

STT	Bộ mã đọc vào	Ghi ra	Bản giải mã
-----	---------------	--------	-------------

1	(0,0,"s")	s	s
2	(0,0,"i")	i	si
3	(0,0,"r")	r	sir
4	(0,0,"e")	e	sire
5	(0,0,"_")	_	sire_
6	(5,5,"e")	sire_e	sire sire_e
7	(0,0,"a")	a	sire sire ea
8	(7,1,"t")	st	sire sire east
9	(0,0,"m")	m	sire sire eastm
10	(4,1,"n")	an	sire sire eastman
11	(8,4,"i")	_easi	sire sire eastman easi
12	(0,0,"l")	l	sire sire eastman easil
13	(0,0,"y")	y	sire sire eastman easily

Văn bản đã giải nén: "sire sire eastman easily".

Sang 8/3

2.6.8 LZ78

LZ78 được phát minh và sử dụng trong những năm 1978. LZ78 sử dụng một từ điển gồm các chuỗi đã xem trước đó. Từ điển này được khởi tạo là rỗng và kích thước của nó chỉ bị giới hạn bởi số lượng bộ nhớ sẵn có.

Một xâu LZ78 được tạo ra gồm hai trường có dạng (W, C):

- W: chỉ số của chuỗi ký hiệu trong từ điển.
- C: mã ký hiệu kế tiếp.

Xâu LZ78 không chứa kích thước của chuỗi khi nó đã được bao hàm trong từ điển. Mỗi xâu tương ứng với một chuỗi các ký hiệu vào và chuỗi đó được thêm vào từ điển sau khi xâu được ghi vào luồng nén. Không có xâu nào bị xóa khỏi từ điển, đây là cả lợi thế (các chuỗi tương lai có thể được nén bởi chính những chuỗi đã được xét từ lâu) và bất lợi (từ điển phát triển nhanh và đầy bộ nhớ sẵn có) so với LZ77.

Từ điển được khởi tạo với một chuỗi rỗng bắt đầu tại vị trí 0. Khi các ký tự được nhập vào và được mã hóa thì các chuỗi được thêm vào tại vị trí 1, 2,...

Khi một ký tự tiếp được đọc từ luồng vào, từ điển tìm kiếm một mục với chuỗi đơn x. Nếu không tìm thấy, x được thêm vào từ điển tại vị trí kế tiếp, và xâu (0, x) được ghi ra. Xâu này cho biết chuỗi "null x" (chuỗi rỗng kết hợp với x). Nếu một mục



với x được tìm thấy (ví dụ tại vị trí 37), ký tự kế tiếp y được đọc và từ điển tìm kiếm mục chứa chuỗi hai ký tự xy . Nếu không có trong từ điển, thì chuỗi xy được thêm vào tại vị trí tiếp theo trong từ điển, và $x(37, y)$ được ghi ra. x này cho biết chuỗi xy với 37 là vị trí của chuỗi x trong từ điển. Quá trình tiếp tục đến khi gặp ký tự kết thúc luồng vào.

Từ điển được xây dựng trong quá trình nén và giải nén là hoàn toàn động, do đó không cần lưu từ điển cùng với file nén. Điều này tạo kích thước file nén giảm đáng kể.

a) Thuật toán

- **Đầu vào:** Tập tin nguồn f
- **Đầu ra:** Tập tin nén fn

Bước 1: + Khởi tạo từ điển = x rỗng có chỉ số 0.

+ Đặt x trung gian $P = x$.

Bước 2: Đọc ký tự tiếp theo trong tệp văn bản nguồn f gán vào C .

Bước 3: Kiểm tra: Nếu $x(P + C)$ đã có trong từ điển thì:

+ Đặt $P = P + C$

+ Quay lại **bước 2**;

Ngược lại thì:

+ Cập nhật $P + C$ vào trong từ điển;

+ Gán $W = P$ chỉ số trong từ điển;

+ Ghi cặp (W, C) ra tệp tin nén fn .

+ Đặt lại $P = x$

Bước 4: Kiểm tra: Nếu còn ký tự trong văn bản thì:

+ Quay lại **bước 2**.

Ngược lại thì:

+ Ghi ra cặp (W, C) với C là x ra tệp nén fn ;

+ Sang bước 5;

Bước 5: Kết thúc

Ví dụ 2.23



Nén văn bản “sir sid eastman”

STT	P	C	Từ điển	W	Ghi ra
1		S	1 – s	0	(0, “s”)
2		I	2 – i	0	(0, “i”)
3		R	3 – r	0	(0, “r”)
4		–	4 – _	0	(0, “_”)
5		S			
6	s	I	5 – si	1	(1, “i”)
7		D	6 – d	0	(0, “d”)
8		–			
9	_	E	7 – _e	4	(4, “e”)
10		A	8 – a	0	(0, “a”)
11		S			
12	s	T	9 – st	1	(1, “t”)
13		M	10 – m	0	(0, “m”)
14		A			
15	a	N	11 – an	8	(8, “n”)

Vậy bản nén là:

(0, “s”)(0, “i”)(0, “r”)(0, “_”)(1, “i”)(0, “d”)(4, “e”)(0, “a”)(1, “t”)(0, “m”)(8, “n”)

b) Thuật toán giải nén

Với mỗi cặp (W,C) ta ký hiệu.

W nội dung của đoạn copy thứ W trong từ điển. Nếu W=0 thì W là rỗng.

Đầu vào: Tập tin nguồn nén fn

Đầu ra: Tập tin giải nén fg;

Bước 1: + Mở tập tin nguồn fn (để đọc)

+ Mở tập tin giải nén fg (để ghi)

Bước 2: Khởi tạo từ điển = xâu rỗng có chỉ số 0

Bước 3: Đọc một cặp (W,C).

Bước 4: + Ghi xâu (W +C) ra file giải nén fg.

+ Cập nhật xâu này vào từ điển



Bước 5: Kiểm tra: nếu còn ký tự trong file mã fn thì quay lại **bước 3**.

Ngược lại sang **bước 6**;

Bước 6: Kết thúc.

Ví dụ 2.24 Giải nén

STT	Cặp mã đọc vào	Ghi ra	Từ điển
1	(0, "s")	s	1 – s
2	(0, "i")	i	2 – i
3	(0, "r")	r	3 – r
4	(0, "_")	_	4 – _
5	(1, "i")	si	5 – si
6	(0, "d")	d	6 – d
7	(4, "e")	_e	7 – _e
8	(0, "a")	a	8 – a
9	(1, "t")	st	9 – st
10	(0, "m")	m	10 – m
11	(8, "n")	an	11 – an

2.7 Câu hỏi và bài tập

2.7.1 Câu hỏi

2.1) Mã hóa, giải mã, phá mã và mật mã học là gì?

2.2) Cho số tự nhiên n và số nguyên a . Hãy định nghĩa phép toán a modulo n .

2.3) Hãy giải thích biểu thức $a \equiv b \pmod{n}$.

2.4) Tập đại diện của các số nguyên theo modulo n gồm những số nào? Hãy định nghĩa vành đồng dư modulo n : Z_n .

2.5) Cho số tự nhiên n và số nguyên a với điều kiện $\text{GCD}(a, n) = 1$. Hãy định nghĩa nghịch đảo của a theo modulo n .

2.7.2 Bài tập

2.1) Tính giá trị các biểu thức theo modulo sau:

$$8 \bmod 9 + 7 \bmod 9$$

$$5^3 \bmod 7$$

$$8 \bmod 9 * 7 \bmod 9$$

$$5^{20} \bmod 7$$

$$5 \bmod 11 - 9 \bmod 11$$

$$5/6 \bmod 7$$



2.2) Tính giá trị các biểu thức theo modulo sau

$(-546) \bmod 13 - 347 \bmod 11$	$14^{35} \bmod 11$
$(1234 + 2345) \bmod 17$	$(235 \cdot 126 / 13) \bmod 19$
$(213 \cdot 345) \bmod 19$	$311^{30} \bmod 23$
$15^{-1} \bmod 101$	$(235^{25} / 17 + 126^{19} - 39^7 / 13) \bmod 29$
$41^{-1} \bmod 100$	

2.3) Tính hàm Ore của các số nguyên sau: 12, 17, 21, 32, 36, 40, 72, 256

2.4) Sử dụng thuật toán Huffman để nén các chuỗi sau và tính tỷ số nén đối với mỗi chuỗi:

ABBCDGHKUABBABAGGG

KBBCDKHKUABBABAKGG

KBBCDKHKUABBABAKKG

ABBCDGHKUABBABADDD

2.5) Hãy sử dụng thuật toán LZ77 để nén và giải nén các chuỗi sau:

$S_1 = \text{"hai hai ba ba nam sau bay tam"}$.

$S_2 = \text{"hai hai ba ba tam ba tam ba"}$

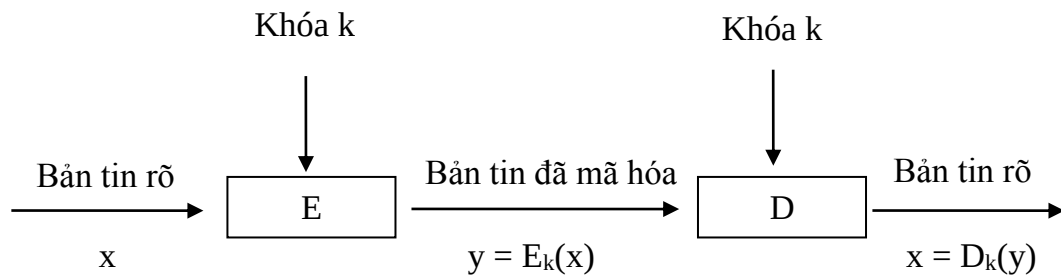
2.6) Hãy sử dụng thuật toán LZ78 để nén và giải nén các chuỗi S_1 và S_2 trong bài 2.5).



CHƯƠNG 3. CÁC HỆ MẬT MÃ ĐỐI XỨNG

3.1 Định nghĩa

Phần này ta xem xét định nghĩa của hệ mật mã đối xứng. Trong thực tế, có nhiều hệ mật mã đối xứng khác nhau được tạo ra phục vụ nhu cầu sử dụng của con người. Tuy nhiên, ta có thể biểu diễn các hệ mật mã đối xứng bằng mô hình tổng quát sau đây:



Hình 3-1: Mô hình tổng quát của các hệ mật mã đối xứng

Trong mô hình nói trên, E và D lần lượt là các thuật toán mã hóa và giải mã tương ứng. Thuật toán mã hóa E sẽ mã hóa một bản tin rõ x thành một bản mã y sử dụng một khóa bí mật k nào đó. Ngược lại, thuật toán giải mã D sẽ dựa trên khóa bí mật k để giải mã bản mã y thành bản tin rõ x ban đầu.

Để thuận tiện trong việc biểu diễn và trình bày các hệ mật mã ở phần tiếp theo, ta đưa vào định nghĩa hình thức về hệ mật mã như sau:

Định nghĩa 3.1 [2] Một hệ mật mã là một bộ gồm 5 thành phần, (P, C, K, E, D) , thỏa mãn các điều kiện sau đây:

- P là tập hữu hạn các bản (tin) rõ
- C là một tập hữu hạn các bản mã
- K là một tập hữu hạn các khóa
- E là quy tắc mã hóa bản tin rõ thành bản mã
- D là quy tắc giải bản mã thành bản tin rõ

Đối với mỗi khóa $k \in K$, có một thuật toán mã hoá $E_k \in E$ ánh xạ từ P vào C và một thuật toán giải mã tương ứng $D_k \in D$ ánh xạ từ C vào P . Thuật toán giải mã $D_k()$ chính là ánh xạ ngược của thuật toán mã hóa $E_k()$, nghĩa là $D_k(E_k(x)) = x$ với mọi $x \in P$.

Trong giáo trình này, chúng ta quy ước dùng chữ thường để biểu diễn nội dung các bản tin rõ và dùng chữ hoa để biểu diễn nội dung bản mã.

3.2 Mật mã đối xứng cổ điển

Có hai kỹ thuật cơ bản được sử dụng trong các hệ mật mã đối xứng nói chung và mật mã cổ điển nói riêng, đó là *kỹ thuật thay thế* và *kỹ thuật hoán vị*.

Mã thay thế là phương pháp mà từng kí tự hoặc một nhóm kí tự trong bản rõ được thay thế bằng một kí tự hoặc một nhóm kí tự khác để tạo ra bản mã. Bên nhận chỉ cần thay thế ngược lại trên bản mã để có được bản rõ ban đầu.

Trong phương pháp mã hoán vị, các kí tự trong bản rõ vẫn được giữ nguyên, chúng chỉ được sắp xếp lại vị trí để tạo ra bản mã. Tức là các kí tự trong bản rõ hoàn toàn không bị thay đổi bằng kí tự khác mà chỉ đảo chỗ của chúng để tạo thành bản mã.

3.2.1 Kỹ thuật mã hóa thay thế

a) Hệ mật mã thay thế đơn Caesar

Đây là hệ mật mã thay thế sớm nhất được Julius Caesar đưa ra. Việc mã hoá được thực hiện đơn giản là thay mỗi chữ trong bản rõ bằng chữ thứ ba tiếp theo trong bảng chữ cái tiếng Anh gồm 26 ký tự (a, b, ..., z).

Ví dụ 3.1:

Bản rõ: mat khai la ngay mai tuoi sang

Bản mã: PDW NKDX OD QJDB PDL WXRL VDQJ

Có thể định nghĩa việc mã hoá này qua ánh xạ trên hai bảng chữ cái, bảng các chữ ở dòng dưới là mã của bảng các chữ tương ứng ở dòng trên.

a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C

Về toán học, có thể gán số thứ tự cho mỗi chữ trong bảng chữ cái bắt đầu từ số 0 như trong bảng sau:

a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25

Khi đó, hệ mật mã Caesar được định nghĩa một cách hình thức như sau:

Cho $P = C = Z_{26}$, $k = 3$, quy tắc mã hóa và giải mã Caesar được định nghĩa như sau:

$$y = e_k(x) = (x + k) \bmod 26 \text{ và} \quad (3.1)$$



$$x = d_x(y) = (y - k) \bmod 26, \quad \forall x, y \in \mathbb{Z}_{26} \quad (3.2)$$

Theo định nghĩa này thì chỉ có 26 giá trị khác nhau của k , nên có 26 khoá khác nhau nhưng độ dài khoá ở đây chỉ là 1 vì mọi chữ đều tịnh tiến đi một khoảng như nhau.

Việc thám mã đối với hệ mật Caesar là việc làm đơn giản do số lượng khóa khác nhau là rất nhỏ. Chỉ có 26 khóa có thể, vì A chỉ có thể ánh xạ vào một trong số 26 chữ cái của bảng chữ cái tiếng Anh $A, B, C, \dots$. Các chữ khác sẽ được xác định bằng số bước tịnh tiến tương ứng của A . Kẻ thám mã có thể thử lần lượt từng khóa một, tức là sử dụng phương pháp tìm duyệt tổng thể. Vì số khóa ít nên việc tìm duyệt là khả thi. Cho trước bản mã, thử 26 cách dịch chuyển khác nhau, ta sẽ đoán nhận thông qua nội dung các bản rõ nhận được.

Để khắc phục nhược điểm này của mã Caesar, người ta tìm cách thay hàm mã hóa $x + k$ bằng hàm $ax + k$, với a nguyên tố cùng nhau với 26, để mã của bảng chữ cái không còn theo thứ tự alphabet nữa. Kỹ thuật này có tên là Affine.

b) Hệ mật mã Affine – một phiên bản nâng cấp của Caesar

Hệ mã hoá Affine được xác định bởi hai số nguyên a và b , với điều kiện là $0 \leq a, b \leq 25$ (tức a, b thuộc bảng chữ cái tiếng Anh gồm 26 ký tự) và a nguyên tố cùng nhau với 26. Ở đây, chúng ta xem xét hệ mật mã trên các số tự nhiên thay cho các ký tự như đã nói ở phần trên, các phép toán số học được thực hiện theo modulo 26.

Đặt $P = C = \mathbb{Z}_{26}$ và đặt $K = \{(a, b) \in \mathbb{Z}_{26} \times \mathbb{Z}_{26} : \gcd(a, 26) = 1\}$.

với $k = (a, b) \in K$, các hàm mã hóa và giải mã được định nghĩa như sau:

$$E_k(x) = (ax + b) \bmod 26$$

$$\text{và} \quad D_k(y) = a^{-1}(y - b) \bmod 26$$

Từ công thức mã hóa của Affine ta thấy ngay là khi $a = 1$ thì hệ mã hoá này chính là hệ mã Caesar.

Ví dụ 3.2: Nếu $a = 3$ và $b = 5$ thì ta có bảng mã hóa của các số tự nhiên tương ứng với bảng chữ cái gốc như sau:

0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25
5	8	11	14	17	20	23	0	3	6	9	12	15	18	21	24	1	4	7	10	13	16	19	22	25	2



Tương ứng, ta có mã của bảng chữ cái gốc:

a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
F	I	L	O	R	U	X	A	D	G	J	M	P	S	V	Y	B	E	H	K	N	Q	T	W	Z	C

Từ bảng này, ta có thể dễ dàng mã hóa và giải mã bằng cách tra xuôi và tra ngược.

Ví dụ 3.3 Cho bản rõ “not every steam bath is sauna”. Sử dụng bảng mã hóa trên đây, lần lượt tra các chữ cái của bản rõ, ta sẽ có bản mã sau:

“SVK RQREZ HKRFP IFKA DH HFNSF”.

c) Hệ mật mã thay thế sử dụng một bảng chữ

Ngoài việc thay đổi hệ số tịnh tiến như đã làm trong kỹ thuật Affine, ta còn có thể khắc phục nhược điểm của mã Caesar bằng cách mã hoá các chữ không chỉ là dịch chuyển bảng chữ, mà có thể tạo ra các bước nhảy khác nhau cho các chữ. Trong một mã, mỗi chữ của bản rõ được ánh xạ đến một chữ khác nhau của bản mã. Do đó, mỗi cách mã như vậy sẽ tương ứng với một hoán vị của bảng chữ và hoán vị đó chính là khoá của mã đã cho. Như vậy độ dài khoá ở đây là 26 và số khoá có thể có là 26!.

Ví dụ 3.4: Cho bản mã tương ứng với bản rõ trong mã hóa bảng chữ đơn:

a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
D	K	V	Q	F	I	B	J	W	P	E	S	C	X	H	T	M	Y	A	U	O	L	R	G	Z	N

Hãy mã hóa bản rõ “help we are being attacked”.

Sử dụng bảng mã trên để mã hóa, ta sẽ có bản mã như sau:

JFST RF DYF KFWXB DUUDVEFQ

Tính an toàn của mật mã bảng chữ đơn cao hơn mật mã chữ đơn. Ở bảng chữ đơn, tổng cộng có 26! (khoảng $4 \cdot 10^{26}$) khoá. Với khá nhiều khoá như vậy, nhiều người nghĩ là mã trên bảng chữ đơn sẽ an toàn. Nhưng không phải như vậy. Vấn đề ở đây là do các đặc trưng về ngôn ngữ. Tuy có số lượng khoá lớn, nhưng do các đặc trưng về tần suất xuất hiện của các chữ trong bản rõ và mã của chúng trong bản mã là như nhau, nên có thể đoán được ánh xạ của một số chữ và từ đó mò tìm ra chữ mã cho các chữ khác.

d) Hệ mật mã Vigenere – mã thay thế sử dụng nhiều bảng chữ

Một hướng khác làm tăng độ an toàn cho mã trên bảng chữ là sử dụng nhiều bảng chữ để mã. Ta sẽ gọi chúng là các mã thay thế nhiều bảng. Ở đây mỗi chữ có thể được



mã bằng bất kỳ chữ nào trong bản mã tùy thuộc vào ngữ cảnh khi mã hoá. Làm như vậy để trải bằng tần suất các chữ xuất hiện trong bản mã và giảm bớt tính cấu trúc của bản rõ được thể hiện trên bản mã. Ta sử dụng từ khoá để chỉ rõ chọn bảng nào được dùng cho từng chữ trong bản tin. Sử dụng lần lượt các bảng theo từ khóa đó và lặp lại từ đầu sau khi kết thúc từ khóa. Độ dài khóa là chu kỳ lặp của các bảng chữ. Độ dài càng lớn và nhiều chữ khác nhau được sử dụng trong từ khóa thì càng khó thám mã.

Một trong những mã thay thế nhiều bảng chữ đơn giản đó là mã Vigenere. Thực chất quá trình mã hoá Vigenere là việc tiến hành đồng thời nhiều mã Caesar cùng một lúc trên bản rõ với nhiều khóa khác nhau. Khóa cho mỗi chữ dùng để mã phụ thuộc vào vị trí của chữ đó trong bản rõ và được lấy trong từ khóa theo thứ tự tương ứng.

Hệ Vigenere được định nghĩa một cách hình thức như sau:

Cho m là một số nguyên dương và $P = C = K = (Z_{26})^m$.

Với một khóa $K = (k_1, k_2, \dots, k_m)$, hàm mã hóa và giải mã được xác định bằng các công thức sau:

$$e_K(x_1, x_2, \dots, x_m) = (x_1 + k_1, x_2 + k_2, \dots, x_m + k_m)$$

và

$$d_K(y_1, y_2, \dots, y_m) = (y_1 - k_1, y_2 - k_2, \dots, y_m - k_m)$$

trong đó các phép $+$, $-$ được thực hiện trên vành Z_{26} .

Ví dụ 3.5

Để sử dụng mã Vigenere với từ khóa và bản rõ cho trước, ta có thể làm như sau:

- Viết ra các chữ của bản rõ. Sau đó viết các chữ của từ khóa ở dòng trên tương ứng với các chữ của bản rõ. Lặp lại từ khóa cho đến khi hết bản rõ.
- Sử dụng mỗi chữ của từ khóa như khóa của mã Caesar.
- Mã chữ của bản rõ với bước nhảy tương ứng.

Giả sử ta có khóa là “deceptive” và bản rõ là “wearediscoveredsaveyourself”, quá trình mã hóa sẽ thực hiện như sau:

Để mã chữ w , ta tìm chữ tương ứng với nó ở hàng khóa. Đó là chữ d (có số thứ tự là 3), như vậy w sẽ được mã trên bảng chữ tịnh tiến 3, tức là chữ w được tịnh tiến thành chữ Z . Chữ thứ hai trong bản rõ tương ứng với chữ mã là e (có số thứ tự là 4), có nghĩa là chữ thứ hai trong bản rõ sẽ được tịnh tiến 4, tức là chữ r được mã thành chữ I . Tương tự như vậy cho đến hết bản rõ, ta sẽ có bản mã sau:

Khóa: deceptivedeceptivedeceptive

Bản rõ: wearediscoveredsaveyourself

Bản mã: ZICVTWQNGRZGVTWAVZHCQYGLMGI

Trên thực tế, để hỗ trợ mã Vigenere, người ta đã tạo ra một bảng được gọi là bảng Saint Cyr trợ giúp cho việc mã và giải mã thủ công. Đó là một bảng cỡ 26×26 , được lập ra như sau:

- Đầu tiên, viết một dòng các chữ cái từ A đến Z. Sau đó, ở dòng tiếp theo ta dịch vòng dòng trên một ký tự sang trái cho đến khi đủ 26 dòng.
- Viết thêm một dòng chữ cái từ A đến Z ở trên cùng để làm các chữ của từ khóa. Viết thêm một cột chữ cái cũng từ A đến Z ở bên trái để làm các chữ bản rõ khi mã hoá và làm các chữ bản mã khi giải mã.

Sử dụng bảng Saint Cyr để mã hóa và giải mã:

- Để mã hoá thì bản rõ được đọc từ các hàng và khoá được đọc từ các cột. Ví dụ để mã hóa bản rõ PURPLE với từ khoá CRYPTO, đầu tiên ta tìm điểm giao nhau của hàng P và cột C, ta được R. Cứ như vậy ta được bản mã RLPEES.
- Ta sẽ thu được bản mã tương tự nếu ta thay đổi vai trò của hàng và cột trong khi mã hoá. Để giải mã bản mã RLPEES vừa mã hoá, ta nhìn vào hàng nào có chứa R trong cột C, theo cách này ta sẽ tìm được P. Và như vậy ta tìm được bản rõ là PURPLE.

Bảng 3-1: Bảng Saint Cyr

	ABCDEFGHIJKLMN	OPQRSTUVWXYZ
A	ABCDEFGHIJKLMN	OPQRSTUVWXYZ
B	BCDEFGHIJKLMN	OPQRSTUVWXYZA
C	CDEFGHIJKLMN	OPQRSTUVWXYZAB
D	DEFGHIJKLMN	OPQRSTUVWXYZABC
E	EFGHIJKLMN	OPQRSTUVWXYZABCD
F	FGHIJKLMN	OPQRSTUVWXYZABCDE
G	GHIJKLMN	OPQRSTUVWXYZABCDEF
H	HIJKLMN	OPQRSTUVWXYZABCDEFG
I	IJKLMN	OPQRSTUVWXYZABCDEFGH
J	JKLMN	OPQRSTUVWXYZABCDEFGHI
K	KLMN	OPQRSTUVWXYZABCDEFGH
L	LMN	OPQRSTUVWXYZABCDEFGHI
M	MN	OPQRSTUVWXYZABCDEFGH
N	N	OPQRSTUVWXYZABCDEFG
O		OPQRSTUVWXYZABCDEFG
P		OPQRSTUVWXYZABCDEFG
Q		OPQRSTUVWXYZABCDEFG



R	RSTUVWXYZABCDEFGHIJKLMNO
S	STUVWXYZABCDEFGHIJKLMNO
T	TUVWXYZABCDEFGHIJKLMNO
U	UVWXYZABCDEFGHIJKLMNO
V	VWXYZABCDEFGHIJKLMNO
W	WXYZABCDEFGHIJKLMNO
X	XYZABCDEFGHIJKLMNO
Y	YZABCDEFGHIJKLMNO
Z	ZABCDEFGHIJKLMNO

❖ An toàn của mã Vigenere

Như vậy có thể có các chữ mã khác nhau cho cùng một chữ của bản rõ. Suy ra tần suất của các chữ bị là phẳng, nghĩa là tần suất xuất hiện các chữ trên bản mã tương đối đều nhau. Tuy nhiên chưa mất hoàn toàn, do độ dài của khoá có hạn, nên có thể tạo nên chu kỳ vòng lặp. Kẻ thám mã bắt đầu từ tần suất của chữ để xem có phải đây là mã đơn bảng chữ hay không. Giả sử đây là mã đa bảng chữ, sau đó xác định số bảng chữ trong từ khoá và lần tìm từng chữ. Như vậy cần tăng độ dài từ khoá để tăng số bảng chữ dùng khi mã để “là” tần suất của các chữ.

3.2.2 Kỹ thuật mã hóa hoán vị cổ điển

Trong mật mã thay thế, các chữ của bản rõ được thay thế bằng các chữ khác của bản mã. Nhưng trong mật mã hoán vị thì khác. Các chữ trong bản rõ không được thay thế bằng các chữ khác mà chỉ thay đổi vị trí, tức là việc mã hoá chỉ dịch chuyển vị trí tương đối giữa các chữ trong bản rõ. Như vậy, nó dấu bản rõ bằng cách thay đổi thứ tự các chữ, nó không thay đổi các chữ thực tế được dùng.

Trong mục này chúng ta sẽ tìm hiểu hai kỹ thuật mã hóa hoán vị.

a) *Mã Rail Fence*

Đây là mã hoán vị đơn giản, nó viết các chữ của bản rõ theo đường chéo trên một số dòng sau đó đọc các chữ theo từng dòng sẽ nhận được bản mã. Số dòng chính là khoá của mã. Vì khi biết số dòng ta sẽ tính được số chữ trên mỗi dòng và lại viết bản mã theo các dòng sau đó lấy bản rõ bằng cách viết lại theo các cột.

Ví dụ 3.6

Viết bản tin “meet me after the toga party” lần lượt trên hai dòng như sau

```
m e m a t r h t g p r y
e t e f e t e o a a t
```

Sau đó ghép các chữ ở dòng thứ nhất với các chữ ở dòng thứ hai ta có bản mã:

Cách giải mã: Khóa của bản mã này là 2 vì khi mã hóa, bản rõ được chia thành 2 dòng. Bản mã có tổng cộng 23 chữ, do đó khi tách thành 2 dòng thì dòng đầu có 12 chữ, còn dòng sau có 11 chữ. Ghép 2 dòng này thành 1 dòng bằng cách lấy lần lượt mỗi dòng một chữ, bắt đầu từ dòng 1 cho đến hết, ta sẽ thu được bản rõ.

b) Mã dịch chuyển dòng

Mã kiểu này có sơ đồ phức tạp hơn. Viết các chữ của bản tin theo các dòng với số cột xác định. Sau đó thay đổi thứ tự các cột theo một dãy số khoá cho trước, rồi đọc lại chúng theo các cột để nhận được bản mã. Quá trình giải mã được thực hiện ngược lại. Khóa của cách mã hóa này là số cột và thứ tự của các cột.

Ví dụ 3.7

Khóa: 4 3 1 2 5 6 7

Bản rõ: a t t a c k p

o s t p o n e

d u n t i l t

w o a m x y z

Ta đọc theo thứ tự các cột từ lần lượt từ 1 đến 7 để nhận được bản mã:

Bản mã: TTNAAPTMTSUOAODWCOIXKNLYPETZ

Khóa của phép mã hóa này là 7 cột và được xếp theo thứ tự 4 3 1 2 5 6 7.

Giải mã: Bản mã có 28 chữ nên ta sẽ chia thành 7 cột theo thứ tự 4 3 1 2 5 6 7, mỗi cột có 4 chữ. Việc viết các cột sẽ thực hiện như sau:

4 chữ đầu tiên viết vào cột thứ 3, 4 chữ tiếp theo viết vào cột 4, 4 chữ tiếp theo viết vào cột 2, 4 chữ tiếp theo viết vào cột 1, các chữ còn lại viết vào các cột 5, 6 và 7. Sau đó liệt kê theo dòng sẽ thu được bản rõ.

3.2.3 Điểm yếu của mã cổ điển

- Phương pháp mã hoá cổ điển có thể dễ dàng bị giải mã bằng cách đoán chữ dựa trên phương pháp thống kê tần suất xuất hiện các chữ cái trên mã và so sánh với bảng thống kê quan sát của bản rõ.
- Để dùng được mã hoá cổ điển thì bên mã hoá và bên giải mã phải thống nhất với nhau về cơ chế mã hoá cũng như giải mã. Nếu không thì hai bên sẽ không thể làm việc được với nhau.



3.3 Thăm mã đối xứng cổ điển

3.3.1 Khái niệm

Thăm mã là công việc phân tích bản tin mã hóa để nhận được bản tin rõ trong điều kiện không biết trước khóa mã.

Trong thực tế, công việc thăm mã gặp nhiều khó khăn hơn khi không biết rõ hệ mật mã nào được sử dụng. Tuy nhiên, để đơn giản hóa, chúng ta giả sử người thăm mã đã biết rõ hệ mật mã được sử dụng khi tiến hành phân tích mã (theo nguyên lý Kerckhoff). Mục đích là thiết kế được một hệ mật mã an toàn bảo mật.

Trước hết chúng ta cần phân loại mức độ tấn công vào các hệ mật mã. Mức độ này tùy thuộc vào hiểu biết của người thăm mã đối với hệ mật mã được sử dụng. Theo đó, chúng ta có thể chia thành các loại tấn công sau:

- Tấn công chỉ biết bản mã (Ciphertext-Only): người thăm mã chỉ có bản tin mã hóa.
- Tấn công biết bản tin rõ (Known Plaintext): người thăm mã có bản tin rõ và bản mã.
- Tấn công chọn bản tin rõ (Chosen Plaintext): người thăm mã tạm thời có quyền truy xuất tới Bộ mã hóa, do đó anh ta có khả năng chọn bản tin rõ và xây dựng bản mã tương ứng.
- Tấn công chọn bản mã (Chosen Ciphertext): người thăm mã tạm thời có quyền truy xuất tới Bộ giải mã, do đó anh ta có khả năng chọn bản mã và xây dựng lại bản tin rõ tương ứng.

Trong phần này chúng ta chỉ thảo luận về kiểu tấn công được xem là “yếu nhất” - Tấn công chỉ biết bản mã.

Nhiều kỹ thuật thăm mã các bản mã tiếng Anh sử dụng tần suất xuất hiện của 26 chữ cái trong văn bản thông thường để tiến hành việc phân tích bản mã. Becker và Piper đã chia 26 chữ cái thành năm nhóm và chỉ ra xác suất của mỗi nhóm theo thứ tự giảm dần như sau:

- + E, có xác suất khoảng 0.120;
- + T, A, O, I, N, S, H, R, mỗi chữ cái có xác suất nằm trong khoảng từ 0.06 đến 0.09;
- + D, L, mỗi chữ cái có xác suất xấp xỉ 0.04;



- + C, U, M, W, F, G, Y, P, B, mỗi chữ cái có xác suất nằm trong khoảng từ 0.015 đến 0.023;
- + V, K, J, X, Q, Z, mỗi chữ cái có xác suất nhỏ hơn 0.01.
- + Ngoài ra, tần suất xuất hiện của dãy hai hay ba chữ cái liên tiếp được sắp theo thứ tự giảm dần như sau: TH, HE, IN, ER ... THE, ING, AND, HER ...

3.3.2 Thám mã Affine bằng phương pháp thống kê

Phương pháp thống kê chủ yếu dựa vào việc thống kê tần suất xuất hiện của các ký tự có trong bản mã, sau đó thực hiện đối sánh với bảng tần suất xuất hiện của một ngôn ngữ, rồi đưa ra các tính toán, phán đoán kết hợp với việc thử cho đến khi tìm được bản rõ. Sau đây, chúng ta sẽ tìm hiểu cách thức thám mã đối với một bản mã được cho là mã Affine qua một ví dụ.

Ví dụ 3.8 Giả sử ta có được bản mã sau:

FMXVEDKAPHFERBNDKRXRSREFMORUDSDKDVSHVUFEDKAPRKDLYEVLRRHHRH

Trước hết, thống kê tần suất xuất hiện của các chữ cái trong bản mã, sau đó xếp các chữ này theo thứ tự tần suất giảm dần:

Chữ cái	Tần suất	Chữ cái	Tần suất
R	8	A	2
D	6	U	2
E	5	X	2
H	5	L	2
K	5	M	2
F	4	B	1
V	4	N	1
P	3	O	1
S	3	Y	1

Từ bảng trên, ta thấy tần suất xuất hiện các chữ cái theo thứ tự giảm dần là: R(8), D(6), E, H, K(5) và F, V(4). Vì vậy, dự đoán đầu tiên R có thể là mã của e, còn D là mã của t. Theo quy tắc mã hóa Affine, ta có $E_k(4) = 17$ và $E_k(19) = 3$.

Mà $E_k(x) = ax + b$ với a, b là các biến. Do đó, để tìm $k = (a, b)$, ta giải hệ phương trình:

$$(4a + b) \bmod 26 = 17$$

$$(19a + b) \bmod 26 = 3$$



Giải ra, ta được $a = 6$, $b = 19$. Đây không phải là khóa vì $\text{GCD}(a, 26) = 2 > 1$. Tiếp tục phỏng đoán, R là mã của e, E là mã của t và nhận được $a = 13$, không thỏa mãn vì 26 chia hết cho 13. Tiếp tục với H, ta có $a = 8$ cũng không được. Cuối cùng, với phán đoán k là t, ta tìm được $a = 3$ và $b = 5$. Sử dụng khóa mã này ta có được bản tin rõ sau:

Algorithmrequiregeneraldefinitionsofarithmeticprocesses

3.4 Mật mã dòng hiện đại

Đối tượng của các phương pháp mã hóa cổ điển là các bản tin ngôn ngữ. Một đơn vị mã hóa là các chữ cái để áp dụng phương thức thay thế hay phương thức hoán vị. Cùng với sự phát triển của máy tính, thông tin ngày một trở nên đa dạng hơn, một bản tin bây giờ không chỉ đơn giản là bản tin gồm các chữ cái, mà có thể gồm cả các thông tin về định dạng văn bản như tài liệu HTML... Ngoài ra, bản tin có thể xuất hiện dưới các loại hình khác như hình ảnh, video, âm thanh... Tất cả các bản tin đó đều được biểu diễn trên máy tính dưới dạng một dãy các số nhị phân. Tương tự như bản tin ngôn ngữ, trong bản tin nhị phân cũng tồn tại một số đặc tính thống kê nào đó mà người phá mã có thể tận dụng để phá bản mã, dù rằng bản mã bây giờ tồn tại dưới dạng nhị phân.

Mật mã dòng là phương pháp mã hóa từng dòng bit và có các đặc tính sau:

- Kích thước một đơn vị mã hóa gồm k bit. Bản rõ P được chia thành các đơn vị mã hóa, $P = p_0 p_1 \dots p_{n-1}$, trong đó mỗi đơn vị p_i gồm k bit.
- Một bộ sinh dãy số ngẫu nhiên với hạt giống K cho trước sẽ sinh ra n số ngẫu nhiên có kích thước bằng kích thước đơn vị mã hóa, $S = s_0 s_1 \dots s_{n-1}$, trong đó mọi số ngẫu nhiên s_i gồm k bits.
- Mỗi số ngẫu nhiên được XOR với đơn vị mã hóa tương ứng của bản rõ để có được bản mã.

$$c_0 = p_0 \oplus s_0, c_1 = p_1 \oplus s_1, \dots, c_{n-1} = p_{n-1} \oplus s_{n-1}$$

$$C = c_0 c_1 \dots c_{n-1}$$

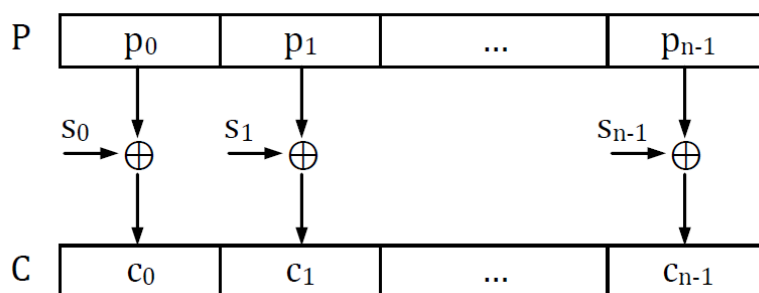
- Quá trình giải mã được thực hiện ngược lại, bản mã C được XOR với dãy số ngẫu nhiên S để cho ra bản rõ ban đầu:

$$p_0 = s_0 \oplus c_0, p_1 = s_1 \oplus c_1, \dots, p_{n-1} = s_{n-1} \oplus c_{n-1}$$

Hình 3-2 dưới đây minh họa một mô hình mã dòng. Có thể thấy mã hóa dòng tương tự như mã hóa Vigenere. Điểm quan trọng nhất của các mã dòng là bộ sinh số



ngẫu nhiên. Nếu chọn khóa có chiều dài ngắn như mã hóa Vigenere thì không bảo đảm an toàn.



Hình 3-2: Mô hình mã dòng

Bộ sinh số của mã dòng cho phép dùng một khóa ngắn nhưng dãy số sinh ra bảo đảm một độ ngẫu nhiên cần thiết dù rằng không hoàn toàn thực sự ngẫu nhiên.

3.5 Mật mã khối

3.5.1 Nguyên lý chung

Các hệ mật mã khối (Block Cipher) được sử dụng rất rộng rãi trong các ứng dụng công nghệ thông tin và truyền thông. Một hệ mật mã được gọi là hệ mật mã khối nếu nó mã hóa các từ của bản tin rõ theo từng khối bit thành các khối bit từ mã có độ dài cố định. Thông thường, mỗi khối bit sẽ có độ dài là một bội số của 2, chẳng hạn là $64 = 2^6$. Một cách trực quan, tất cả các thuật toán mã hóa khối đối xứng hiện nay đều dựa trên cấu trúc của mật mã khối Feistel. Do đó, phần này ta sẽ tập trung vào các nguyên lý thiết kế của mật mã Feistel. Sau đó, ta xem xét kỹ hệ mật mã khối DES nổi tiếng đã được sử dụng làm chuẩn mã hóa dữ liệu của Mỹ.

Horst Feistel sáng tạo ra mã Feistel dựa trên mã tích nghịch đảo được, tức là kết hợp mã thay thế với mã hoán vị và qui trình giải mã là giống với mã hoá, chỉ cần thay đổi vai trò khối bản mã với khối bản rõ và thứ tự các khoá con được dùng.

Trong hệ mã Feistel, bản rõ sẽ được biến đổi qua một số vòng để cho ra bản mã cuối cùng:

$$P \xrightarrow{K_1} C_1 \xrightarrow{K_2} C_2 \xrightarrow{K_3} \dots \xrightarrow{K_{n-1}} C_n$$

trong đó bản rõ P và các bản mã C_i được chia thành hai nửa trái và phải:

$$P = (L_0, R_0)$$

$$C_i = (L_i, R_i), \text{ với } i = 1, 2, \dots, n$$



Quy tắc biến đổi các nửa trái phải này qua các vòng được thực hiện như sau:

$$L_i = R_{i-1}$$

$$R_i = L_{i-1} \oplus F(R_{i-1}, K_i)$$

Trong đó, K_i là một khóa con cho vòng thứ i . Khóa con này được sinh ra từ khóa K ban đầu theo một thuật toán sinh khóa con (key generation): $K \rightarrow K_1 \rightarrow K_2 \rightarrow \dots \rightarrow K_n$. F là một hàm mã hóa dùng chung cho tất cả các vòng. Hàm F đóng vai trò như là phép thay thế còn việc hoán đổi các nửa trái, phải đóng vai trò hoán vị. Bản mã C được tính từ kết xuất của vòng cuối cùng:

$$C = C_n = (L_n, R_n)$$

Sơ đồ tính toán của hệ mã Feistel được thể hiện trong Hình 3.2.

Để giải mã, ta thực hiện qui trình này theo thứ tự ngược lại:

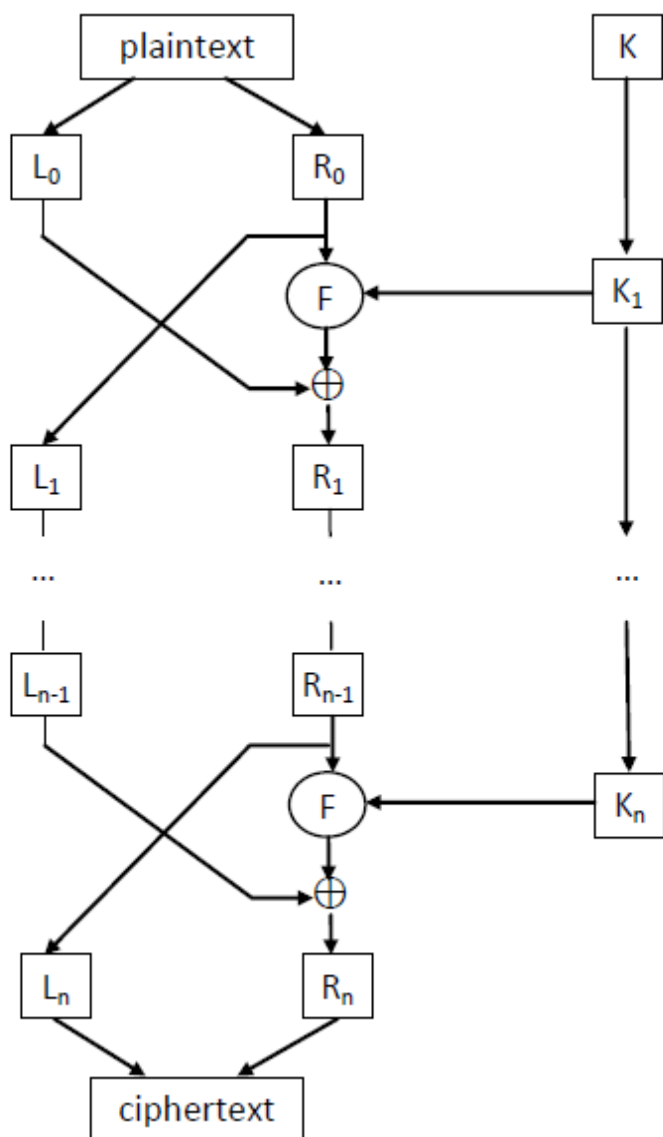
$$C = (L_n, R_n)$$

$$R_{i-1} = L_i$$

$$L_{i-1} = R_i \oplus F(R_{i-1}, K_i)$$

và cuối cùng bản rõ là $P = (L_0, R_0)$.

Hệ mã Feistel có một điểm quan trọng là việc chia các bản mã thành hai nửa trái phải giúp cho hàm F không cần khả nghịch (không cần có F^{-1}). Mã hóa và giải mã đều dùng chiều thuận của hàm F . Hàm F và thuật toán sinh khóa con càng phức tạp thì càng khó phá mã, hệ thống càng an toàn.



Hình 3-3: Mô hình mã khối Feistel

Ứng với các hàm F và thuật toán sinh khóa con khác nhau, ta sẽ có các phương pháp mã hóa khác nhau.

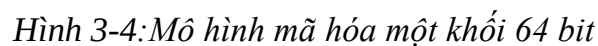
Phần tiếp theo sẽ trình bày mã hóa DES, một phương pháp mã hóa nổi tiếng dựa trên nguyên tắc của hệ mã Feistel.

3.5.2 Hệ mã hóa DES

a) Mô hình của DES

Mã DES (Data Encryption Standard) là mã thuộc hệ mã Feistel bao gồm 16 vòng. Ngoài ra, DES có thêm một hoán vị khởi tạo trước khi vào vòng 1 và một hoán vị kết thúc sau vòng 16. Kích thước của khối bits đầu vào là 64 bits. Kích thước khóa





- **Đầu vào:** một thông điệp M gồm 64 bits và một khóa K gồm 64 bits
- **Đầu ra:** bản mã C gồm 64 bits.

Bước 2: Chia M' thành hai nửa $L_0 = 32$ bits trái $R_0 = 32$ bits phải.

For i = 1 to 16 do

$$R_i = L_{i-1} \oplus F(R_{i-1}, K_i) \quad // F \text{ là hàm Feistel sẽ được định nghĩa sau.}$$

71



Bước 4: Đổi chỗ hai nửa trái, phải L_{16} , R_{16} . Sau đó, hoán vị bằng phép hoán vị kết thúc FP để cho ra bản mã C của M .

Theo mô hình và thuật toán của DES đã trình bày trên đây, ta thấy mã DES bao gồm ba phần:

- Hoán vị khởi tạo và hoán vị kết thúc,
- Các vòng mã Feistel
- Thuật toán sinh khóa con.

Sau đây, chúng ta sẽ mô tả chi tiết từng phần của DES.

- *Hoán vị khởi tạo và hoán vị kết thúc*

Giả sử 64 bits của M được đánh số theo thứ tự từ trái sang phải là 0, 1, 2, ..., 62, 63. Hoán vị khởi tạo sẽ hoán đổi các bits theo quy tắc sau:

$$b_0b_1b_2 \dots b_{62}b_{63} \rightarrow b_{57}b_{49}b_{41} \dots b_{14}b_6$$

57	49	41	33	25	17	9	1
59	51	43	35	27	19	11	3
61	53	45	37	29	21	13	5
63	55	47	39	31	23	15	7
56	48	40	32	24	16	8	0
58	50	42	34	26	18	10	2
60	52	44	36	28	20	12	4
62	54	46	38	30	22	14	6

Hoán vị kết thúc hoán đổi các bits của kết quả cuối cùng sau khi đổi chỗ hai nửa trái, phải cho nhau theo quy tắc sau:

Cột 2 gồm các bits $b_7b_6 \dots b_1b_0$; Cột 4 là các bit có số thứ tự bằng số thứ tự của các bit ở cột 1 cộng thêm 8; cột 6 bằng cột 4 cộng thêm 8; cột 8 bằng cột 6 cộng thêm 8; Cột 1 bằng cột 8 cộng thêm 8; cột 3 bằng cột 1 cộng thêm 8; cột 5 bằng cột 3 cộng thêm 8.

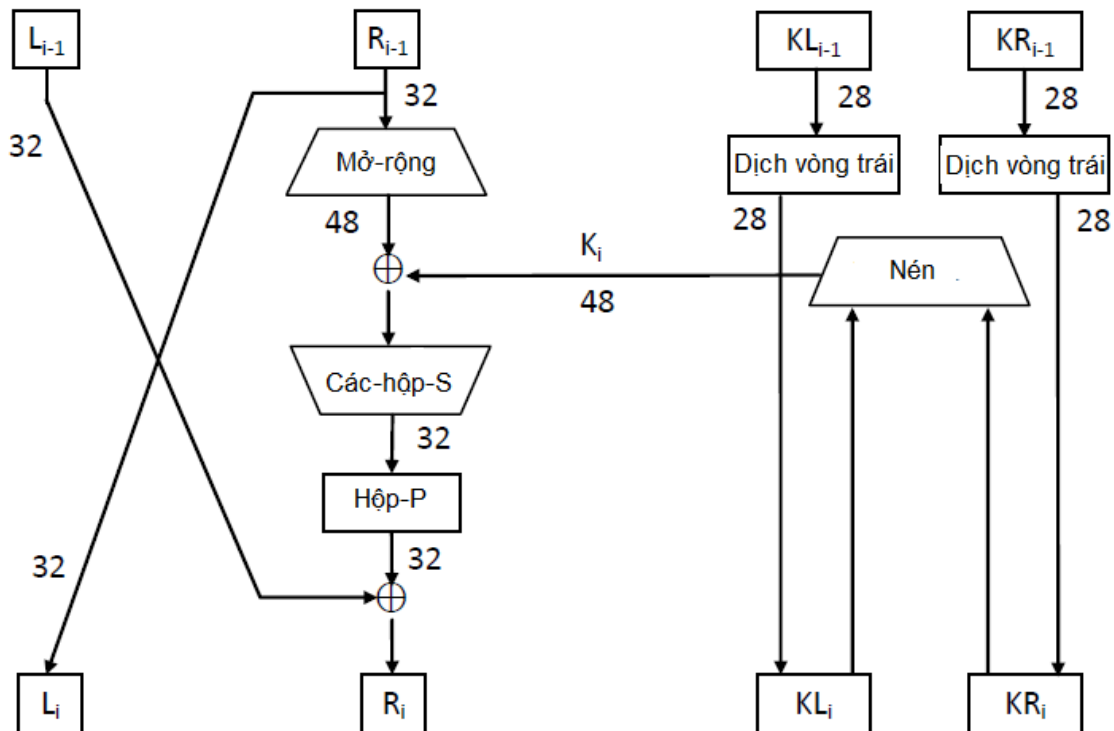
39	7	47	15	55	23	63	31
38	6	46	14	54	22	62	30
37	5	45	13	53	21	61	29
36	4	44	12	52	20	60	28
35	3	43	11	51	19	59	27
34	2	42	10	50	18	58	26
33	1	41	9	49	17	57	25
32	0	40	8	48	16	56	24

Hoán vị kết thúc chính là hoán vị nghịch đảo của hoán vị khởi tạo, $FP = IP^{-1}$. Hai phép hoán vị này không có ý nghĩa về mặt mã hóa. Chúng chỉ có tác dụng dùng để nạp và xuất dữ liệu theo cơ chế của phần cứng thời DES được sinh ra.



– Các vòng mã hóa của DES

DES dùng 16 vòng Feistel để mã hóa. Hình 3.4 mô tả vòng thứ i của DES.



Hình 3-5: Cấu trúc một vòng mã của DES

Trong hình này có hai nửa. Nửa bên trái là qui trình mã hóa kết quả của vòng mã thứ $i-1$, $C_{i-1} = L_{i-1}R_{i-1}$ có sự tham gia của khóa con K_i . Khóa con này được sinh ra bởi lược đồ sinh khóa ở nửa bên phải.

Trong nửa trái, bắt đầu từ hàm *Mở-rộng* cho đến *Hộp-P* gộp lại thành một hàm Feistel F có công thức như sau:

$$F(R_{i-1}, K_i) = \text{Hộp-P}(\text{Các-hộp-S}(\text{Mở-rộng}(R_{i-1}) \oplus K_i))$$

Trong đó, hàm *Mở-rộng* vừa mở rộng vừa hoán vị R_{i-1} từ 32 bits lên 48 bits. Hàm *Các-hộp-S* nén chuỗi 48 bits còn 32 bits. Hàm *Hộp-P* là một hoán vị 32 bits.

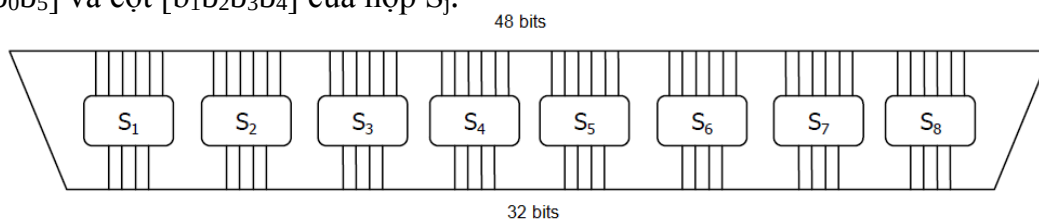
– Mô tả các hàm con trong F

Hàm *Mở-rộng* sẽ mở rộng 32 bits của R_{i-1} thành 48 bits. Đầu tiên, đánh số các bits của R_{i-1} theo thứ tự từ trái sang phải là 0, 1, 2, ..., 31 và viết dưới dạng một ma trận 4 cột, 8 dòng. Sau đó, tạo thêm một cột bên trái bằng cột thứ 4 nhưng dịch vòng xuống dưới một dòng. Tiếp theo, tạo thêm một cột bên phải bằng cột thứ nhất (cũ) nhưng dịch vòng lên trên một dòng. Cuối cùng $\text{Mở-rộng}(R_{i-1})$ có dạng sau:

31	0	1	2	3	4
3	4	5	6	7	8
7	8	9	10	11	12
11	12	13	14	15	16
15	16	17	18	19	20
19	20	21	22	23	24
23	24	25	26	27	28
27	28	29	30	31	0

Hàm *Các-hộp-S* lại thu hẹp 48 bits của *Mở-rộng* (R_{i-1}) $\oplus K_i$ thành 32 bits. Hàm này chia 48 bits đầu vào thành 8 nhóm, mỗi nhóm 6 bits và sử dụng 8 hộp con S_j ($j = 1, 2, \dots, 8$) tương ứng với 8 nhóm để nén 6 bits thành 4 bits. Hình 3.5 là mô tả của hàm *Các-hộp-S*. Cách nén được thực hiện như sau:

Giả sử 6 bits của nhóm j là $B_j = b_0b_1b_2b_3b_4b_5$. Lấy bit đầu b_0 ghép với bit cuối b_5 để xác định thứ tự hàng; 4 bits còn lại cũng ghép lại để xác định thứ tự cột của hộp S_j . Ta sẽ có $S_j(B_j) = S_j[b_0b_5][b_1b_2b_3b_4]$. Đây là giá trị thập phân tại ô nằm ở giao điểm của dòng $[b_0b_5]$ và cột $[b_1b_2b_3b_4]$ của hộp S_j .



Hình 3-6: Hàm *Các-hộp-S*

Hình 3-7 là hộp S_1 của hàm *Các-hộp-S*. Các hộp còn lại sẽ được liệt kê trong Phụ lục 1 của giáo trình này.

		$b_1b_2b_3b_4$															
		0000	0001	0010	0011	0100	0101	0110	0111	1000	1001	1010	1011	1100	1101	1110	1111
b_0b_5	00	1110	0100	1101	0001	0010	1111	1011	1000	0011	1010	0110	1100	0101	1001	0000	0111
	01	0000	1111	0111	0100	1110	0010	1101	0001	1010	0110	1100	1011	1001	0101	0011	1000
	10	0100	0001	1110	1000	1101	0110	0010	1011	1111	1100	1001	0111	0011	1010	0101	0000
	11	1111	1100	1000	0010	0100	1001	0001	0111	0101	1011	0011	1110	1010	0000	0110	1101

Hình 3-7: Hộp S_1

Ví dụ: đầu vào của hộp S_1 là $B_1=101011$. Ta có $S_1(B_1) = S[11][0101]=1001$. Tức là đầu ra của S_1 là 1001.

Có thể thấy, mỗi hàm con của hàm *Các-hộp-S* là một phép thay thế. Các hàm con này không khả nghịch, do đó hàm *Các-hộp-S* cũng không khả nghịch. Sự phức tạp này của các hàm con là yếu tố chính làm cho DES có độ an toàn cao.



Hàm *Hộp -P*: hàm này thực hiện hoán vị 32 bits đầu vào được đánh số thứ tự từ trái qua phải theo quy tắc:

15	6	19	20	28	11	27	16
0	14	22	25	4	17	30	9
1	7	23	13	31	26	2	8
18	12	29	5	21	10	3	24

– *Thuật toán sinh khóa con của DES*

Khóa K gồm 64 bits được đánh số từ trái sang phải bắt đầu từ 0. Sau đó bỏ đi 8 bits dùng để kiểm tra chẵn lẻ 7, 15, 23, ..., 63 và hoán vị theo hàm PC-1 thành một khóa 56 bits theo quy tắc:

56	48	40	32	24	16	8	
0	57	49	41	33	25	17	
9	1	58	50	42	34	26	
18	10	2	59	51	43	35	
62	54	46	38	30	22	14	
6	61	53	45	37	29	21	
13	5	60	52	44	36	28	
20	12	4	27	19	11	3	

Khóa 56 bit này được chia thành 2 nửa trái phải KL_0 và KR_0 , mỗi nửa có kích thước 28 bits.

Có thể viết thành công thức như sau:

$$PC-1(K) = KL_0KR_0$$

Tại vòng thứ i ($i = 1, 2, 3, \dots, 16$), KL_i và KR_i được xác định qua KL_{i-1} và KR_{i-1} như sau:

$$KL_i = LS_i(KL_{i-1})$$

$$KR_i = LS_i(KR_{i-1})$$

Trong đó LS_i là phép dịch vòng sang trái 1 hoặc 2 bit tùy thuộc vào giá trị của i . Nếu $i = 1, 2, 9, 16$ thì dịch 1 bit, đối với các trường hợp khác thì dịch 2 bit. Cuối cùng hàm *Nén* sẽ đánh số thứ tự bắt đầu 0 và từ trái qua phải 28 bits của KL_i , sau đó đánh số tiếp 28 bits của KR_i . Tiếp theo, nén 56 bits này thành 48 bits bằng cách bỏ đi 8 bits 8, 17, 21, 24, 34, 37, 42, 53 và sau đó được hoán vị theo qui tắc sau:

13	16	10	23	0	4	2	27
14	5	20	9	22	18	11	3
25	7	15	6	26	19	12	1
40	51	30	36	46	54	29	39
50	44	32	47	43	48	38	55
33	52	45	41	49	35	28	31



Đây chính là khóa con K_i . Công thức dùng để tính khóa K_i là

$$K_i = \text{Nén}(KL_i KR_i)$$

Cuối cùng khóa con K_i gồm 48 bits sẽ được XOR với R_{i-1} đã mở rộng từ 32 thành 48 bits.

Để hiểu rõ hơn hoạt động của DES, có thể đọc thêm một ví dụ về các bước mã hóa một bản rõ được trình bày trong Phụ lục 1 ở cuối giáo trình.

– *Hiệu ứng lan truyền (Avalanche Effect)*

Một tính chất quan trọng cần thiết của mọi thuật toán mã hóa là chỉ cần một thay đổi nhỏ trong bản rõ hay trong khóa sẽ dẫn đến thay đổi lớn trong bản mã. Cụ thể, chỉ cần thay đổi một bit trong bản rõ hay khóa thì dẫn đến sự thay đổi của nhiều bit bản mã. Tính chất này được gọi là hiệu ứng lan truyền. Nhờ có tính chất này mà người phá mã không thể giới hạn miền tìm kiếm của bản rõ hay của khóa nên buộc phải thực hiện vét cạn khóa.

Đã có khá nhiều ví dụ chứng tỏ DES là một phương pháp mã hóa có hiệu ứng lan truyền này.

– *Độ an toàn của DES*

Ta hãy xem xét độ an toàn của DES trước một vài phương pháp tấn công phá mã.

– *Tấn công vét cạn khóa (Brute Force Attack):*

Vì khóa của mã DES có chiều dài là 56 bits nên để tiến hành tấn công vét cạn cần phải kiểm tra 2^{56} khóa khác nhau. Hiện nay, với những thiết bị phổ dụng, thời gian thử khóa là rất lớn nên việc phá mã là không khả thi. Tuy nhiên vào năm 1998, tổ chức Electronic Frontier Foundation (EFF) thông báo đã xây dựng được một thiết bị phá mã DES gồm nhiều máy tính chạy song song, trị giá khoảng 250.000\$. Thời gian thử khóa là 3 ngày. Hiện nay mã DES vẫn còn được sử dụng trong thương mại, tuy nhiên người ta đã bắt đầu áp dụng những phương pháp mã hóa khác có chiều dài khóa lớn hơn (128 bit hay 256 bit) như TripleDES hoặc AES.

– *Phá mã DES theo phương pháp vi sai (differential cryptanalysis):*

Năm 1990 Biham và Shamir đã giới thiệu phương pháp phá mã vi sai. Phương pháp vi sai tìm khóa ít tốn thời gian hơn vét cạn. Tuy nhiên phương pháp phá mã này lại đòi hỏi phải có 2^{47} cặp bản rõ - bản mã được lựa chọn (chosen-plaintext). Vì vậy phương pháp này là bất khả thi dù rằng số lần thử có thể ít hơn phương pháp vét cạn.



– *Phá mã DES theo phương pháp thử tuyến tính (linear cryptanalysis)*

Năm 1997, Matsui đưa ra phương pháp phá mã tuyến tính. Trong phương pháp này, cần phải biết trước 2^{43} cặp bản rõ-bản mã (known-plaintext). Tuy nhiên 2^{43} cũng là một con số lớn nên phá mã tuyến tính cũng không phải là một phương pháp khả thi.

3.6 Câu hỏi và bài tập

3.6.1 Câu hỏi

3.1) Sự khác nhau giữa mật mã khối (block) và mật mã dòng (stream) là gì? Mật mã DES thuộc loại nào?

3.2) Cần bao nhiêu khóa để hai người có thể truyền tin mật cho nhau?

3.3) Hãy định nghĩa ngắn gọn mật mã Ceasar và mật mã affine.

3.4) Sự khác nhau giữa mật mã một bảng chữ cái (monoalphabetic) và mật mã nhiều bảng chữ cái (polyalphabetic) là gì?

3.5) Hãy trình bày lược đồ sinh khóa con thứ i của DES.

3.6) Hãy trình bày cấu trúc của chu trình thứ i của chuẩn mã hóa dữ liệu DES.

3.7) Hãy minh họa lược đồ mã hóa và giải mã khóa đối xứng bằng một sơ đồ.

3.8) Hãy mô tả phép hoán vị khởi tạo (IP) và phép hoán vị kết thúc (FP) của DES.

3.9) Mục đích của các hộp S_i ($i=1,2, \dots, 8$) trong chuẩn mã hóa DES là gì ?

3.10) Tại sao phải mở rộng 32 bit dữ liệu thành 48 bits trong thuật toán mã hóa DES? Mở rộng như thế nào?

3.6.2 Bài tập

3.1) Hãy sử dụng thuật toán Vigenère, mã hóa hoặc giải mã các chuỗi ký tự bằng từ khóa tương ứng:

$C_1 = \text{PIGHPIDJVSUWHZGBRGOSEY}, K = \text{DECODE}$

$C_2 = \text{VPXZGIA XIVWPUBTTMJPWIZITWZT}, K = \text{CIPHER}$

$C_3 = \text{YMLPPCCBIHGBCBHLZVPIB}, K = \text{CIPHER}$

$S_1 = \text{NETWORKSECURITYISVERYIMPORTANT}, K = \text{SOFTWARE}$



3.2) Sử dụng hệ mật Affine với khóa $K=(a, b) = (3, 5)$ giải mã hoặc mã hóa các bản mã hoặc bản rõ sau đây:

$C_1 = \text{TRFERHKNOZDSXLEZYKVXEFYAZ}$

$C_2 = \text{SVKRQREZHKRFPIFKADHHFNSF}$

$P_1 = \text{WEWILLATTACKATSEVENAM}$

3.3) Một bản mã được sinh ra bằng hệ mật Affine. Trong đó, chữ cái xuất hiện nhiều nhất là chữ 'B', và chữ cái xuất hiện nhiều thứ hai là chữ 'U'. Hãy bẻ khóa bản mã này.

3.4) Các bản mã sau đây được sinh ra bằng hệ mật Affine. Hãy giải mã chúng

$C_1 = \text{SOBPTUKBVNIKBOVBGU}$

$C_2 = \text{IOBHJBMCAYZDMCBECYBCCBODVB}$



CHƯƠNG 4. CÁC HỆ MẬT MÃ KHÓA CÔNG KHAI

4.1 Mã hóa khóa công khai

4.1.1 Những hạn chế của mã hóa khóa đối xứng

Trong các chương trước, chúng ta đã làm quen với các khái niệm quan trọng liên quan đến việc truyền tin bảo mật trên các mạng truyền tin công cộng, các kỹ thuật mật mã và mật mã khóa đối xứng.

Mã hóa đối xứng dù rằng đã phát triển từ cổ điển đến hiện đại, vẫn tồn tại hai điểm yếu sau:

- Vấn đề trao đổi khóa giữa người gửi và người nhận: cần phải có một kênh an toàn để trao đổi khóa sao cho khóa phải được giữ bí mật chỉ có người gửi và người nhận biết. Điều này tỏ ra không hợp lý khi mà ngày nay, khối lượng thông tin luân chuyển trên khắp thế giới là rất lớn. Việc thiết lập một kênh an toàn như vậy sẽ tốn kém về mặt chi phí và chậm trễ về mặt thời gian.
- Tính bí mật của khóa: không có cơ sở quy trách nhiệm nếu khóa bị tiết lộ.

Trong chương này, ta sẽ tiếp cận kiến thức tổng quan về hệ mật mã khóa công khai. Đặc biệt, ta sẽ tập trung nghiên cứu hệ mật mã khóa công khai điển hình RSA.

Hệ mật mã khóa công khai là một bước tiến lớn nhất và là cuộc cách mạng thực sự trong lĩnh vực mật mã. Sau hàng thiên niên kỷ làm việc với các giải thuật mã hoá và giải mã thủ công, sự ra đời của các thiết bị mã hoá và giải mã tự động đánh dấu một bước ngoặt lớn. Tuy nhiên, các giải thuật mã hoá mặc dù rất phức tạp chẳng hạn như DES của IBM, cũng vẫn dựa trên hai kỹ thuật cơ bản là hoán vị và thay thế. Vì thế cần phải phát triển những phương pháp mã hóa khác nhằm khắc phục được những nhược điểm trên đây của các phương pháp mã hóa khóa đối xứng.

4.1.2 Mã hóa khóa công khai

Vào năm 1976, Whitfield Diffie và Martin Hellman đã tìm ra một phương pháp mã hóa khác mà có thể giải quyết được hai vấn đề trên, đó là mã hóa khóa công khai (Public Key Cryptography) hay còn gọi là mã hóa bất đối xứng (Asymmetric Cryptography). Đây có thể xem là một bước đột phá quan trọng nhất trong lĩnh vực mã hóa.

Để khắc phục điểm yếu của mã hóa đối xứng, người ta tập trung vào nghiên cứu theo hướng liệu có cách nào có thể mã hóa và giải mã dùng hai khóa khác nhau hay

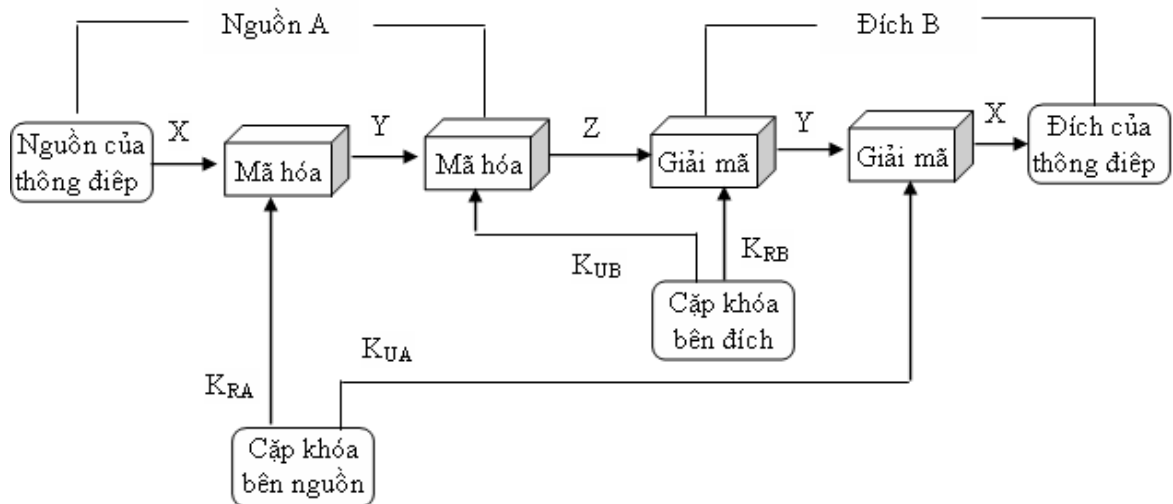


không. Nghĩa là tìm được hai thuật toán E và D là ngược của nhau nhưng lại sử dụng hai khóa khác nhau K_U và K_R : $C = E(P, K_U)$ và $P = D(C, K_R)$. Sau đó, mỗi thành viên cộng đồng mật hóa cần phải có hai khóa có tính chất như trên, trong đó một khóa (giả sử là K_U) sẽ được công khai cho mọi người cùng biết còn khóa kia (giả sử là K_R) thì của người nào người đó phải giữ bí mật. Nếu thực hiện được như vậy thì chúng ta sẽ có thể có hai ứng dụng sau đây.

- Gửi tin mật: Giả định là có 2 người là Bob và Alice thường xuyên trao đổi thư từ với nhau nhưng lại không muốn người thứ ba là Mallory biết. Để có thể đảm bảo được việc này thì khi Alice muốn gửi thư cho Bob, Alice phải làm như sau. Alice dùng khóa công khai của Bob (K_{UB}) để mã hóa thư của mình rồi gửi cho Bob. Khi nhận được thư của Alice (đã mã hóa), Bob sẽ dùng khóa bí mật của mình (K_{RB}) để giải mã. Trong lúc này, Mallory có thể biết việc trao đổi này nhưng cho dù anh ta biết khóa K_{UB} của Bob nhưng lại không thể dùng K_{UB} để giải mã mà phải dùng K_{RB} mới giải được, mà khóa này lại chỉ mình Bob có. Do đó, chỉ có duy nhất Bob mới có thể giải mã được. Điều này bảo đảm tính bảo mật của quá trình truyền dữ liệu. Ưu điểm của phương án này là không cần phải truyền khóa K_{RB} trên kênh an toàn.
- Xác thực thông tin: Bây giờ Alice lại muốn gửi cho Bob một thông tin quan trọng nhưng không cần phải giữ bí mật mà chỉ muốn khẳng định là thư này là do đích thân cô gửi cho anh. Để làm được việc này, Alice sẽ dùng khóa bí mật của mình (K_{RA}) để mã hóa thư rồi gửi cho Bob. Khi nhận được thư của Alice, Bob sẽ dùng khóa công khai của Alice (K_{UA}) để giải mã. Nếu giải được thì đây chính là thư do Alice gửi. Nhưng vì thư của Alice được mã hóa bằng khóa bí mật của Alice nên Mallory cũng có thể giải mã được thư này vì ai cũng biết khóa công khai K_{UA} của Alice. Do đó, phương án này không được dùng để đảm bảo tính bí mật mà chủ ý được dùng để đảm bảo tính xác thực và tính không thể chối bỏ đối với thông tin đã gửi vì chỉ có duy nhất Alice biết được khóa bí mật (K_{RA}) của cô ấy, nên nếu Bob dùng khóa công khai K_{UA} của Alice mà giải mã được thư này thì điều đó có nghĩa là Alice là người đã gửi thư cho anh.

Hình 4-1 mô tả một qui trình mã hóa và giải mã bằng khóa công khai. Mô hình này thực hiện cùng một lúc hai mục đích, xác thực và mật hóa bằng cách sử dụng hai cặp khóa công khai và một cặp thuật toán mã hóa và giải mã.





Hình 4-1: Mật hóa và xác thực tin gửi bằng khóa công khai

Vì vậy, nếu kết hợp hai ứng dụng này lại thì ta sẽ có một mô hình mã hóa và xác thực khắc phục được các nhược điểm của mã hóa đối xứng. Trong cả hai phương án, một khóa được giữ bí mật, chỉ một người biết, còn khóa kia được công khai. Do đó, mô hình mã hóa trên được gọi là mã hóa khóa công khai (hay mã hóa bất đối xứng). Để thuận tiện ta quy ước lại các ký hiệu như sau:

Để tránh nhầm lẫn với khóa bí mật của mã đối xứng, khóa bí mật trong mô hình mã hóa khóa công khai được gọi là khóa riêng (pRivate Key) và ký hiệu là K_R . Khóa công khai (pUblIC Key) được ký hiệu là K_U . Nếu muốn chỉ cặp khóa của ai đó thì thêm tên của người này vào. Ví dụ K_{UA} và K_{RA} là để chỉ cặp khóa công khai và bí mật của A (viết tắt của Alice).

Bản rõ được ký hiệu là M , còn bản mã được ký hiệu là C .

Khi đó, nếu A muốn gửi M cho B và chỉ cho B đọc được thì A mã hóa M bằng khóa công khai của B; Khi nhận được bản mã, B dùng khóa riêng của mình để giải mã ra M :

$$C = E(M, K_{UB}) \text{ và} \\ M = D(C, K_{RB})$$

Còn nếu A muốn B xác thực M là do A đích thân soạn và gửi thì A mã hóa M bằng khóa riêng của mình; Khi nhận được bản mã, B dùng khóa công khai của B để giải ra M :

$$C = E(M, K_{RA}) \\ M = D(C, K_{UA})$$

Vấn đề còn lại ở đây là liệu có tồn tại một mô hình mã hóa và giải mã dùng hai khóa khác nhau như vậy không. Dĩ nhiên là hai khóa K_U và K_R không thể nào hoàn toàn độc lập với nhau. Phải có một mối quan hệ nào đó giữa K_U và K_R thì mới có thể tiến hành mã hóa và giải mã được. Có nghĩa là tồn tại một hàm f sao cho $K_R = f(K_U)$. Tuy nhiên một yêu cầu rất quan trọng là việc tính $K_R = f(K_U)$ phải là bất khả thi về mặt thời gian. Nếu nguyên tắc này bị vi phạm thì việc giữ bí mật khóa K_R không còn ý nghĩa vì từ khóa công khai K_U có thể tính được K_R .

Để có được cặp khóa K_R và K_U như trên, người ta thường dùng các hàm một chiều. Các hàm một chiều có tính chất là hàm nghịch đảo của chúng rất khó thực hiện. Sau đây là ví dụ về hàm một chiều: việc sinh ra hai số nguyên tố lớn p , q và tính tích $N = pq$ thì thực hiện dễ dàng. Tuy nhiên nếu chỉ cho trước N và thực hiện phân tích N để tìm lại hai số nguyên tố p , q là việc hoàn toàn bất khả thi về mặt thời gian. Chúng ta sẽ xem cách thức áp dụng hàm một chiều này để tạo khóa K_R và K_U trong phần mã hóa RSA.

Tóm lại, lý do của việc ra đời khóa công khai và những đặc trưng cần phải có của phương pháp mã hóa sử dụng loại khóa này là:

a) Lý do phải sử dụng mã hóa khoá công khai

- Phân phối khoá: làm sao có thể phân phối khóa an toàn mà không cần trung tâm phân phối khóa tin cậy.
- Chữ ký điện tử: làm sao có thể kiểm chứng được rằng thông tin gửi đến là nguyên vẹn và từ đúng người đứng tên gửi.

b) Các đặc trưng cần phải có của mã hóa khoá công khai

- Không có khả năng tính toán để tìm khóa giải mã nếu chỉ biết thuật toán mã và khóa dùng để mã.
- Có thể dễ dàng mã hoá hoặc giải mã mẫu tin nếu biết khóa tương ứng.
- Trong một số sơ đồ, một khóa bất kỳ trong hai khóa có thể dùng để mã, còn khóa kia dùng để giải mã. Chúng có vai trò đối ngược nhau.

Có nhiều phương pháp mã hóa thuộc loại mã hóa khóa công khai. Đó là các phương pháp Knapsack, RSA, Elgaman, và phương pháp đường cong elliptic ECC.... Mỗi phương pháp sử dụng một hàm một chiều khác nhau. Trong tài liệu này, chúng ta chỉ tập trung vào tìm hiểu phương pháp RSA.

4.2 Mã hóa khóa công khai RSA

RSA là một phương pháp mã hóa khóa công khai. RSA được xây dựng bởi các tác giả Ron Rivest, Adi Shamir và Len Adleman tại học viện MIT của Mỹ vào năm



1977, và ngày nay đang được sử dụng rộng rãi. Về mặt tổng quát, RSA là một phương pháp mã hóa theo khối, trong đó, bản rõ M và bản mã C là các số nguyên trong khoảng từ 0 đến 2^i với i là số bits của một khối. Kích thước thường dùng của i là 1024. Hàm một chiều trong RSA là hàm phân tích một số nguyên thành tích của hai số nguyên tố.

4.2.1 Nguyên tắc thực hiện của RSA

a) Tạo khóa công khai và bí mật

Mỗi người sử dụng, giả dụ là Alice, cần phải tạo một cặp khóa công khai – bí mật theo các bước sau:

- Chọn ngẫu nhiên hai số nguyên tố khác nhau p và q đủ lớn. Nhưng chọn p và q như thế nào là đủ lớn cũng là một vấn đề. Nếu p, q càng lớn thì càng khó phá vỡ RSA, tuy nhiên thời gian để mã hoá và giải mã sẽ tăng lên đáng kể. Phòng nghiên cứu RSA đề xuất rằng tích của p và q nên có độ dài 1024 bit, nhưng cũng có thể chọn là 768 bit đối với các thông tin ít có giá trị hơn.
- Tính $N = p \times q$ và $n = (p - 1)(q - 1)$;
Cần chọn p và q sao cho $M < 2^{i-1} < N < 2^i$. Với $i = 1024$ thì N là một số nguyên dài khoảng 309 chữ số.
- Chọn một số nguyên e thỏa mãn điều kiện $0 < e < n$ và nguyên tố cùng nhau với n , tức là $\text{GCD}(e, n) = 1$. Đến đây, Alice lấy cặp số $\{e, N\}$ làm khóa công khai K_{UA} và công bố cho mọi người biết. Số e được gọi là số mũ công khai (hay còn gọi là số mũ mã hóa), còn số N được gọi là số modulo.
- Tìm một số nguyên d thỏa mãn các điều kiện $0 < d < n$ và $e \times d \bmod n = 1$, nghĩa là d là nghịch đảo của e theo modulo n .
Alice lấy cặp số $\{d, N\}$ làm khóa bí mật của mình, $K_{RA} = \{d, N\}$, hủy p, q và n . Số d được gọi là số mũ bí mật (hay còn gọi là số mũ giải mã).
Tương tự như trên, Bob cũng có thể tự tạo cho mình một cặp khóa K_{UB} và K_{RB} .

b) Sử dụng RSA để mã hóa bảo mật

- Giả sử Alice muốn gửi cho Bob thông điệp bí mật. Thông điệp này nếu biểu diễn dưới dạng số nguyên có giá trị là M với $M < N$. Để mã hoá, Alice làm như sau:
 - + Lấy khóa công khai của Bob, $K_{UB} = \{e, N\}$;
 - + Tính bản mã của M : $C = M^e \bmod N$ và gửi cho Bob.
- Để giải mã số C , Bob làm như sau:
 - + Lấy khóa bí mật của mình, $K_{RB} = \{d, N\}$;

+ Tính bản rõ $M' = C^d \bmod N$

c) Sử dụng RSA để mã hóa chứng thực

- Giả sử Alice muốn gửi cho Bob một thông điệp quan trọng mà cô muốn khi nhận được anh tin thông điệp này chính là do cô gửi. Tức là cô muốn chứng thực thông tin là do cô gửi. Thông điệp này có giá trị nguyên là M với $0 < M < N$. Để thực hiện việc này, Alice làm như sau:

+ Alice lấy khóa bí mật của mình, $K_{RA} = \{d, N\}$;

+ Tính bản mã của M : $C = M^d \bmod N$ và gửi cho Bob.

- Để giải mã số C , Bob làm như sau:

+ Lấy khóa công khai của Alice, $K_{UA} = \{e, N\}$;

+ Tính bản rõ $M' = C^e \bmod N$.

4.2.2 Chứng minh tính đúng của RSA

Để đảm bảo rằng RSA thực hiện đúng theo nguyên tắc của mã hóa khóa công khai, ta phải chứng minh hai điều sau:

a) Bản giải mã chính là bản rõ ban đầu: $M' = M$

- Xét trường hợp mã hóa bảo mật

Do $ed \bmod N = 1$ nên $\exists k$ nguyên dương, sao cho $ed = kn + 1$

$$\begin{aligned}\text{Vậy} \quad M' &= C^d \bmod N \\ &= M^{ed} \bmod N \\ &= M^{kn+1} \bmod N \\ &= M^{k(p-1)(q-1)+1} \bmod N\end{aligned}$$

Trước tiên ta chứng minh: $M^{k(p-1)(q-1)+1} \equiv M \bmod p$

Xét hai trường hợp của M :

- + M chia hết cho p : $M \bmod p = 0 \Rightarrow M^{k(p-1)(q-1)+1} \equiv M \equiv 0 \bmod p$
- + M không chia hết cho p : vì p là số nguyên tố nên suy ra M nguyên tố cùng nhau với p . Do đó:

$$\begin{aligned}M^{k(p-1)(q-1)+1} &= M (M^{p-1})^{k(q-1)} \bmod p \\ &= M (1^{k(q-1)}) \bmod p \text{ (theo định lý Fermat)} \\ &= M \bmod p\end{aligned}$$

Do vậy, với mọi M ta có $M^{k(p-1)(q-1)+1} - M \equiv 0 \bmod p$. Hay nói cách khác



$M^{k(p-1)(q-1)+1} - M$ chia hết cho p .

Chứng minh tương tự ta có $M^{k(p-1)(q-1)+1} - M$ chia hết cho q . Vì p, q là hai số nguyên tố nên suy ra $M^{k(p-1)(q-1)+1} - M$ chia hết cho $N = pq$.

Tóm lại:

$$M^{k(p-1)(q-1)+1} \equiv M \pmod{N}$$

$$\Rightarrow M' = M^{k(p-1)(q-1)+1} \pmod{N} = M \text{ (điều phải chứng minh)}$$

– Xét trường hợp mã hóa chứng thực

Vì e và d đối xứng nhau nên có thể suy ra $M' = M$.

b) Không thể suy ra K_R từ K_U , nghĩa là không thể tìm cặp (d, N) từ cặp (e, N) :

Có e và N , muốn tìm d , ta phải dựa vào công thức $ed \pmod{n} = 1$. Do đó phải tính được n . Vì $n = (p-1)(q-1)$ nên suy ra phải tính được p và q .

Vì $N = pq$ nên ta chỉ có thể tính được p và q từ N . Tuy nhiên điều này là bất khả thi vì $N = pq$ là hàm một chiều. Vậy không thể tính được K_R từ K_U .

4.2.3 Ví dụ về mã hóa bằng RSA

Để minh họa ta sẽ thực hiện một ví dụ về mã hóa RSA với kích thước khóa là 6 bits.

Ví dụ 4.1

1) Chọn $p = 11$ và $q = 3$. Ta có $N = pq = 11 \cdot 3 = 33$ ($25 = 32 < 33 < 64 = 2^6$)

2) $n = (p-1)(q-1) = (11-1) \cdot (3-1) = 10 \cdot 2 = 20$

3) Chọn $e = 3$ nguyên tố cùng nhau với $n = 20$.

4) Tính nghịch đảo của e trong phép modulo 20 được $d = 7$ vì $(3 \cdot 7 = 21)$

5) Khóa công khai $K_U = (e, N) = (3, 33)$. Khóa bí mật $K_R = (d, N) = (7, 33)$.

Mã hóa bảo mật:

6) Mã hóa bản rõ $M = 15$:

$$C = M^e \pmod{N} = 15^3 \pmod{33} = 9$$

7) Giải mã bản mã $C = 9$:

$$M' = C^d \pmod{N} = 9^7 \pmod{33} = 15 = M$$

Mã hóa chứng thực:



6) Mã hóa bản rõ $M = 15$:

$$C = M^d \bmod N = 15^7 \bmod 33 = 27$$

7) Giải mã bản mã $C = 27$:

$$M' = C^e \bmod N = 27^3 \bmod 33 = 15 = M$$

4.3 Độ phức tạp tính toán RSA

Có hai vấn đề về độ phức tạp tính toán trong phương pháp RSA. Đó là các phép tính mã hóa/giải mã và các phép tính sinh khóa.

4.3.1 Phép tính mã hóa/giải mã

Phép tính mã hóa và giải mã dùng phép lũy thừa modulo. Để an toàn, thường phải chọn p , q , e và d lớn. Nếu thực hiện bằng cách tính phép lũy thừa trước, sau đó rút gọn modulo, thì giá trị của phép lũy thừa là quá lớn để có thể lưu trữ và tính toán. Tuy nhiên số học modulo có một tính chất là modulo của một tích bằng tích của các modulo.

$$ab \equiv ((a \bmod n)(b \bmod n)) \bmod n$$

Chúng ta có thể sử dụng tính chất này để đơn giản phép tính lũy thừa modulo thông qua một phương pháp gọi là “bình phương liên tiếp”. Ví dụ cần tính $x^{16} \bmod n$, đầu tiên sẽ tính $a = x \bmod n$, tiếp theo là $b = x^2 \bmod n = a^2 \bmod n$, tiếp theo là $c = x^4 \bmod n = b^2 \bmod n$, tiếp theo là $d = x^8 \bmod n = c^2 \bmod n$, và cuối cùng

$$x^{16} \bmod n = d^2 \bmod n.$$

Các số a , b , c , d luôn nhỏ hơn n do đó tránh được việc tính số lũy thừa lớn đồng thời nâng cao tốc độ tính toán.

Tóm lại, để tính $x^b \bmod n$, ta viết b dưới dạng số nhị phân:

$b = b_k b_{k-1} \dots b_2 b_1 b_0$, trong đó b_i là các bit bằng 0 hoặc bằng 1.

$$\text{Như vậy, } b = \sum_{b_i \neq 0} 2^i \quad \text{suy ra} \quad x^b = \prod_{b_i \neq 0} x^{2^i} \bmod n$$

Tức là ứng với các $b_i = 1$, ta dùng phương pháp bình phương liên tiếp để tính các $x^{2^i} \bmod n$. Sau đó nhân các kết quả với nhau và rút gọn modulo để có kết quả cuối cùng.

Ví dụ 4.2 Tính $y = 5^{20} \bmod 11$. Viết số 20 dưới dạng nhị phân: $20_{10} = 10100_2$. Số này chỉ có bit 2 và bit 4 bằng 1 (đánh số từ trái qua phải bắt đầu từ 0). Tính $5^i \bmod 11$, với $i = 2^0, 2^1, \dots, 2^4$



$$5^1 \equiv 5 \pmod{11},$$

$$5^2 = (5^1)^2 = 25 \equiv 3 \pmod{11},$$

$$5^4 = (5^2)^2 = 3^2 \equiv 9 \pmod{11}$$

$$5^8 = (5^4)^2 = 9^2 = 81 \equiv 4 \pmod{11}$$

$$5^{16} = (5^8)^2 = 4^2 = 16 \equiv 5 \pmod{11}$$

$$\text{Kết quả cuối cùng } y = 5^{20} \pmod{11} = (5^4 \pmod{11})(5^{16} \pmod{11})$$

$$= 9 * 5 \pmod{11} = 1$$

4.3.2 Phép tính sinh khóa

Phép tính sinh khóa là chọn p và q nguyên tố để tính N . Để phân tích số N thành tích hai thừa số nguyên tố p, q , chỉ có một cách duy nhất là thử từng số p và q . Do đó phải chọn p, q đủ lớn để việc thử là không khả thi. Hiện nay chưa có phương pháp nào để sinh ra số nguyên tố lớn tùy ý. Chỉ có cách là chọn một số lẻ ngẫu nhiên nào đó và kiểm tra số đó có phải là số nguyên tố không. Việc kiểm tra tính nguyên tố cũng gặp nhiều khó khăn. Thuật toán kiểm tra số nguyên tố hiệu quả hiện nay là thuật toán Miller-Rabin, dù rằng không hoàn toàn chính xác 100%, tuy nhiên có thể đạt sai số nhỏ không đáng kể.

Dựa vào lý thuyết số nguyên tố, người ta ước tính rằng cần thử trung bình khoảng 70 số lẻ để tìm ra một số nguyên tố lớn chừng 2^{200} .

Vì chúng ta đã chọn e trước là 65537 (hay 3 hoặc 17 ...), do đó cần kiểm tra xem e có nguyên tố cùng nhau với $n = (p - 1)(q - 1)$ hay không. Nếu không ta phải thử lại với p và q khác. Sau khi đã tìm p và q thích hợp, cần tìm d sao cho $ed \equiv 1 \pmod{n}$. Bằng cách dùng thuật toán Euclid mở rộng, chúng ta có thể kết hợp việc kiểm tra tính nguyên tố cùng nhau của e và n , đồng thời nếu e nguyên tố cùng nhau với n thì thuật toán cũng cho biết d . Vì vậy không cần tiến hành bước tìm d riêng.

4.4 Độ an toàn của RSA

Sau đây ta sẽ xem xét một số cách tấn công đối với phương pháp RSA:

1) Vết cạn khóa: cách tấn công này thử tất cả các khóa d có thể có để tìm ra bản giải mã có ý nghĩa, tương tự như cách thử khóa K của mã hóa đối xứng. Với N lớn, việc tấn công là bất khả thi.

2) Phân tích N thành thừa số nguyên tố $N = pq$. Chúng ta đã nói rằng việc phân tích phải là bất khả thi thì mới là hàm một chiều, là nguyên tắc hoạt động của RSA.



Tuy nhiên, nhiều thuật toán phân tích mới đã được đề xuất, cùng với tốc độ xử lý của máy tính ngày càng nhanh, đã làm cho việc phân tích N không còn quá khó khăn như trước đây. Năm 1977, các tác giả của RSA đã treo giải thưởng cho ai phá được RSA có kích thước của N vào khoảng 428 bit, tức 129 chữ số. Các tác giả này ước đoán phải mất 40 nghìn triệu triệu năm mới có thể giải được. Tuy nhiên vào năm 1994, câu đố này đã được giải chỉ trong vòng 8 tháng.

Dĩ nhiên là việc phá mã trên chỉ được thực hiện trong phòng thí nghiệm. Tuy nhiên người ta cho rằng kích thước của N phải khoảng 1024 bit (309 chữ số) thì mới bảo đảm an toàn thật sự.

3) Đo thời gian: Đây là một phương pháp phá mã không dựa vào mặt toán học của thuật toán RSA, mà dựa vào một “hiệu ứng lẻ” sinh ra bởi quá trình giải mã RSA. Hiệu ứng lẻ đó là thời gian thực hiện giải mã.

Giả sử người phá mã có thể đo được thời giải mã dùng thuật toán bình phương liên tiếp. Trong thuật toán bình phương liên tiếp, nếu một bit của d là 1 thì xảy ra hai phép modulo, nếu bit đó là 0 thì chỉ có một phép modulo, do đó thời gian thực hiện giải mã là khác nhau. Bằng một số phép thử chosen-plaintext, người phá mã có thể biết được các bit của d là 0 hay 1 và từ đó biết được d .

Phương pháp phá mã này là một ví dụ cho thấy việc thiết kế một hệ mã an toàn rất phức tạp. Người thiết kế phải lường trước được hết các tình huống có thể xảy ra.

4.5 Bảo mật, chứng thực và không chối bỏ với mã hóa khóa công khai

Giả sử Alice muốn gửi dữ liệu cho Bob dùng mã hóa khóa công khai, trước tiên Alice và Bob sẽ chọn cặp khóa riêng-khóa công khai. Ký hiệu khóa riêng-khóa công khai của Alice là K_{RA} và K_{UA} , của Bob là K_{RB} và K_{UB} ,

Như vậy để gửi dữ liệu bảo mật cho Bob, Alice sẽ dùng phương án 1: mã hóa dữ liệu bằng khóa công khai K_{UB} của Bob, và Bob dùng khóa riêng K_{RB} để giải mã.

$$C = E(M, K_{UB})$$

$$M = D(C, K_{RB})$$

Để đảm bảo tính chứng thực và Alice không từ chối trách nhiệm gửi dữ liệu, Alice sẽ dùng phương án 2: Alice mã hóa dữ liệu bằng khóa riêng K_{RA} , và Bob dùng khóa công khai K_{RA} của Alice để giải mã.

$$C = E(M, K_{RA})$$

$$M = D(C, K_{UA})$$



Cũng với giả định rằng thông điệp có ý nghĩa là một dãy bit có cấu trúc, nếu bản giải mã của Bob là hợp lệ thì rõ ràng là Alice là người gửi vì chỉ có Alice mới có khóa riêng K_{RA} . Giống như mã hóa đối xứng, nếu Trudy can thiệp, chỉnh sửa trên bản mã C thì Bob sẽ giải mã ra bản rõ là một dãy bit vô nghĩa. Còn nếu Trudy có được khóa K_{RA} thì Alice không thể thoái thác trách nhiệm làm lộ khóa.

Tuy nhiên, mô hình như trên lại không đảm bảo tính bảo mật vì không chỉ riêng Bob, Trudy biết được khóa công khai K_{UA} của Alice mà cả Trudy cũng biết và có thể giải mã bản mã C và biết được nội dung bản rõ M .

Để giải quyết vấn đề trên, người ta kết hợp tính bảo mật, chứng thực và không từ chối qua mô hình sau:

$$C = E(E(M, K_{RA}), K_{UB})$$

$$M = D(D(C, K_{RB}), K_{UA})$$

4.6 Trao đổi khóa

4.6.1 Trao đổi khóa công khai

Khi hai người sử dụng muốn truyền dữ liệu với nhau bằng phương pháp mã hóa khóa công khai, trước tiên họ phải trao đổi khóa công khai cho nhau. Vì đây là khóa công khai nên không cần giữ bí mật việc trao đổi này, khóa có thể truyền công khai trên kênh thường. Alice và Bob, hay bất cứ người nào khác có thể công bố rộng rãi khóa công khai của mình.

Tuy nhiên ở đây chúng ta lại gặp phải vấn đề về chứng thực. Làm như thế nào mà Alice có thể đảm bảo rằng K_{UB} chính là khóa công khai của Bob. Trudy có thể mạo danh Bob bằng cách lấy khóa K_{UT} của Trudy và nói rằng đó là khóa công khai của Bob. Vì vậy, việc trao đổi khóa công khai theo mô hình trên đặt gánh nặng lên vai của từng cá nhân. Alice muốn gửi thông điệp cho Bob hay bất cứ người nào khác thì phải tin tưởng vào khóa công khai của Bob hay của người đó. Tương tự như vậy đối với Bob.

Để giảm gánh nặng cho từng cá nhân, một mô hình gọi là “chứng chỉ khóa công khai” (public-key certificate) được sử dụng. Trong mô hình này có một tổ chức làm nhiệm vụ cấp chứng chỉ được gọi là Trung tâm Chứng thực (Certificate Authority – CA). Các bước thực hiện cấp chứng chỉ cho Alice như sau:

Bước 1: Alice gửi định danh ID_A và khóa công khai K_{UA} của mình đến trung tâm chứng thực.



Bước 2: Trung tâm chứng nhận kiểm tra tính hợp lệ của Alice, ví dụ nếu ID_A là “Microsoft”, thì Alice phải có bằng chứng chứng tỏ mình thực sự là công ty Microsoft.

Bước 3: Dựa trên cơ sở đó, trung tâm chứng thực cấp một chứng chỉ C_A để xác nhận rằng khóa công khai K_{UA} đó là tương ứng với ID_A . Chứng chỉ được ký chứng thực bằng khóa riêng của trung tâm để đảm bảo rằng nội dung của chứng chỉ là do trung tâm ban hành.

$$C_A = E(ID_A || K_{UA}, K_{RAuth}), (|| \text{ là phép nối dây bit})$$

Bước 4: Alice công khai chứng chỉ C_A .

Bước 5: Bob muốn trao đổi thông tin với Alice thì sẽ giải mã C_A bằng khóa công khai của trung tâm chứng thực để có được khóa công khai K_{UA} của Alice. Do đó nếu Bob tin tưởng vào trung tâm chứng thực thì Bob sẽ tin tưởng là K_{UA} là tương ứng với ID_A , tức tương ứng với Alice.

Như vậy có thể thấy rằng nếu Bob muốn gửi thông điệp cho Alice, Cindy, hay Darth..., thì Bob không cần phải tin tưởng vào khóa công khai của Alice, Cindy, hay Darth nữa. Bob chỉ cần tin tưởng vào Trung tâm Chứng thực và khóa công khai của Trung tâm Chứng thực là đủ.

Hiện nay mô hình chứng chỉ khóa công khai đang được áp dụng rộng rãi với chuẩn của chứng chỉ là chuẩn X.509. Trên thế giới có khoảng 80 tổ chức chứng thực chứng chỉ khóa công khai.

4.6.2 Dùng mã hóa khóa công khai để trao đổi khóa bí mật

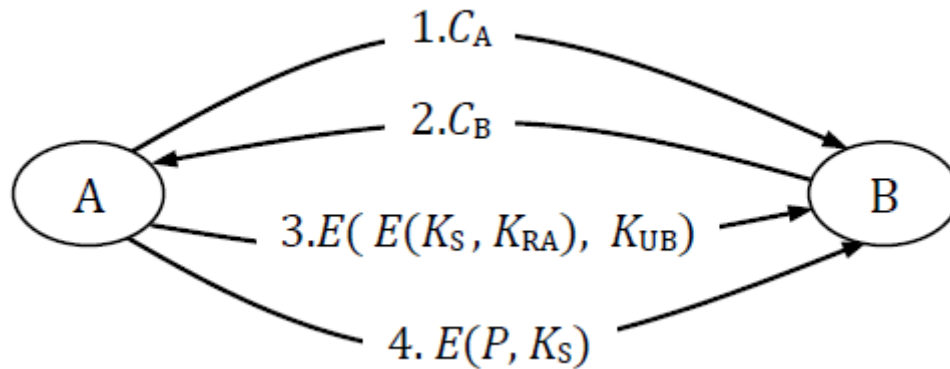
Do đặc điểm toán học của phương pháp mã hóa khóa công khai, thời gian mã hóa và giải mã của phương pháp này chậm hơn so với phương án mã hóa đối xứng. Trong thực tế, đối với vấn đề bảo đảm tính bảo mật, người ta vẫn sử dụng phương pháp mã hóa đối xứng.

Mã hóa khóa công khai được dùng để thiết lập khóa bí mật cho mỗi phiên trao đổi dữ liệu. Lúc này khóa bí mật được gọi là khóa phiên (session key), các phiên trao đổi dữ liệu khác nhau sẽ dùng các khóa bí mật khác nhau.

Hình dưới mô tả một mô hình đơn giản để thiết lập khóa phiên K_S giữa Alice và Bob.

$$C_A = E(ID_A || K_{UA}, K_{RAuth}), (|| \text{ là phép ghép các dây bit})$$





Hình 4-2: Thiết lập khóa phiên bí mật bằng mã hóa khóa công khai

Alice tạo một khóa phiên K_S , mã hóa bằng khóa riêng của Alice, sau đó mã hóa bằng khóa công khai của Bob. Bob giải mã K_S dùng khóa riêng của Bob và khóa công khai của Alice. Nhờ tính bảo mật, Alice biết chắc rằng ngoài Alice chỉ có Bob mới biết được K_S .

Nhờ tính không từ chối, Bob biết rằng ngoài Bob chỉ có Alice mới biết được K_S vì Alice dùng khóa riêng để mã hóa K_S . Do đó K_S có thể dùng làm khóa bí mật cho mã hóa đối xứng để trao đổi dữ liệu giữa Alice và Bob. Sau phiên trao đổi dữ liệu, K_S được hủy bỏ nên khóa bí mật này sẽ ít có khả năng bị lộ. Lúc này vai trò của mã hóa khóa công khai không phải là bảo mật dữ liệu nữa (việc này do mã hóa đối xứng đảm trách) mà là bảo đảm tính bí mật của khóa đối xứng, chỉ có A và B biết khóa K_S .

4.7 Phương pháp trao đổi khóa Diffie – Hellman

Phương pháp trao đổi khóa Diffie-Hellman dùng để thiết lập một khóa bí mật giữa người gửi và người nhận mà không cần dùng đến mã hóa công khai như ở phần 4.6.2. Phương pháp này dùng hàm một chiều làm hàm logarithm rời rạc. Diffie-Hellman không có ý nghĩa về mặt mã hóa giống như RSA.

Trước tiên Alice và Bob sẽ thống nhất sử dụng chung một số nguyên tố p và một số g nhỏ hơn p và là căn nguyên thủy (Primitive Root) của p (nghĩa là phép toán $g^x \bmod p$ khả nghịch). Hai số p và g không cần giữ bí mật. Sau đó Alice chọn một số a và giữ bí mật số a này. Bob cũng chọn một số b và giữ bí mật số b . Tiếp theo Alice tính và gửi $g^a \bmod p$ cho Bob, Bob tính và gửi $g^b \bmod p$ cho Bob. Trên cơ sở đó Alice tính:

$$(g^b)^a \bmod p = g^{ab} \bmod p$$

Bob tính:

$$(g^a)^b \bmod p = g^{ab} \bmod p$$



Do đó Alice và Bob có chung giá trị $g^{ab} \bmod p$. Giá trị này có thể dùng làm khóa cho phép mã hóa đối xứng.

Như vậy, Trudy có thể có được g , p , g^a và g^b . Muốn tính được $g^{ab} \bmod p$, Trudy không thể dùng cách:

$$g^a g^b \bmod p = g^{a+b} \bmod p \neq g^{ab} \bmod p$$

Muốn tính được $g^{ab} \bmod p$, Trudy phải tính được a hoặc được b . Tuy nhiên việc tính a hay b theo công thức:

$$a = \text{dlog}_{g, p} g^a \quad \text{hay} \quad b = \text{dlog}_{g, p} g^b$$

là không khả thi do tính phức tạp của phép logarith rời rạc. Vậy Trudy không thể nào tính được $g^{ab} \bmod p$. Hay nói cách khác, khóa dùng chung được trao đổi bí mật giữa Alice và Bob.

Tuy nhiên, thuật toán Diffie-Hellman lại thất bại đối với cách tấn công kẻ-đứng-giữa. Trong phương pháp tấn công này, Trudy đứng giữa Alice và Bob. Trudy chặn các thông điệp của Alice và Bob, giả mạo các thông điệp mà Alice và Bob không hay biết. Alice vẫn nghĩ là nhận dữ liệu từ Bob và ngược lại.

Do đó Trudy có thể thiết lập khóa Diffie-Hellman $g^{at} \bmod p$ với Alice và khóa $g^{bt} \bmod p$ với Bob. Khi Alice gửi dữ liệu, Trudy giải mã bằng khóa $g^{at} \bmod p$, sau đó mã hóa lại bằng $g^{bt} \bmod p$ và gửi cho Bob. Như vậy Alice và Bob không hay biết còn Trudy thì xem trộm được dữ liệu.

Để an toàn, quá trình thiết lập khóa Diffie-Hellman vẫn phải được mã hóa bằng một khóa công khai. Lúc này một câu hỏi được đặt ra là nếu đã được bảo vệ bằng khóa công khai rồi, thì có thể chọn khóa đối xứng bất kỳ, cần gì chọn khóa Diffie-Hellman? Tuy nhiên có một số trường hợp, khi mà cách thức tấn công kẻ-đứng-giữa không thể thực hiện được, thì phương thức Diffie-Hellman tỏ ra rất hữu dụng.

4.8 Câu hỏi và bài tập

4.8.1 Câu hỏi

- 4.1) Hãy nêu rõ vai trò của khóa công khai và khóa bí mật.
- 4.2) Ba lớp ứng dụng lớn của hệ mật mã khóa công khai là gì?
- 4.3) Một hệ mật mã khóa công khai phải thỏa mãn những yêu cầu nào để trở thành một hệ mật mã an toàn?



4.4) Hãy chỉ rõ những ưu điểm và nhược điểm của hệ mật mã khóa đối xứng và hệ mật mã khóa không đối xứng.

4.8.2 Bài tập

4.1) Mã hóa và giải mã bằng thuật toán mật mã khóa công khai RSA với các tham số được cho dưới đây:

- a) $p = 3; q = 11; e = 7; M = 5$ Khánh
- b) $p = 5; q = 11; e = 3; M = 9$ Trang
- c) $p = 7; q = 11, e = 3; M = 7$ Thuận
- d) $p = 11; q = 13, e = 11; M = 7$ Thế
- e) $p = 7; q = 13; e = 17; M = 8$ Nhâm
- f) $p = 17; q = 31, e = 7; M = 9$ Đạt

4.2) Trong hệ mật mã khóa công khai RSA, Melory bắt được một bản mã $C = 10$ được gửi cho một người có khóa công khai $e = 5$ và $N = 35$. Hãy tìm bản rõ M ?

CHƯƠNG 5. HÀM BẮM VÀ XÁC THỰC THÔNG TIN

5.1 Xác thực thông tin

5.1.1 Các khái niệm

Xác thực thông tin là quy trình thẩm định, chứng thực thông tin xem có đáng tin cậy không, có chính xác không, có bị sửa đổi không. Xác thực thông tin liên quan đến các vấn đề sau khi thông tin được truyền đi trên mạng. Các thông tin truyền đi ở đây thường là các văn bản có ý nghĩa quan trọng đối với các bên tham gia truyền tin. Việc xác thực văn bản nhằm đảm bảo những vấn đề sau đây:

- Bảo vệ tính toàn vẹn của thông tin: bảo vệ văn bản không bị thay đổi hoặc có các biện pháp phát hiện nếu văn bản bị thay đổi trên đường truyền dù đó là nhỏ nhất.
- Kiểm chứng danh tính và nguồn gốc: xem xét văn bản nhận được có đúng do người xưng tên gửi không, hay là do một kẻ mạo danh nào khác gửi.
- Không thể chối bỏ bản gốc: trong trường hợp cần thiết, bản thân văn bản chứa các thông tin chứng tỏ chỉ có người xưng danh gửi, không một ai khác có thể làm điều đó. Như vậy người gửi không thể chối bỏ hành động gửi, thời gian gửi và nội dung của văn bản đã gửi.

Ngoài ra có thể xem xét bổ sung thêm các yêu cầu bảo mật như mã hoá. Để đáp ứng được các yêu cầu trên, có thể lựa chọn một hoặc kết hợp hai trong ba phương án sau đây:

- Mã hóa văn bản bằng phương pháp mã hóa đối xứng hoặc mã hóa khóa công khai.
- Mã xác thực văn bản (MAC – Message Authentication Code): dùng một hàm nén có khoá để nén văn bản cần gửi, tạo ra một mã MAC mang đặc trưng của văn bản.
- Mã băm (hash): dùng một hàm băm để băm văn bản tạo thành “dấu vân tay” cho văn bản.

5.1.2 Các yêu cầu bảo mật khi truyền văn bản trên mạng

Khi truyền văn bản trên mạng cần phải tìm các biện pháp hữu hiệu để bảo vệ thông tin, chống lại các hành động phá hoại hoặc đánh cắp thông tin. Cụ thể là



- *Để lộ bí mật*: giữ bí mật nội dung thông tin, chỉ cho người có thẩm quyền biết và sử dụng.
- *Thăm mã đường truyền*: không cho tin tặc theo dõi hoặc làm trì hoãn việc truyền tin.
- *Giả mạo*: lấy danh nghĩa người khác để gửi tin.
- *Sửa đổi nội dung*: thay đổi, cắt xén, thêm bớt thông tin. Thay đổi trình tự các gói tin nhỏ của văn bản truyền.
- *Sửa đổi thời gian*: làm trì hoãn truyền tin.
- *Từ chối gốc*: không cho phép người gửi từ chối trách nhiệm tác giả.
- *Từ chối đích*: không cho phép người nhận phủ định sự tồn tại và đến đích của văn bản đã gửi.

5.1.3 Xác thực văn bản bằng mã hóa

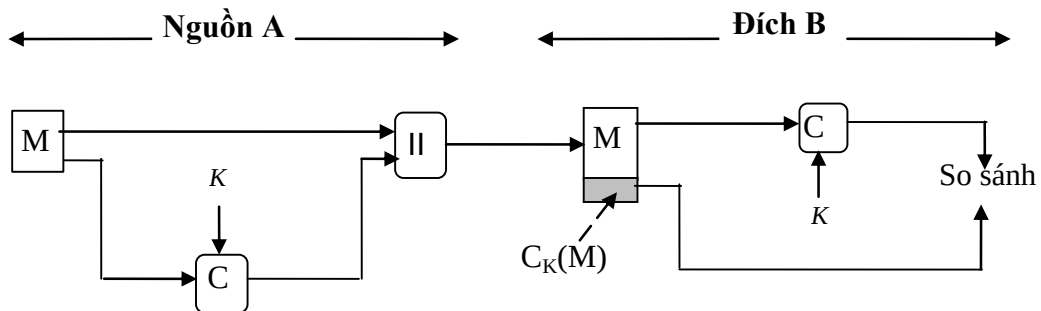
Nếu sử dụng hệ mật mã khóa bí mật thì bản mật mã của văn bản tự thân đã cung cấp một phần tính xác thực của văn bản vì khoá bí mật chỉ được chia sẻ giữa người gửi và người nhận. Hơn nữa, việc thay đổi nội dung cũng không dễ dàng thực hiện nếu không có khoá giải mã. Cụ thể, nếu mật mã được sử dụng là đối xứng thì người nhận sẽ biết ai là người chủ của văn bản, vì chỉ có người gửi và người nhận mới biết khoá bí mật được dùng để mã hóa cũng như giải mã. Mặt khác, người nhận có thể biết nội dung không bị sửa đổi, nếu mẫu tin có cấu trúc phù hợp, tính dư thừa và tổng kiểm tra để phát hiện bất cứ thay đổi nào.

Nhưng nếu sử dụng khoá công khai thì bản mã của văn bản không đủ độ tin cậy về người gửi vì mọi người đều có thể biết khoá công khai của người gửi. Tuy nhiên, nếu người gửi sử dụng khoá riêng của mình để mã hóa văn bản, sau đó lại mã bằng khoá công khai của người nhận thì khi đó đảm bảo cả tính bảo mật và xác thực của văn bản. Sau đó chỉ cần bổ sung các biện pháp để xác minh xem văn bản có còn toàn vẹn không. Việc sử dụng khoá riêng của người gửi kết hợp với khoá công khai của người nhận có nhiều ưu việt, nhưng với giá phải trả là chậm do phải mã hóa văn bản 2 lần bằng hệ mã hóa khóa công khai.

5.1.4 Xác thực văn bản bằng Mã xác thực

Mã xác thực văn bản MAC được tạo thành bởi một thuật toán nén với một khoá bí mật. Thuật toán này nén văn bản có độ dài tùy ý thành một mẫu tin có độ dài cố định. Mẫu tin này phụ thuộc cả vào văn bản được nén và vào khoá bí mật nhưng không cần phải giải mã.

Mã xác thực văn bản được bổ sung vào đuôi văn bản và được gọi là MAC để gửi kèm theo làm bằng chứng xác thực. Khi nhận được văn bản và MAC đính kèm, người nhận tính lại MAC của văn bản và so sánh xem nó có trùng với MAC đính kèm không. Nếu chúng giống nhau thì nguyên bản tương ứng giống nhau, ngược lại nguyên bản khác nhau. Hình 5.1 mô tả quy trình xác thực văn bản dựa vào MAC. Trong quy trình này cả hai bên cùng dùng một thuật toán nén MAC với một khóa bí mật.



Hình 5-1: Quy trình xác thực văn bản dựa vào MAC

Các mã xác thực văn bản MAC cung cấp sự tin cậy cho người nhận, đảm bảo văn bản không bị thay đổi và đảm bảo đích danh người gửi truyền đến. Cũng có thể sử dụng mã xác thực MAC kèm theo với việc mã hoá để bảo mật. Nói chung, người ta thường sử dụng từng khoá riêng biệt cho mỗi hàm MAC và nên tính MAC trước sau đó mới mã hoá.

Sử dụng MAC có nhược điểm là MAC phụ thuộc vào văn bản và cả người gửi. Nhưng đôi khi chỉ cần xác thực thông điệp và thông tin xác thực đó chỉ phụ thuộc vào thông điệp để lưu trữ làm bằng chứng cho tính toàn vẹn của nó. Để khắc phục nhược điểm này, người ta sử dụng hàm băm (hash) thay cho hàm MAC. Cần lưu ý rằng MAC không phải là chữ ký điện tử, vì cả người gửi và người nhận đều biết thông tin về khoá.

a) Các tính chất của MAC

MAC là thông tin nén của văn bản kết hợp với khoá, vì vậy có thể biểu diễn hàm MAC bằng công thức:

$MAC = C_K(M)$, trong đó **M** là văn bản có độ dài tùy ý, C_K là một thuật toán nén có sử dụng khoá bí mật **k** tạo ra mã xác thực có độ dài cố định.

MAC có thể là hàm nhiều - một, nghĩa là có nhiều bản tin khác nhau có thể có cùng giá trị MAC. Tuy nhiên, chúng ta cần phải lựa chọn hàm MAC sao cho xác suất để các văn bản có ý nghĩa có MAC trùng nhau là rất nhỏ. Tức là việc tìm được hai văn bản khác nhau có cùng giá trị MAC là rất khó khăn.



b) Các yêu cầu đối với MAC

Tùy thuộc vào kiểu tấn công mà MAC phải có các tính chất khác nhau để chống đối lại. Nhưng nói chung, MAC phải thỏa mãn các yêu cầu sau:

- Biết văn bản và MAC, không thể tìm được mẫu tin khác có cùng MAC.
- Các giá trị MAC cần phải phân bố đều.
- MAC phải phụ thuộc như nhau vào tất cả các bit trong văn bản. Tức là khi thay đổi một bit thông tin nào đó trong nguyên bản, MAC sẽ có những thay đổi kéo theo.

5.1.5 Các hàm băm

Hàm băm là một thuật toán dùng để nén một văn bản có độ dài bất kỳ thành một mẫu tin có độ dài cố định. Hàm băm là một hàm tạo ra mã xác thực văn bản giống như MAC nhưng không sử dụng khóa bí mật.

a) Các tính chất của hàm băm

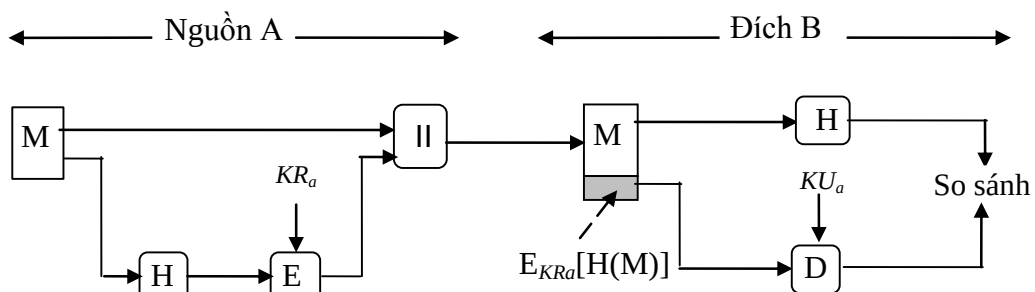
Hàm băm tạo ra dấu vân tay (tức là thông tin đặc trưng) của một thông điệp và được định nghĩa bằng công thức:

$$h = H(M)$$

trong đó, M là thông điệp cần băm, H là hàm băm, h là giá trị băm.

Văn bản có kích thước tùy ý còn giá trị băm có kích thước cố định. Hàm băm được giả thiết là công khai, mọi người đều biết cách sử dụng chúng.

Hàm băm được sử dụng để phát hiện sự thay đổi của thông điệp và thường được kết hợp với mã hóa khóa công khai để tạo ra chữ ký số (digital signature) cho thông điệp. Hình 5.2 minh họa một qui trình xác thực sử dụng hàm băm và mã hóa khóa công khai. Trong đó, M là thông điệp của nguồn A cần gửi cho đích B; H là hàm băm; E và D là cặp thuật toán mã hóa và giải mã khóa công khai tương ứng; KR_a và KU_a là cặp khóa bí mật và công khai của nguồn A. Ký hiệu || là phép ghép hai tệp.



Hình 5-2: Qui trình xác thực văn bản dựa vào hàm băm



b) Các yêu cầu đối với hàm băm

- Có thể áp dụng được cho mọi văn bản có kích thước tùy ý. Tuy nhiên, phải tạo đầu ra h có kích thước cố định, thường là 128 bits đến 1024 bits.
- Dễ tính được $h=H(M)$ cho mọi văn bản nguồn M và kết quả phụ thuộc chặt chẽ vào văn bản nguồn M mà không tính ngược lại được, hay chính xác hơn là rất khó để có thể tìm được M khi biết h .
- Cho trước h không thể tìm được (rất khó) x sao cho $H(x) = h$. Tính chất này gọi là tính chất một chiều, chiều tìm nghịch ảnh rất khó khăn, tuy chiều tìm ảnh dễ dàng.
- Cho x không thể tìm được y sao cho $H(y)=H(x)$. Đây là tính chất chống đỡ va chạm yếu, không tìm được một văn bản khác có cùng giá trị băm với văn bản đã cho.
- Không thể tìm được x, y sao cho $H(y)=H(x)$. Đây gọi là tính chất chống đỡ va chạm mạnh. Yêu cầu này cao hơn yêu cầu về chống đỡ va chạm yếu.

❖ **Nhận xét**

Hai đặc tính đầu tiên bảo đảm khả năng thực tiễn ứng dụng hàm băm để xác thực văn bản, thông tin.

Đặc tính thứ ba bảo đảm tính một chiều, dễ dàng nhận được mã hàm băm h trên cơ sở của văn bản đã cho, nhưng thực tiễn không có khả năng khôi phục lại tin tức, khi chỉ có h phù hợp.

Đặc tính thứ tư bảo đảm rằng không có người tham gia nào có thể tìm được một bản tin khác, có cùng giá trị băm như bản tin đã cho. Điều này ngăn ngừa khả năng làm giả thông tin, văn bản nguồn, trong trường hợp khi thực hiện mã hoá hàm băm.

Đặc tính thứ năm xác định độ bền của hàm băm tới một lớp tấn công cụ thể, được biết dưới tên cuộc tấn công dựa trên bài toán nghịch lí về ngày sinh nhật (Birthday Attack).

5.1.6 Các hàm băm đơn giản

Có một số đề xuất cho các hàm băm đơn giản. Chẳng hạn biểu diễn văn bản dưới dạng bit sau đó chia chúng thành các khối bit có kích thước bằng kích thước mong muốn của hàm băm, sau đó XOR các bit thông tin ở cùng vị trí tương ứng của các khối với nhau. Kết quả nhận được là chuỗi băm của cả văn bản. Hàm băm được tạo ra như trên là không an toàn vì đối với một văn bản bất kỳ có thể dễ dàng tìm được văn bản



khác có cùng giá trị băm. Cần phải có các hàm băm mạnh hơn thỏa mãn được các yêu cầu đối với hàm băm.

5.2 Các hàm băm SHA và MD5

5.2.1 Các hàm băm SHA

Hàm băm SHA1 (Secure Hash Standard) do Viện Tiêu chuẩn Công nghệ Quốc gia Hoa kỳ xây dựng và được công bố vào năm 1992 và sau đó đã chính thức trở thành phương pháp băm chuẩn từ năm 1993. Hàm này xử lý văn bản theo từng khối 512 bits và cho ra một chuỗi băm có độ dài cố định là 160 bits.

Ba phiên bản mới gồm SHA256, SHA384, SHA512 được phát hành năm 2002. Độ dài của các giá trị băm lần lượt là 256, 384 và 512 bits. Thuật toán của các hàm này tương tự như SHA1.

Bảng dưới đây liệt kê các thông số của các phiên bản hàm băm thuộc họ SHA.

Bảng 5-1: Các hàm băm họ SHA

	SHA1	SHA256	SHA384	SHA512
Kích thước giá trị băm	160	256	384	512
Kích thước thông điệp	$< 2^{64}$	$< 2^{64}$	$< 2^{128}$	$< 2^{128}$
Kích thước khối	512	512	1024	1024
Kích thước từ (word)	32	32	64	64
Số bước mã hóa	80	64	80	80

Sau đây là mô tả chi tiết về hoạt động của hàm băm có giá trị băm nhỏ nhất (160 bits) SHA1 và hàm băm có giá trị băm lớn nhất (512 bits) SHA512.

a) Hàm băm SHA1

Hàm băm SHA1 khá phức tạp, trong đó có sử dụng các phép toán logic trên các bits, các hàm logic dùng để băm các bits dữ liệu và một số hằng số. Phần này sẽ trình bày một số khái niệm và một số phép toán được sử dụng trong giải thuật.

❖ Một số khái niệm cần dùng trong giải thuật của SHA1

– Chuỗi bit và các số nguyên:

+ Các số hệ 16 (hexa) nằm trong tập $[0, 1, \dots, 9, A, B, \dots, F]$, được biểu diễn bởi 4 bits. Ví dụ $6_H = 0110$; $A_H = 1010$, trong đó chỉ số H có nghĩa là các số có chỉ số này được viết dưới dạng hexa.

- + Mỗi từ 32 bits được thể hiện bởi 4 chuỗi 8 bits, mỗi chuỗi 8 bits sẽ gồm hai số hexa. Ví dụ 1110 1010 0110 1100 1101 0010 1111 1011 = EA6CD2FB_H.
- + Mọi số nguyên có giá trị trong khoảng từ 0 đến $2^{32} - 1$ đều có thể biểu diễn thành 4 từ 8 bits, mỗi từ 8 bits gồm hai số hexa. Ví dụ $291 = 2^8 + 2^5 + 2^1 + 2^0 = 256 + 32 + 2 + 1 = 0000\ 0001\ 0010\ 0011$ được biểu diễn thành (00000123)_H trong đó mỗi số là một số hexa.
- + Một khối có 512 bits được chia thành 16 từ 32 bits.
- Các phép toán được dùng trong các giải thuật SHA
- + Các phép toán logic với X, Y là các từ 32 hoặc 64 bits
 - $X \wedge Y$ phép "và logic" từng bit tương ứng của X và Y
 - $X \vee Y$ phép "hoặc logic không loại trừ" từng bit tương ứng của X và Y
 - $X \oplus Y$ phép "hoặc logic có loại trừ" từng bit tương ứng của X và Y
 - $\sim X$ phép "phủ định logic" từng bit của X

Các phép toán logic nói trên được thực hiện theo bảng chân lý sau:

X	Y	$X \wedge Y$	$X \vee Y$	$X \oplus Y$	$\sim Y$
0	0	0	0	0	1
0	1	0	1	1	0
1	0	0	1	1	1
1	1	1	1	0	0

- Các phép dịch chuyển và dịch vòng

Tên	Ký hiệu	Ý nghĩa
Phép dịch sang trái (Left Shift) n bits	$LS <_n$	n bit 0 được chèn vào từ bên phải, đẩy n bits trái nhất ra ngoài
Phép dịch sang phải (Right Shift) n bits	$RS >_n$	n bit 0 được chèn vào từ bên trái, đẩy n bits phải nhất ra ngoài
Phép dịch vòng sang trái (Left Rotation) n bits	$LR <_n$	n bits trái nhất được dịch vòng từ trái qua phải
Phép dịch vòng sang phải (Right Rotation) n bits	$RR >_n$	n bits phải nhất được dịch vòng từ phải qua trái



Ví dụ 5.1: Cho $X = 1000\ 0101 = 85$

$$LS_{<2}(X) = 0001\ 0100 \quad RS_{>2}(X) = 0010\ 0001$$

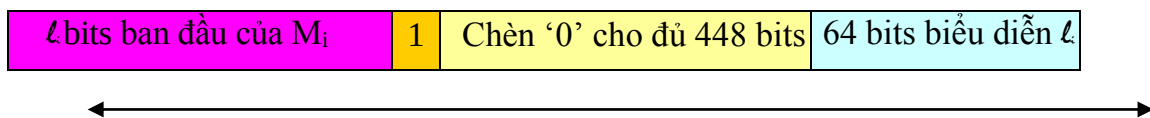
$$LR_{<2}(X) = 0001\ 0110 \quad RR_{>2}(X) = 0110\ 0001$$

- Phép cộng modulo 2^{32} : $X +^{32} Y = (X + Y) \bmod 2^{32}$
- Chèn bit: dùng để chèn thêm bits cho một khối bit cần băm M_i có độ dài ℓ nhỏ hơn 448 bits để tạo thành một khối 512 bits.

Kỹ thuật chèn “bit” được thực hiện như sau:

- + Biểu diễn ℓ bits của M_i ;
- + Chèn thêm một bit 1, sau đó chèn các bits 0 cho đủ 448 bits ;
- + Ghi độ dài ℓ của M_i vào 64 bit để cho đủ 512 bits.

Hình 5-3 mô tả hình ảnh của một khối sau khi đã được chèn thêm bits.



Hình 5-3: Khối M_i có độ dài 512 bits sau khi được chèn thêm

b) Giải thuật SHA1

- **Đầu vào:** Thông điệp M có độ dài tối đa 2^{64} bits
- **Đầu ra:** Giá trị băm có độ dài cố định 160 bits

Giải thuật gồm 5 bước như sau:

Bước 1: Nhồi thêm dữ liệu

Văn bản cần băm M có độ dài ℓ bits được chia thành các khối 512 bits. Khối cuối cùng sẽ được nhồi thêm một số bits sao cho :

$$\ell \equiv 448 \bmod 512 \text{ nghĩa là } \ell = n * 512 + 448 \text{ với } n \text{ là số nguyên.}$$

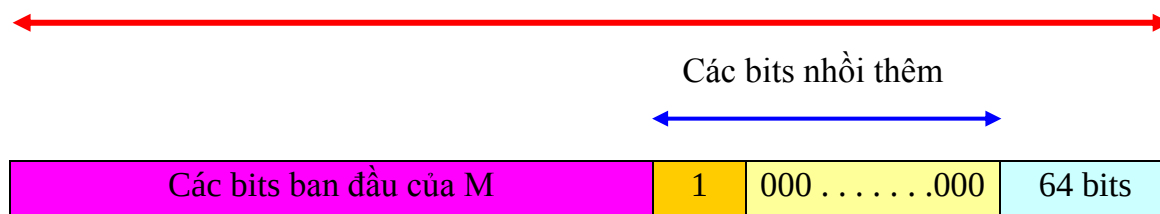
Cụ thể là khối cuối cùng sẽ có 448 bits bao gồm số bits còn dư lại của M sau khi chia cho 512 và các bits được nhồi thêm.

Phần dữ liệu nhồi thêm bao gồm một bit 1 và theo sau là các bit 0.

Hình 5-4 mô tả hình ảnh của văn bản M sau khi đã nhồi thêm dữ liệu.



$$l \equiv 448 \bmod 512$$



Hình 5-4: Nhồi thêm dữ liệu vào văn bản M

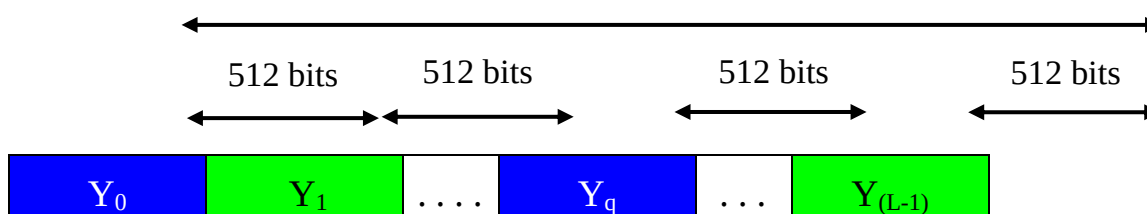
Bước 2: Thêm vào độ dài của văn bản

Độ dài của văn bản nguồn M được biểu diễn dưới dạng nhị phân 64 bits và được ghi vào 64 bits cuối của khối 512 bits cuối cùng.

Kết quả có được từ 2 bước đầu là một văn bản có độ dài là bội số của 512. Từ đây, văn bản cần băm có thể được biểu diễn dưới hai dạng như sau:

- Bằng một dãy L khối 512-bit được ký hiệu là $Y_0, Y_1, \dots, Y_{L-1}$ hoặc
- Bằng một dãy N từ (word) 32-bit, được ký hiệu là $M_0, M_1, \dots, M_{N-1}$.
Tức là $N = L \cdot 16$.

Hình 5-5 mô tả văn bản thu được sau bước 2.



Hình 5-5: Văn bản sau khi nhồi dữ liệu và ghi độ dài vào 64 bits cuối

Bước 3: Khởi tạo bộ đệm

Một bộ đệm 160 bits sẽ được dùng để lưu trữ các giá trị băm trung gian và kết quả cuối cùng của hàm băm. Bộ đệm này được biểu diễn bằng 5 thanh ghi 32 bits, ký hiệu là A, B, C, D, E với các giá trị khởi tạo dưới dạng các số hexa như sau:

$$\begin{aligned} A &= 01 \ 23 \ 45 \ 67 \\ B &= 89 \ AB \ CD \ EF \\ C &= FE \ DC \ BA \ 98 \\ D &= 76 \ 54 \ 32 \ 10 \\ E &= C3 \ D2 \ E1 \ F0 \end{aligned} \quad (1)$$



Trạng thái khởi tạo này của bộ đệm được ký hiệu là IV(Initial Value) và được gán vào CV_0 (Compress Value).

Tiếp theo, các khối dữ liệu Y_q ($q = 0, 1, \dots, L-1$) sẽ lần lượt được băm và được cộng dồn vào bộ đệm.

Bước 4 : Xử lý các khối dữ liệu 512 bits Y_q

Quá trình băm một khối dữ liệu bao gồm 4 vòng lặp, mỗi vòng có 20 bước, tổng cộng là 80 bước.

Đầu vào của các vòng lặp này bao gồm:

- Khối dữ liệu đầu vào 512 bits $Y_q = M_{q*16} \dots M_{(q+1)*16-1}$ sẽ được mở rộng thành 80 từ 32 bit để chia đều cho mỗi vòng lặp 20 từ. Cách mở rộng như sau:
 - + Với $t \in [0,15]$ đặt $W_0 = M_{q*16}$, $W_1 = M_{q*16+1}$, ..., $W_{15} = M_{(q+1)*16-1}$ (2)
 - + Với $t \in [16,79]$ đặt $W_t = LR_{<1}(W_{t-3} \oplus W_{t-8} \oplus W_{t-14} \oplus W_{t-16})$
- Kết quả băm q khối $Y_0, Y_1, \dots, Y_{q-1}$ đang được chứa trong bộ đệm $CV_q = ABCDE$.
- 80 hằng số K_t tương ứng với 4 nhóm dưới đây :

$$\begin{aligned} K_t &= 5A827999 \quad \text{với } t \in [0, 19] \\ K_t &= 6ED9EBA1 \quad \text{với } t \in [20,39] \\ K_t &= 8F1BBCDC \quad \text{với } t \in [40,59] \\ K_t &= CA62C1D6 \quad \text{với } t \in [60,79] \end{aligned} \quad (3)$$

Quá trình băm khối Y_q được thực hiện bằng hàm giả mã được gọi là BAMKHOI sau đây:

```
FUNCTION BAMKHOI ( $Y_q, CV_q$ )
{
    Mở rộng  $Y_q$  thành 80 từ 32 bits:  $W_t, t = 0, 1, \dots, 79$  ;
    Tách  $CV_q$  thành 5 từ 32 bits: A, B, C, D, E ;
    Nhập các hằng số  $K_t, t = 0, 1, \dots, 79$ 
    for  $t = 0$  to 79
    {
        TEMP =  $LR_{<5}(A) +^{32} f_t(B, C, D) +^{32} E +^{32} W_t +^{32} K_t$ ;
        E = D ;
        B = A ;
```



```

        D = C ;
        C = LR<30(B) ;
        A = TEMP ;
    }
    CVq+1 = CVq +32 ABCD;
    return CVq+1 ;
}

```

Trong đó, hàm f_t với t nguyên nằm trong đoạn $[0, 79]$ nén 3 từ 32 bits B, C, D thành một từ 32 bits. Hàm $f_t(B, C, D)$ được định nghĩa theo 4 nhóm giá trị của t như sau:

$$\begin{aligned}
 f_t(B, C, D) &= (B \wedge C) \vee ((\sim B) \wedge D) && \text{với } t \in [0, 19] \\
 f_t(B, C, D) &= B \oplus C \oplus D && \text{với } t \in [20, 39] \\
 f_t(B, C, D) &= (B \wedge C) \vee (B \wedge D) \vee (C \wedge D) && \text{với } t \in [40, 59] \\
 f_t(B, C, D) &= B \oplus C \oplus D && \text{với } t \in [60, 79]
 \end{aligned} \tag{4}$$

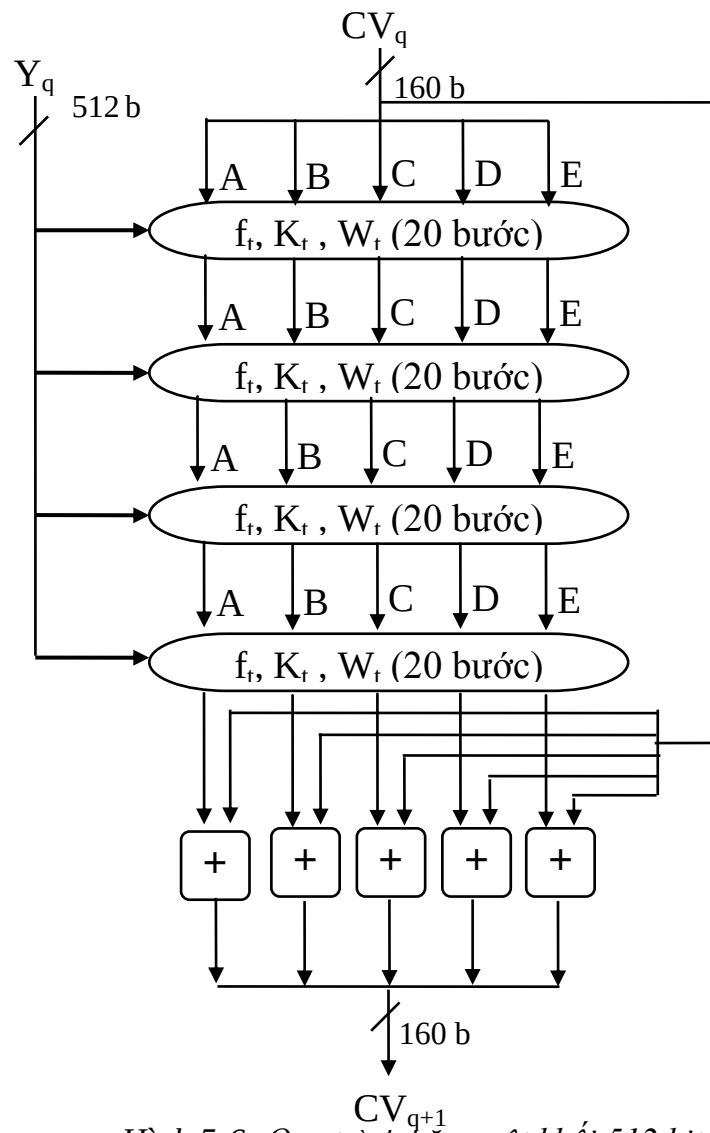
Ngoài ra, do đơn vị thao tác trong thuật toán là các từ 32 bits, nên các kết quả của phép cộng các từ 32 bit cần phải modulo cho 2^{32} trước khi gán cho các thanh ghi 32 bits.

Hình 5-6 là sơ đồ mô tả thuật toán băm khối Y_q . Trong đó, khối dữ liệu đầu vào gồm 16 từ 32 bits (Y_q) được mở rộng thành 80 từ 32 bit W_t ($t=0, 1, 2, \dots, 79$) và được chia thành 4 nhóm, mỗi nhóm 20 từ cho một vòng lặp. Kết quả băm của q khối dữ liệu trước đó (CV_q) được chứa trong các thanh ghi A, B, C, D, E . Mỗi khối trong hình là một vòng lặp gồm 20 bước tương ứng với một nhóm các giá trị của tham số t . Đầu ra của vòng lặp trước là đầu vào cho vòng lặp sau. Cuối cùng, đầu ra của vòng lặp thứ tư sẽ được cộng với CV_q (modulo 2^{32}) để thu được CV_{q+1} .

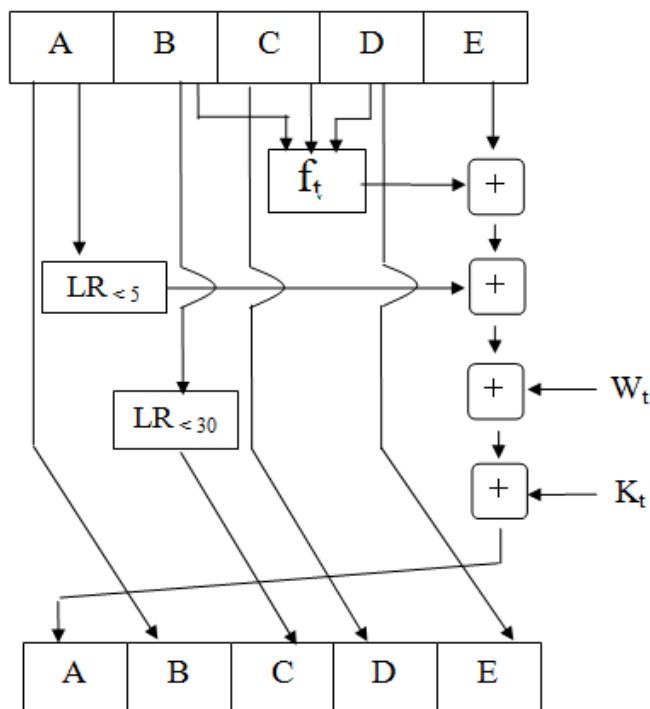
Mỗi bước lặp trong một vòng lặp mô tả ở Hình 5.6 được chi tiết hóa trong Hình 5.7. Trong đó:

- A, B, C, D, E là các từ 32 bits trong bộ đệm hiện hành;
- t là số thứ tự của bước lặp ($t = 0, 1, \dots, 79$);
- $f_t(B, C, D)$ là hàm logic tại bước t được định nghĩa trong (4);
- $LR_{<k}$ là phép dịch vòng trái k bits;
- W_t là từ 32 bits thứ t được mở rộng từ khối dữ liệu 512 bit được xác định trong công thức (2);
- K_t là hằng số được xác định trong công thức (3);
- $\boxed{+}$ là phép cộng modulo 2^{32}





Hình 5-6: Quy trình băm một khối 512 bits



Hình 5-7: Một trong 80 bước của qui trình băm một khối dữ liệu 512 bits

Bước 5: Xuất kết quả

Sau khi thao tác trên toàn bộ L khối, kết quả của khối thứ L (160 bits) là giá trị băm của văn bản ban đầu.

Qui trình băm có thể được tóm tắt như sau:

$$CV_0 = IV$$

$$CV_{q+1} = CV_q + {}^{+32}ABCDE_q$$

$$MD = CV_L$$

với :

- IV là giá trị khởi tạo của bộ đệm ABCDE .
- $ABCDE_q$ là giá trị băm của khối thứ q (CV_q).
- L là số khối 512 bits của văn bản cần băm.
- $+^{32}$ là phép cộng modulo 2^{32} trên từng từ (32 bits) của đầu vào.
- MD (Message Digest) là giá trị băm cuối cùng.



c) Giải thuật SHA512

SHA512 có cấu trúc tương tự như SHA1, nhưng mức độ an toàn cao hơn do độ dài của giá trị băm lớn hơn. Sau đây là qui trình băm của giải thuật SHA512

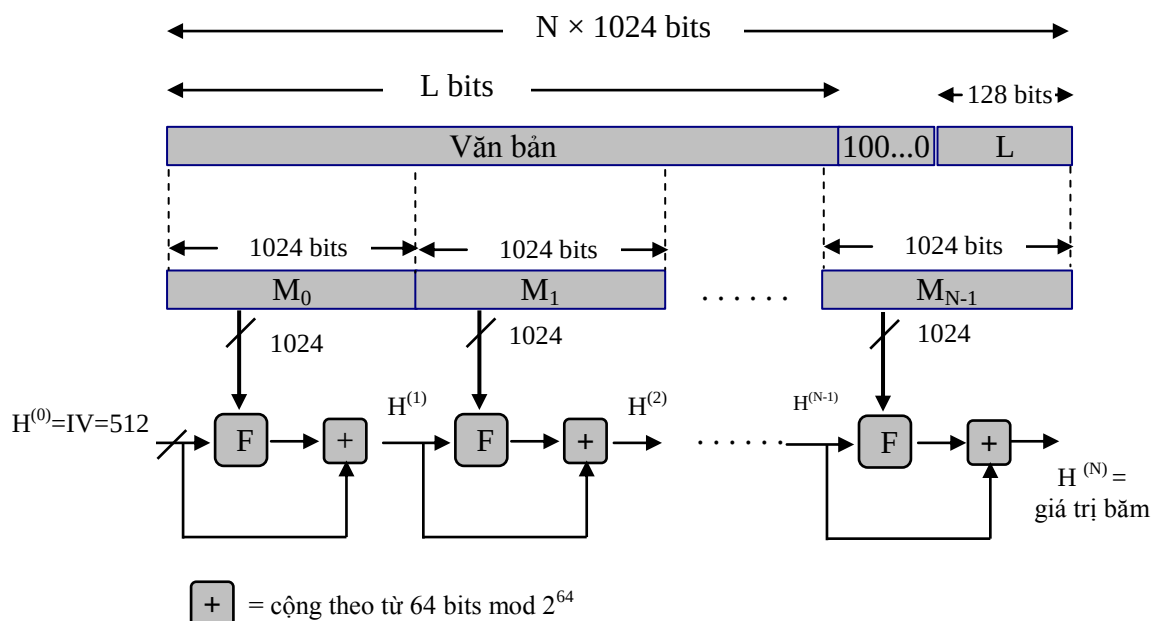
❖ Mô tả giải thuật

- **Đầu vào:** văn bản M có độ dài tối đa 2^{128} bits
- **Đầu ra:** giá trị băm có độ dài cố định 512 bits

Văn bản đầu vào M được chia thành các khối 1024 bits. Khối cuối cùng được nhồi thêm một bit 1 và một số bits 0 để còn lại đúng 128 bits cuối cùng dùng để ghi độ dài của dữ liệu đầu vào. Giả sử văn bản được chia thành N khối 1024 bits.

Hình 5-8 dưới đây mô tả hoạt động của giải thuật SHA-512. Trong đó, đơn vị nén của giải thuật này là các khối 1024 bits của M được ký hiệu lần lượt là $M_0, M_1, \dots, M_{N-1}$. $H^{(0)}$ là giá trị khởi tạo của 8 thanh ghi 64 bits được ký hiệu là a, b, c, d, e, f, g và h; F là hàm nén một khối 1024 bits thành 512 bits bằng cách thực hiện một vòng lặp gồm 80 bước theo sơ đồ được mô tả trong Hình 5-9.

Kết quả nén của F sau đó được cộng modulo 2^{64} với $H^{(0)}$ và gán vào $H^{(1)}$. Tiếp tục làm như vậy cho đến khối cuối cùng để thu được $H(N)$. Đây chính là giá trị băm của văn bản M.

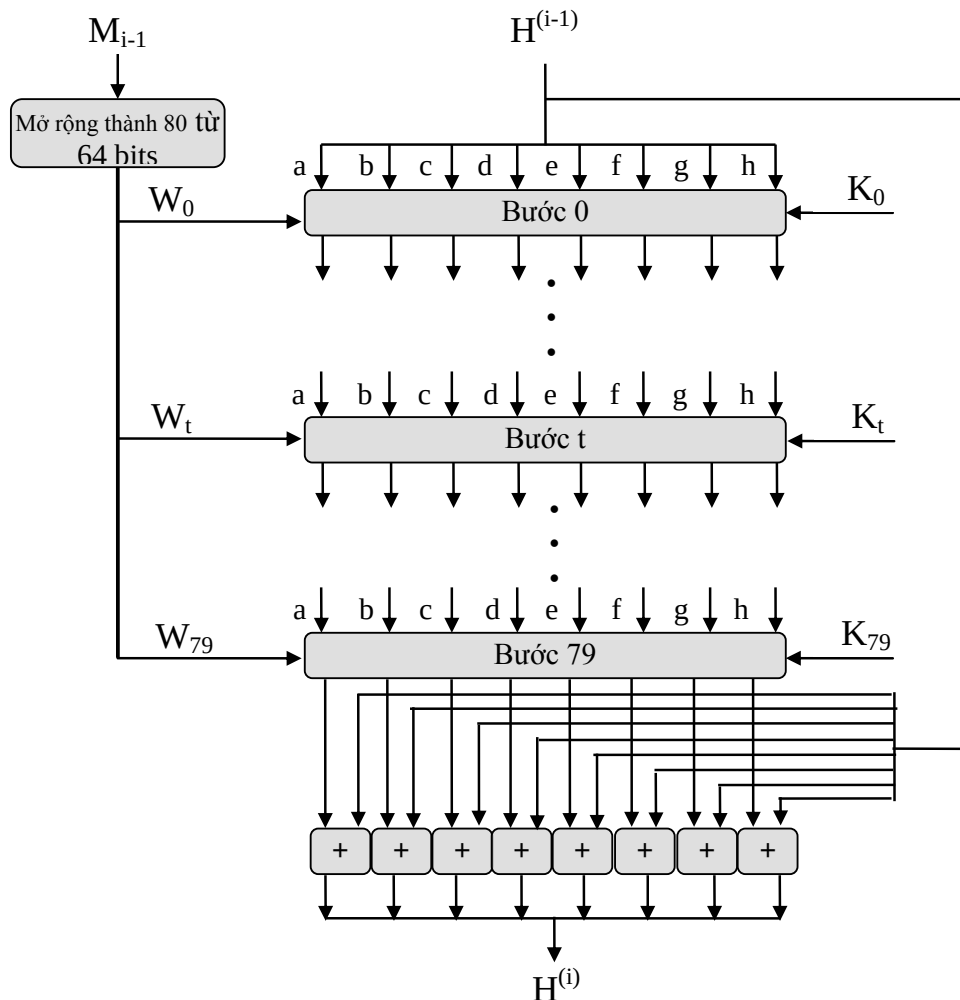


Hình 5-8: Sơ đồ hoạt động của hàm băm SHA512



Tâm điểm của giải thuật SHA512 là hàm F dùng để nén một khối dữ liệu 1024 bits thành 512 bits. Hàm này được mô tả chi tiết trong Hình 5.9. Ở đây, khối M_{i-1} gồm 1024 bits được chia thành 16 từ, mỗi từ 64 bits và được ký hiệu là $W_0, W_1, \dots, W_{15}$. Sau đó, chúng được mở rộng để tạo thêm 64 từ nữa để có tổng cộng là 80 từ theo sơ đồ trong Hình 5.10. $H^{(i-1)}$ là giá trị băm của $(i-1)$ khối dữ liệu từ M_0 đến M_{i-2} . $H^{(i-1)}$ được chứa trong 8 thanh ghi 64 bits a, b, c, d, e, f, g, h . Khi $i=1$, $H^{(i-1)} = H^{(0)}$ được đặt bằng giá trị khởi tạo của các thanh ghi.

Quy trình nén bao gồm 80 bước, từ 0 đến 79. Tại bước lặp thứ t , giá trị của các thanh ghi được trộn với một từ dữ liệu W_t và một hằng số K_t . Các hằng số này được cho trong Bảng 5.1. Sau 80 bước lặp, các thanh ghi a, b, c, d, e, f, g, h sẽ được cộng modulo 2^{64} với $H^{(i-1)}$ để tạo thành $H^{(i)}$.



Hình 5-9: Hàm F nén khối M_{i-1} với kết quả băm trung gian $H^{(i-1)}$

Mỗi bước lặp trong Hình 5-9 lại thực hiện một hàm quay vòng được mô tả trong Hình 5.11. Ở đây là bước lặp thứ t , trong đó 8 thanh ghi $a, b, \dots, h$ sẽ được trộn với từ dữ liệu W_t và hằng số K_t bằng 4 hàm logic:



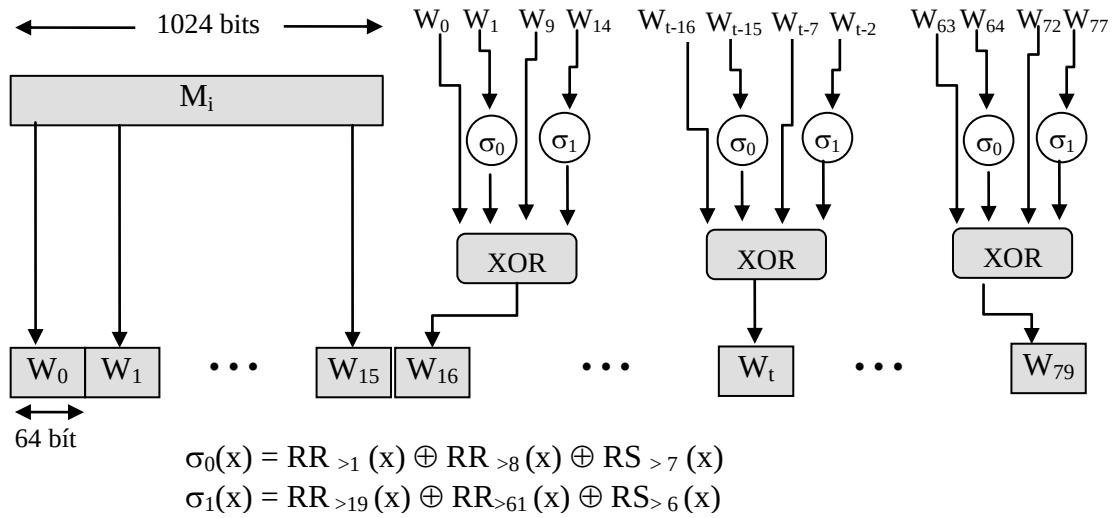
$$\text{Ch}(x, y, z) = (x \wedge y) \oplus (\sim x \wedge z)$$

$$\text{Maj}(x, y, z) = (x \wedge y) \oplus (x \wedge z) \oplus (y \wedge z) \quad (5)$$

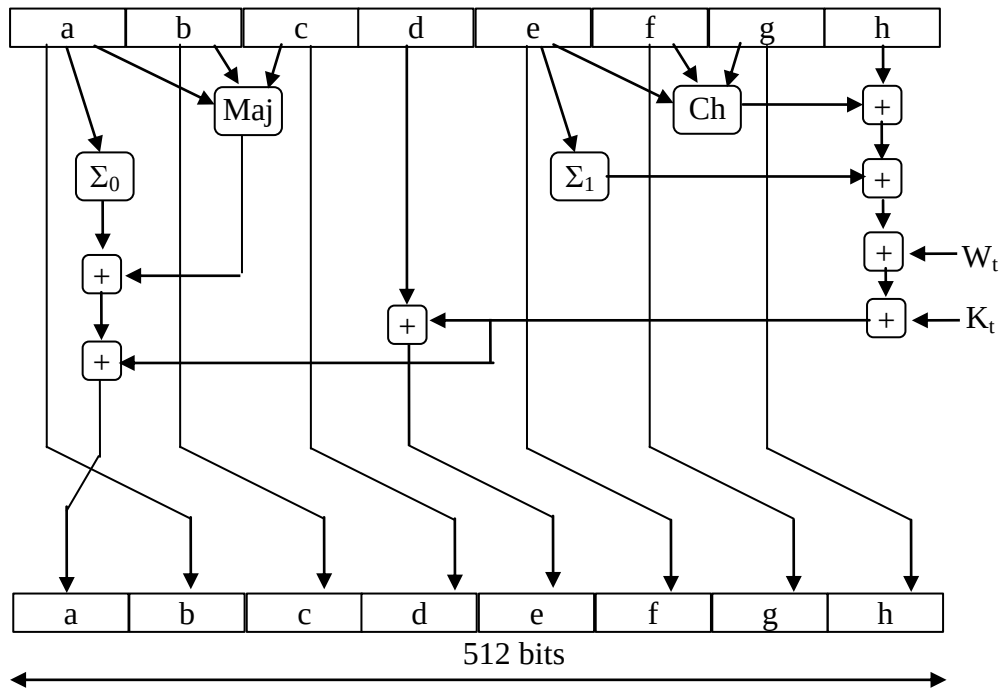
$$\Sigma_0(x) = \text{RR}_{>28}(x) \oplus \text{RR}_{>34}(x) \oplus \text{RR}_{>39}(x)$$

$$\Sigma_1(x) = \text{RR}_{>14}(x) \oplus \text{RR}_{>18}(x) \oplus \text{RR}_{>41}(x)$$

với $\text{RR}_{>k}$ là phép dịch vòng phải k bit, $\text{RS}_{>k}$ là phép dịch phải k bit.



Hình 5-10: Sơ đồ mở rộng khối M_i thành 80 từ 64 bits W_t ($t = 1, 2, \dots, 79$)



Hình 5-11: Quy trình hoạt động của một bước lặp trong vòng lặp 80 bước



❖ Giải mã của giải thuật SHA512

```
{  
    // Giải thuật băm SHA512  
    // Khởi tạo giá trị băm  $H^{(0)}$   
     $H^{(0)}(1) = 6a09e667f3bcc908$  ;  $H^{(0)}(2) = bb67ae8584caa73b$  ;  
     $H^{(0)}(3) = 3c6ef372fe94f82b$  ;  $H^{(0)}(4) = a54ff53a5f1d36f1$  ;  
     $H^{(0)}(5) = 510e527fade682d1$  ;  $H^{(0)}(6) = 9b05688c2b3e6c1f$  ;  
     $H^{(0)}(7) = 1f83d9abfb41bd6b$  ;  $H^{(0)}(8) = 5be0cd19137e2179$   
    // Vòng lặp chính: băm N khối dữ liệu 1024 bits của  $M = (M_0, M_1, \dots, M_{N-1})$   
    For i = 1 to N  
    {  
        // Gán cho các thanh ghi a, b, c, d, e, f, g, h giá trị băm  $H^{(i-1)}$   
         $a = H^{(i-1)}(1)$  ;  $b = H^{(i-1)}(2)$  ;  $c = H^{(i-1)}(3)$  ;  $d = H^{(i-1)}(4)$  ;  
         $e = H^{(i-1)}(5)$  ;  $f = H^{(i-1)}(6)$  ;  $g = H^{(i-1)}(7)$  ;  $h = H^{(i-1)}(8)$  ;  
        // Mở rộng khối dữ liệu  $M_{i-1}$   
         $W_j = M_{i-1}(j)$  với  $j = 0, 1, \dots, 15$   
    }  
    For j = 16 to 79  
    {  
         $W_j = \sigma_0(W_{j-2}) + W_{j-7} + \sigma_1(W_{j-15}) + W_{j-16}$  ;  
    }  
    // Nén khối dữ liệu  $M_{i-1}$  với  $H^{(i-1)}$  và gán vào các thanh ghi a, b, ..., h  
    For j = 0 to 79  
    {  
        Tính  $Ch(e, f, g)$ ,  $Maj(a, b, c)$ ,  $\Sigma_0(a)$ ,  $\Sigma_1(e)$  theo công thức (5):  
         $T_1 = h + \Sigma_1(e) + Ch(e, f, g) + K_j + W_j$  ;  
         $T_2 = \Sigma_0(a) + Maj(a, b, c)$  ;
```



```
h = g ; g = f ; f = e ; e = d + T1 ;  
d = c ; c = b ; b = a ; a = T1 + T2  
}  
// Tính giá trị băm trung gian thứ i : H(i)  
H(i)(1) = a + H(i-1)(1) ; H(i)(2) = b + H(i-1)(2) ;  
H(i)(3) = c + H(i-1)(3) ; H(i)(4) = d + H(i-1)(4) ;  
H(i)(5) = e + H(i-1)(5) ; H(i)(6) = f + H(i-1)(6) ;  
H(i)(7) = g + H(i-1)(7) ; H(i)(8) = h + H(i-1)(8) ;  
}  
// Tính giá trị băm của văn bản M  
H = (H(N)(1), H(N)(2), ..., H(N)(8))  
}
```

Để hiểu rõ quá trình băm một thông điệp bằng SHA512, có thể xem thêm một ví dụ trình bày qui trình băm một thông điệp đơn giản bằng hàm băm này trong Phụ lục 2.

5.2.2 Hàm băm MD5

MD5 (Message-Digest algorithm 5) là hàm băm có đầu ra là 128bits. MD5 đã được sử dụng rộng rãi trong các chương trình an ninh mạng, và cũng thường được dùng để kiểm tra tính nguyên vẹn của tập tin. MD5 biến đổi một thông điệp có chiều dài bất kì thành một khối có kích thước cố định 128 bits.

- **Đầu vào:** Thông điệp M với độ dài bất kỳ $\leq 2^{64}$ bits
- **Đầu ra:** Giá trị băm có độ dài cố định 128 bits

Giải thuật gồm 5 bước thao tác trên các khối 512bits như sau.

Bước 1: Nhồi thêm dữ liệu

Nhồi thêm các bits sao cho thông điệp M có độ dài $\ell \equiv 448 \pmod{512}$ hay $\ell = n * 512 + 448$ (n, ℓ nguyên).

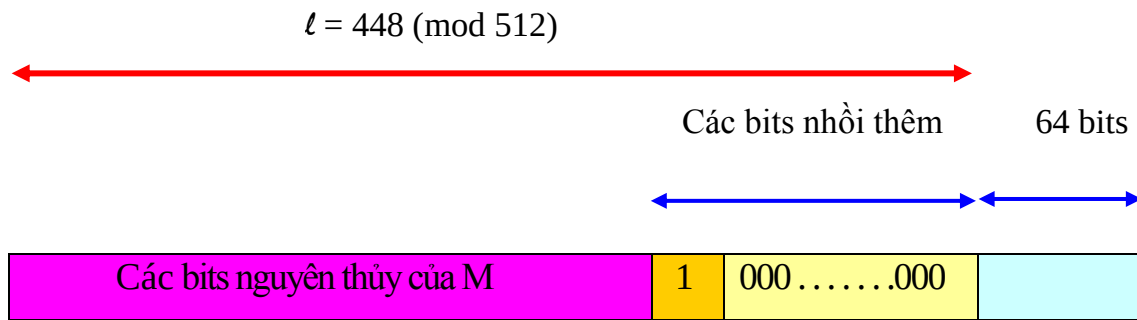
Luôn thực hiện nhồi dữ liệu ngay cả khi dữ liệu ban đầu có độ dài mong muốn. Ví dụ, nếu dữ liệu có độ dài 448 thì phải nhồi thêm 512 bits để được độ dài 960 bits.

Số lượng bit nhồi thêm nằm trong khoảng 1 đến 512.

Các bit được nhồi gồm 1 bit “1” và các bit 0 theo sau.



Hình 5-12 minh họa cấu trúc của thông điệp M sau khi nhồi thêm dữ liệu.



Hình 5-12: Cấu trúc của thông điệp M sau khi nhồi thêm dữ liệu

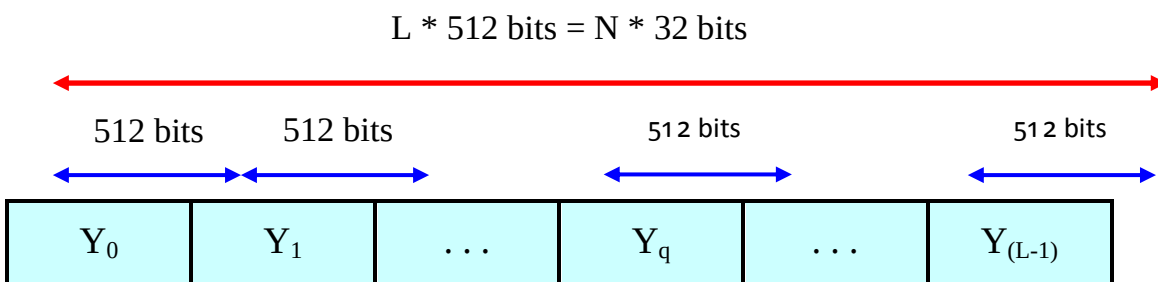
Bước 2: Chèn thêm độ dài của dữ liệu ban đầu

Độ dài của khối dữ liệu ban đầu được biểu diễn dưới dạng nhị phân 64-bit và được chèn vào cuối chuỗi nhị phân được thêm vào ở Bước 1.

Nếu độ dài của khối dữ liệu ban đầu > 264 thì chỉ 64 bits thấp được sử dụng, nghĩa là giá trị được thêm vào bằng $K \pmod{264}$.

Kết quả có được từ 2 bước đầu là một khối dữ liệu có độ dài là bội số của 512. Khối dữ liệu được biểu diễn:

- Bằng một dãy L khối 512-bit : $Y_0, Y_1, \dots, Y_{L-1}$.
- Bằng một dãy N từ (word) 32-bit M_0, M_1, M_{N-1} . Vậy $N = L * 16$



Hình 5-12: Cấu trúc của khối dữ liệu sau bước 2

Bước 3: Khởi tạo bộ đệm MD

Một bộ đệm 128-bit được dùng lưu trữ các giá trị băm trung gian và kết quả. Bộ đệm được biểu diễn bằng 4 thanh ghi 32-bit với các giá trị khởi tạo ở dạng little-endian (byte có trọng số nhỏ nhất trong từ nằm ở địa chỉ thấp nhất) như sau:

$$\begin{aligned} A &= 67 \ 45 \ 23 \ 01 & B &= EF \ CD \ AB \ 89 \\ C &= 98 \ BA \ DC \ FE & D &= 10 \ 32 \ 54 \ 76 \end{aligned}$$



Bước 4: Xử lý các khối dữ liệu 512-bit

Trọng tâm của giải thuật là hàm nén (compression function) dùng để nén từng khối dữ liệu 512 bits. Khối này được chia thành 16 từ 32 bits, $W[i]$ với $i=0,1, \dots, 15$. Hàm nén gồm 64 phép toán chia thành 4 vòng lặp. Hình 5.13 mô tả bốn vòng lặp này. Trong đó:

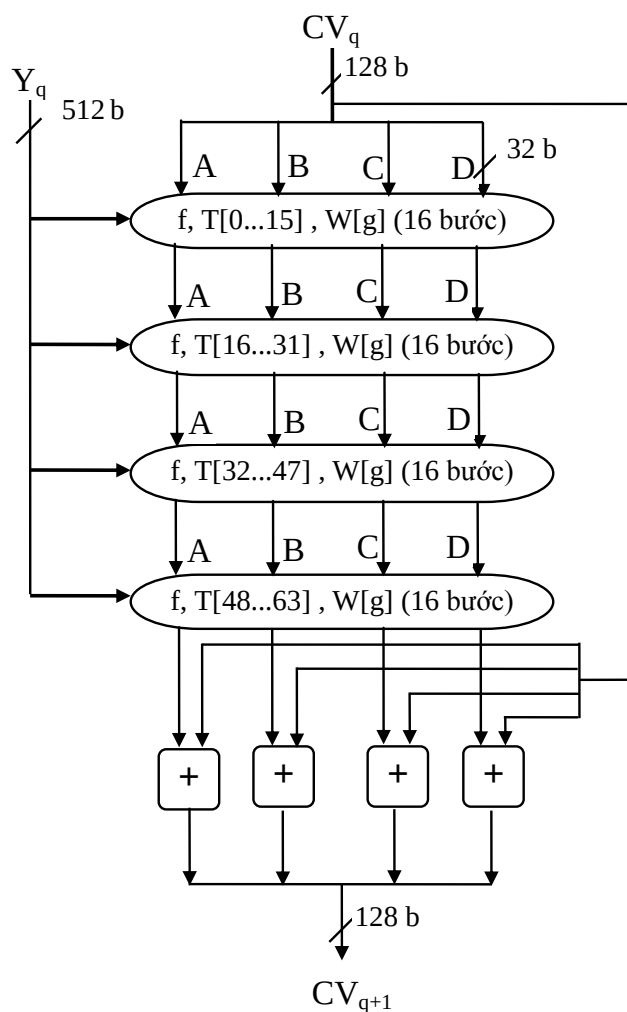
- Các vòng này có cấu trúc giống nhau nhưng sử dụng các hàm luận lý phi tuyến khác nhau là F , G , H và I và được ký hiệu chung là f . Các hàm này được định nghĩa như sau:

$$\begin{aligned} F(X, Y, Z) &= X \wedge Y \vee (\sim X \wedge Z) & G(X, Y, Z) &= (X \wedge Z) \vee (Y \wedge \sim Z) \\ H(X, Y, Z) &= X \text{ xor } Y \text{ xor } Z & I(X, Y, Z) &= Y \text{ xor } (X \vee \sim Z) \end{aligned}$$

- Mỗi vòng sử dụng 16 hằng số 32 bits $T[i] = 2^{32} \cdot \text{abs}(\sin(i))$, với $i = 0, 1, \dots, 63$ được tính theo radian. Các giá trị của $T[i]$ được cho trong Bảng 5.2.
- Các từ dữ liệu 32 bits $W[i]$ được sử dụng theo các thứ tự khác nhau trong các vòng lặp khác nhau.
 - + Ở vòng lặp thứ nhất, $W[g] = W[i]$ với $g = i = 0, 1, \dots, 15$;
 - + Ở vòng lặp thứ hai, $W[g] = W[(5 \cdot i + 1) \bmod 16]$, với $i = 16, 17, \dots, 31$;
 - + Ở vòng lặp thứ ba, $W[g] = W[(3 \cdot i + 5) \bmod 16]$, với $i = 32, 33, \dots, 47$;
 - + Ở vòng lặp thứ tư, $W[g] = W[(7 \cdot i) \bmod 16]$, với $i = 48, 49, \dots, 63$;
- Kết quả của 4 vòng lặp được cộng modulo 2^{32} với đầu vào CV_q để tạo ra CV_{q+1} .

Hình 5-14 minh họa một bước nén trong 64 bước nén của hàm nén đã mô tả trong hình 5-13. Trong đó mô tả quá trình thay đổi các thanh ghi A , B , C , D . Ở đây, f là ký hiệu chung cho các hàm F , G , H , I ; $\oplus$ là ký hiệu của phép cộng modulo 2^{32} ; $W[g]$ là một từ dữ liệu đầu vào 32 bits; $T[i]$ là hằng số 32 bits thứ i trong Bảng 5.5; $LR_{\leftarrow s}$ là ký hiệu dịch vòng trái s bits.





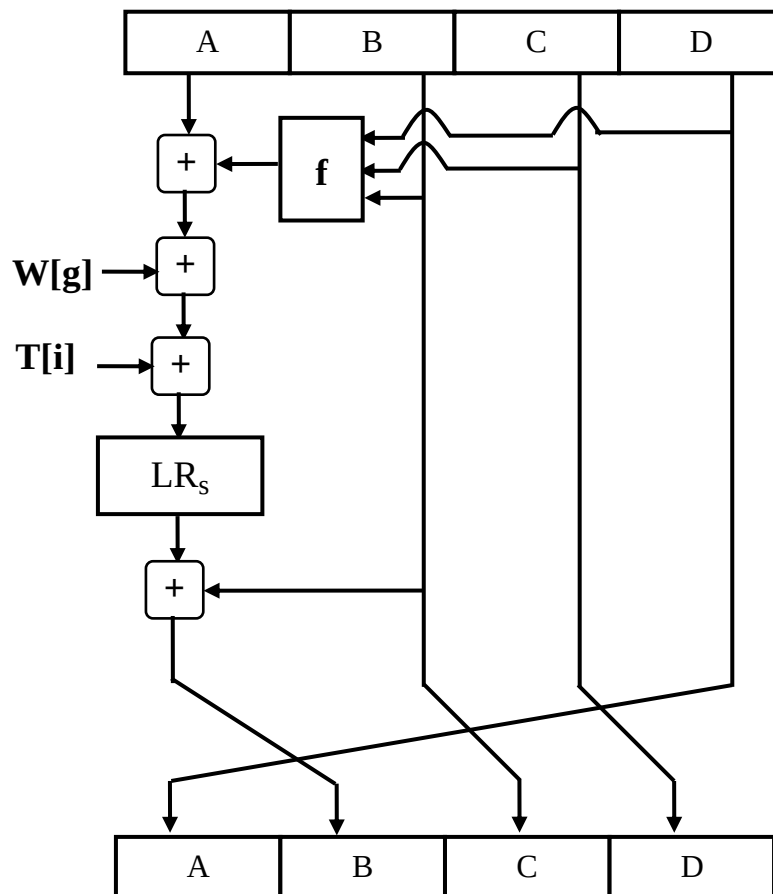
Hình 5-13: Hàm nén khối dữ liệu 512 bit Y_q

Bảng 5.2: Các giá trị của $T[i]$, $i = 0, . 1, \dots, 63$

$T[0] = \text{d76aa478}$	$T[16] = \text{f61e2562}$	$T[32] = \text{ffa3942}$	$T[48] = \text{f4292244}$
$T[1] = \text{e8c7b756}$	$T[17] = \text{c040b340}$	$T[33] = \text{8771f681}$	$T[49] = \text{432aff97}$
$T[2] = \text{242070db}$	$T[18] = \text{265e5a51}$	$T[34] = \text{6d9d6122}$	$T[50] = \text{ab9423a7}$
$T[3] = \text{c1bdceee}$	$T[19] = \text{e9b6c7aa}$	$T[35] = \text{fde5380c}$	$T[51] = \text{fc93a039}$
$T[4] = \text{f57c0faf}$	$T[20] = \text{d62f105d}$	$T[36] = \text{a4beea44}$	$T[52] = \text{655b59c3}$
$T[5] = \text{4787c62a}$	$T[21] = \text{2441453}$	$T[37] = \text{4bdecfa9}$	$T[53] = \text{8f0ccc92}$
$T[6] = \text{a8304613}$	$T[22] = \text{d8a1e681}$	$T[38] = \text{f6bb4b60}$	$T[54] = \text{ffeff47d}$
$T[7] = \text{fd469501}$	$T[23] = \text{e7d3fbc8}$	$T[39] = \text{bebfbc70}$	$T[55] = \text{85845dd1}$
$T[8] = \text{698098d8}$	$T[24] = \text{21e1cde6}$	$T[40] = \text{289b7ec6}$	$T[56] = \text{6fa87e4f}$



T[9] = 8b44f7af	T[25] = c33707d6	T[41] = eaa127fa	T[57] = fe2ce6e0
T[10] = ffff5bb1	T[26] = f4d50d87	T[42] = d4ef3085	T[58] = a3014314
T[11] = 895cd7be	T[27] = 455a14ed	T[43] = 4881d05	T[59] = 4e0811a1
T[12] = 6b901122	T[28] = a9e3e905	T[44] = d9d4d039	T[60] = f7537e82
T[13] = fd987193	T[29] = fcefa3f8	T[45] = e6db99e5	T[61] = bd3af235
T[14] = a679438e	T[30] = 676f02d9	T[46] = 1fa27cf8	T[62] = 2ad7d2bb
T[15] = 49b40821	T[31] = 8d2a4c8a	T[47] = c4ac5665	T[63] = eb86d391



Hình 5-14: Một bước trong 64 bước nén của MD5

Bước 5: Xuất kết quả

Sau khi xử lý hết L khối 512-bit, đầu ra của lần xử lý thứ L là giá trị băm 128 bits của hàm MD5.



Giải thuật MD5 được tóm tắt như sau:

$$CV_0 = IV \text{ (Initial Value)}$$

$$CV_{q+1} = CV_q + I(Y_q, H(Y_q, G(Y_q, F(Y_q, CV_q))))$$

$$MD = CV_{L-1}$$

– Với các tham số:

- + IV bộ đệm gồm 4 thanh ghi A, B, C, D
- + Y_q khối dữ liệu 512 bits thứ q
- + L số khối 512 bits sau khi nhồi thêm dữ liệu
- + CV_q đầu ra của khối thứ q sau khi nén

– Các hàm luận lý sử dụng trong các vòng nén: F, G, H, I

– MD giá trị băm

– $\boxed{+}$ cộng modulo 2^{32}

Mỗi vòng thực hiện 16 bước, mỗi bước thực hiện các phép toán để cập nhật giá trị các thanh ghi A, B, C, D. Bước thứ i được mô tả như sau:

$$TEMP = D ;$$

$$C = B ;$$

$$D = C ;$$

$$B = B + ((A + f(B,C,D) + W[g] + T[i]) \lll s) ;$$

$$A = TEMP ;$$

với :

- + A,B,C,D là các thanh ghi bits;
- + f là một trong các hàm F,G,H,I ;
- + LR_s là phép dịch vòng trái s bits ;
- + $W[g]$ là từ 32-bit thứ g của khối dữ liệu 512 bits ; g được xác định qua i theo định nghĩa trong Bước 4 ;
- + $T[i]$ là giá trị thứ i trong Bảng 5.5 ;
- + là phép toán cộng modulo 2^{32} .



5.3 Câu hỏi và bài tập

5.3.1 Câu hỏi

5.1) MAC là hàm gì? Nó cần phải thỏa mãn những tính chất gì và được ứng dụng trong lĩnh vực nào ?

5.2) Hàm băm là một hàm như thế nào? Nó cần phải thỏa mãn những tính chất gì và được ứng dụng trong lĩnh vực nào ?

5.3) Hàm MAC và hàm băm giống nhau và khác nhau ở những đặc điểm nào?

5.4) Những hàm số học và logic cơ bản nào được sử dụng trong hàm băm SHA?

5.5) Hàm nén trong một hàm băm có vai trò gì ?

5.6) Sự khác nhau giữa đặc tính chống va chạm yếu và chống va chạm mạnh là gì ?

5.3.2 Bài tập

5.1) Hãy xác định độ dài của trường đệm (được thêm vào cho chẵn khối) trong hàm băm SHA512 khi chiều dài của thông điệp cần băm là

- a) 1919 bits
- b) 1920 bits
- c) 1921 bits

5.2) Hãy xác định giá trị (dưới dạng hệ 16) của trường độ dài trong SHA512 khi chiều dài của thông điệp là

- a) 1919 bits
- b) 1920 bits
- c) 1921 bits

CHƯƠNG 6. AN TOÀN VÀ BẢO MẬT HỆ THỐNG THÔNG TIN TRÊN INTERNET

6.1 Hạ tầng mạng và những điểm yếu

6.1.1 Mô hình OSI và TCP/IP

Mô hình OSI và TCP/IP đều được thiết kế dựa trên kiến trúc phân tầng. Các mạng máy tính được thiết kế và cài đặt theo quan điểm có cấu trúc đa tầng. Mỗi một thành phần mạng được xem như một hệ thống gồm nhiều tầng và mỗi một tầng bao gồm một số chức năng truyền thông. Các tầng được chồng lên nhau, số lượng và chức năng của các tầng phụ thuộc vào các nhà sản xuất và thiết kế. Tuy nhiên quan điểm chung là trong mỗi tầng có nhiều thực thể (các tiến trình) thực hiện một số chức năng nhằm cung cấp một số dịch vụ, thủ tục cho các thực thể tầng trên hoạt động.

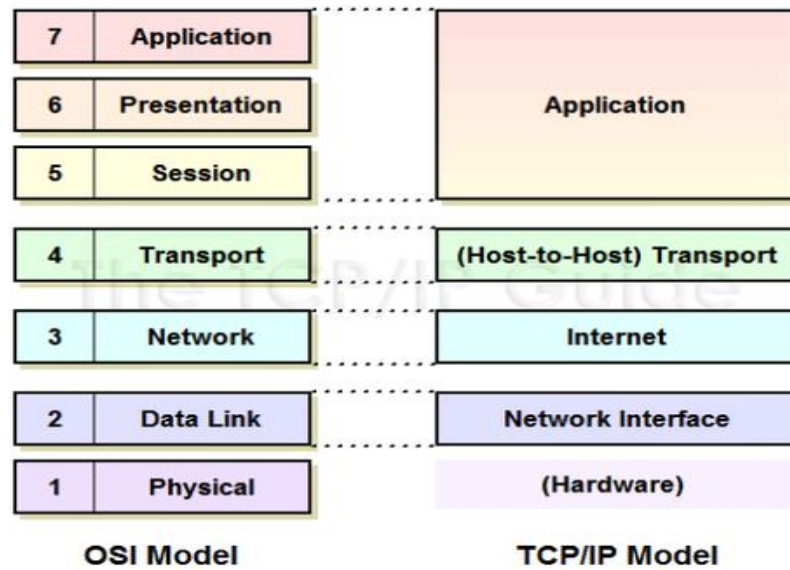
Tổ chức quốc tế về tiêu chuẩn hoá quy định cách phân tầng như sau:

Không định nghĩa quá nhiều tầng, số lượng tầng, vai trò và chức năng của các tầng trong mỗi hệ thống của mạng là như nhau, không quá phức tạp khi xác định và ghép nối các tầng. Chức năng các tầng độc lập với nhau và có tính mở.

Trong mỗi hệ thống, cần xác định rõ mối quan hệ giữa các tầng liên kế nhau, mối quan hệ này gọi là giao diện tầng (Interface). Mối quan hệ này quy định những thao tác và dịch vụ cơ bản mà tầng kẻ dưới cung cấp cho tầng kẻ trên và số các tương tác qua lại giữa hai tầng kẻ nhau là nhỏ nhất.

Dữ liệu không được truyền trực tiếp từ tầng thứ i của hệ thống phát sang tầng thứ i của hệ thống nhận (trừ tầng thấp nhất-tầng vật lý) mà được chuyển từ tầng cao xuống tầng thấp nhất bên hệ thống phát và qua đường truyền vật lý, dữ liệu là chuỗi bit không cấu trúc được truyền sang tầng thấp nhất của hệ thống nhận và từ đó dữ liệu được chuyển ngược lên các tầng trên. Giữa các tầng đồng cấp xác định liên kết logic, giữa các tầng vật lý có liên kết vật lý.





Hình 6-1: Mô hình OSI và TCP/IP

Mô hình OSI gồm 7 lớp:

Mô hình OSI			
	Đơn vị dữ liệu giao thức	Tầng	Chức năng
Các tầng Host	Dữ liệu (Data)	Ứng dụng	Cung cấp giao diện cho người dùng và hệ thống mạng thông qua các ứng dụng
		Trình bày	Biểu diễn, mã hóa và nén dữ liệu
		Phiên	Quản lý các phiên truyền thông giữa các thực thể
	Phân đoạn (Segment)	Vận chuyển	Kết nối các thiết bị đầu cuối và đảm bảo tin cậy (TCP)
Các tầng môi trường mạng	Các gói tin (Packets)	Mạng	Xác định đường đi và địa chỉ logic (IP)
	Các Khung (Frames)	Liên kết dữ liệu	Địa chỉ vật lý (MAC & LLC)
	Các bit (Bits)	Vật lý	Môi trường truyền dẫn, tín hiệu và các bit nhị phân

Hình 6-2: Mô hình OSI



Tầng application (ứng dụng): Cung cấp các dịch vụ cho người sử dụng và các chương trình ứng dụng. Nó như là giao diện của người sử dụng và các ứng dụng để truy cập các dịch vụ mạng

Tầng presentation (trình bày): Làm nhiệm vụ trình bày dữ liệu được gửi từ tầng ứng dụng sang dạng định dạng chung và ngược lại.

Tầng session (phiên): Thiết lập và kết thúc các phiên kết nối giữa các tiến trình đang chạy trên các máy tính khác nhau.

Tầng transport (vận chuyển): Cung cấp dịch vụ truyền dữ liệu tin cậy giữa các thiết bị đầu cuối thông qua giao thức TCP có kết nối và giao thức UDP không kết nối.

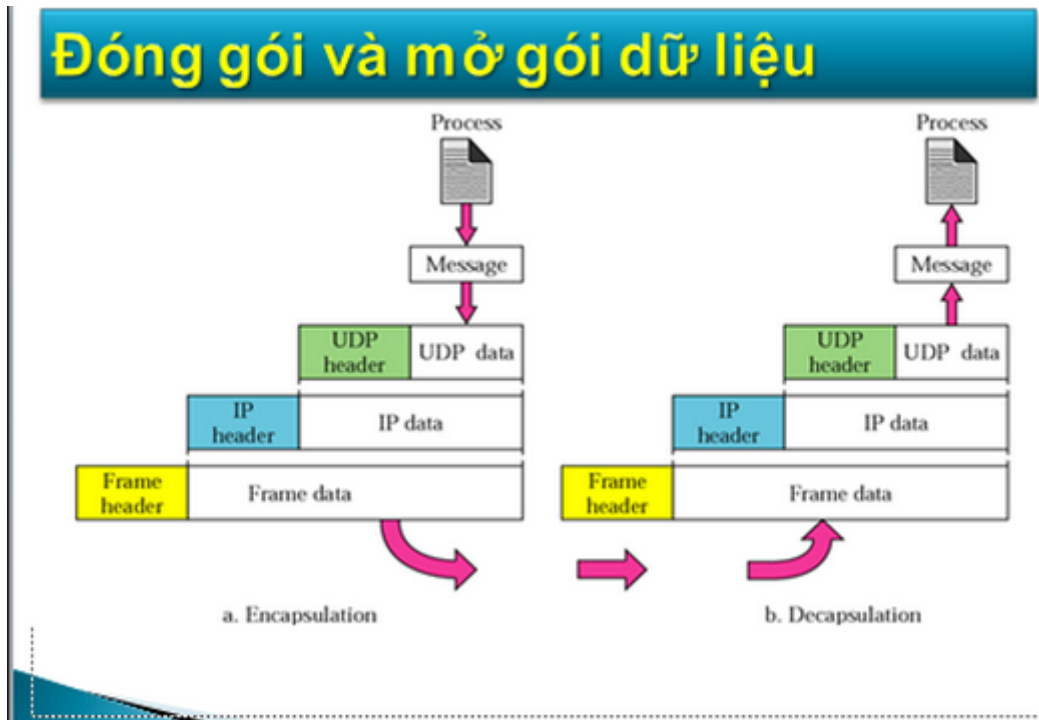
Tầng network (mạng): Cung cấp dịch vụ đánh địa chỉ mạng, định tuyến, tìm kiếm đường đi cho các gói tin, từ nơi gửi tới nơi nhận, điều khiển tránh tắc nghẽn.

Tầng data link (liên kết dữ liệu): Thực hiện công việc truyền các khung dữ liệu từ thiết bị này sang thiết bị khác qua tầng vật lý, đảm bảo sự tin cậy, gửi các khối dữ liệu với các cơ chế đồng bộ hoá, kiểm soát lỗi và kiểm soát luồng dữ liệu.

Lớp physical (vật lý): Xác định các giao diện về mặt điện học và cơ học giữa một trạm thiết bị và môi trường truyền thông nhằm đảm nhiệm toàn bộ công việc truyền dẫn dữ liệu bằng phương tiện vật lý.

Mô hình tham chiếu OSI bao hàm mọi mặt của quá trình truyền thông, giúp chúng ta hiểu rõ quá trình truyền thông trên mạng xảy ra như thế nào. Cụ thể quá trình đóng gói dữ liệu và sửa gói dữ liệu trong mô hình OSI được mô tả dưới hình sau:

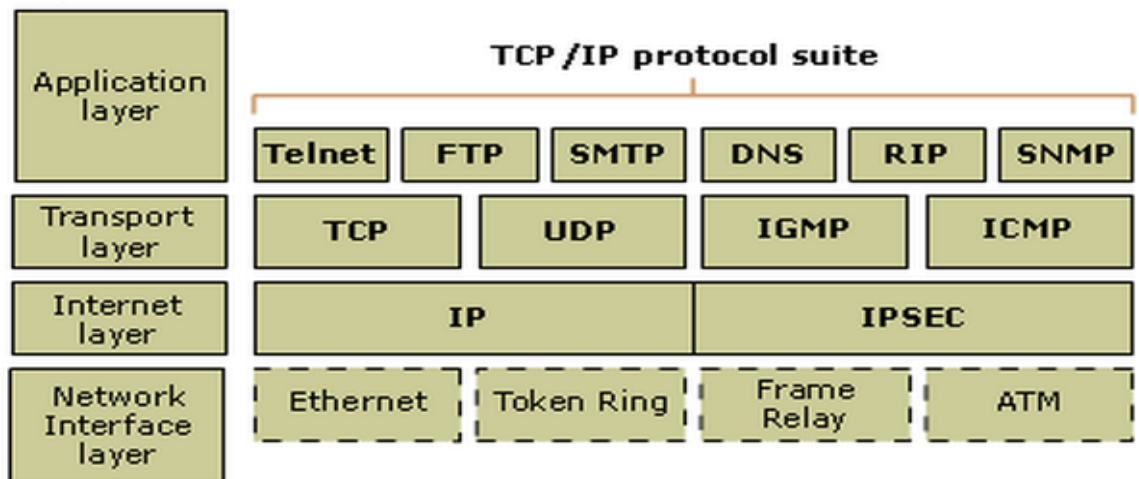




Hình 6-3: Đóng gói / mở gói dữ liệu trong mô hình OSI

❖ Mô hình TCP/IP gồm các tầng sau:

TCP /IP model



Hình 6-4: Mô hình TCP/IP

Tầng ứng dụng: Quản lý các giao thức, hỗ trợ việc trình bày, mã hóa và quản lý cuộc gọi. Lớp ứng dụng trong mô hình TCP/IP hỗ trợ nhiều ứng dụng như: FTP(File Transfer Protocol), HTTP(Hypertext Transfer Protocol), SMTP(Simple Mail Transfer Protocol), DNS(DomainName System), TFTP(Trivial File TransferProtocol).



Tầng Transport: đảm nhiệm việc vận chuyển dữ liệu từ nguồn đến đích thông qua hai nghi thức: TCP (Transmission Control Protocol) và UDP (User Datagram Protocol).

Tầng Internet: Làm nhiệm vụ chọn đường đi tốt nhất cho các gói tin, giao thức chính sử dụng tại lớp này là giao thức IP.

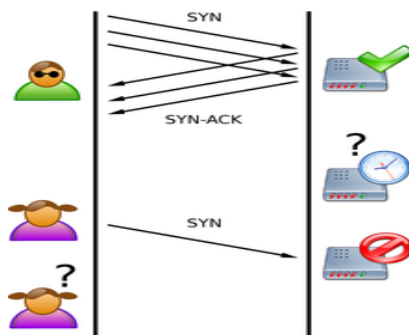
Tầng truy cập mạng: Bao gồm chức năng của lớp Data Link và Physical.

6.1.2 Một số điểm yếu của bộ giao thức TCP/IP

TCP (Transmission Control Protocol) là giao thức thuộc tầng vận chuyển, TCP là giao thức hoạt động có độ tin cậy rất cao, trước khi các thiết bị trao đổi thông tin với nhau thông qua giao thức TCP thì giữa chúng phải thực hiện quá trình bắt tay 3 bước (Three –Way–Handshake) đây là điểm yếu mà các tin tặc (Hacker) lợi dụng để thực hiện các cuộc tấn công. Điển hình là kiểu tấn công làm ngập lụt (TCP SYNflood), máy bị tấn công theo kiểu ngập lụt sẽ không thể hoạt động được như bình thường nữa do phải xử lý quá nhiều gói tin TCP SYN.

a) Tấn công TCP SYN flood

Kẻ tấn công lợi dụng quá trình bắt tay 3 bước trong giao thức TCP để thực hiện tấn công vào máy đích. Sau khi xác định được mục tiêu tấn công, kẻ tấn công liên tục gửi các gói tin SYN (Synchronization) để yêu cầu khởi tạo kết nối TCP đến máy định tấn công. Khi nhận được các yêu cầu này, máy bị tấn công sẽ gửi lại các gói tin đồng bộ SYN-ACK (Synchronization-Acknowledgement) và chờ gói tin xác nhận ACK từ máy tấn công. Tuy nhiên, kẻ tấn công không gửi lại các gói tin ACK mà vẫn tiếp tục gửi các gói tin SYN. Kết quả là máy bị tấn công phải tốn bộ nhớ để xử lý các gói tin SYN và chờ gói ACK của máy tấn công. Khi số lượng yêu cầu kết nối từ kẻ tấn công rất lớn sẽ làm cho máy bị tấn công cạn kiệt tài nguyên và buộc phải từ chối phục vụ những yêu cầu khác.



Hình 6-5: Tấn công TCP Syn Flood



❖ **Phòng chống tấn công**

Để ngăn ngừa những cuộc tấn công SYN xảy ra thì hệ thống mạng cần phải loại bỏ được các gói tin SYN của kẻ tấn công. Các bộ định tuyến, tường lửa ...có thể ngăn ngừa các cuộc tấn công TCP SYN bằng cách hạn chế các yêu cầu kết nối từ một nguồn. Nếu số lượng yêu cầu kết nối lớn hơn một ngưỡng nào đó thì các kết nối sau sẽ tạm thời bị loại bỏ. Hoặc cách khác vẫn cho phép các kết nối TCP đi vào mạng nhưng giám sát các kết nối này để chống kiểu tấn công TCP SYN.

Ví dụ 6.1:

Trên bộ định tuyến Cisco thực hiện câu lệnh "ip tcp intercept mode watch" để giám sát các gói tin TCP nếu kết nối TCP nào không hoàn thành bắt tay hai chiều trong một khoảng thời gian sẽ được phát hiện và lúc này router sẽ gửi một thông điệp "TCP reset" đến máy đang bị tấn công lúc này máy bị tấn công sẽ biết và loại bỏ các kết nối TCP ảo khỏi bộ nhớ.

b) Tấn công sử dụng giao thức gói dữ liệu người dùng (UDP)

UDP (User Datagram Protocol): Là một trong những giao thức cốt lõi của bộ giao thức TCP/IP. UDP không cung cấp sự tin cậy và thứ tự truyền nhận giống giao thức TCP. Các gói dữ liệu có thể đến không đúng thứ tự hoặc bị mất mà không có thông báo. Tuy nhiên UDP nhanh và hiệu quả hơn đối với các ứng dụng yêu cầu sự đáp ứng về mặt thời gian ngắn (thời gian thực) và dữ liệu nhỏ.

Do UDP không có cơ chế điều khiển tắc nghẽn nên khi tin tặc thực hiện tấn công thông qua giao thức UDP thì các gói tin tấn công UDP sẽ chiếm băng thông của mạng làm ảnh hưởng tới người dùng.

❖ **Phòng chống tấn công**

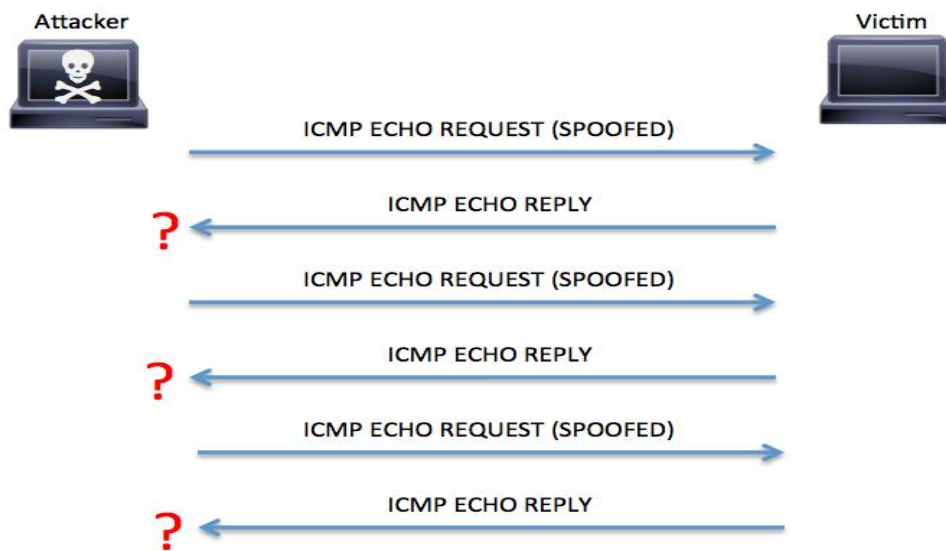
Sử dụng phần mềm và biện pháp nghiệp vụ để tìm và đóng các cổng UDP không cần thiết trên máy tính. Trong đó, tường lửa là giải pháp tối ưu để ngăn cản các hình thức tấn công kiểu này. Tường lửa có thể chặn, giới hạn kích thước và số lượng gói tin UDP cho hệ thống.

c) Tấn công sử dụng giao thức thông điệp điều khiển liên mạng (ICMP)

Giao thức điều khiển tin nhắn liên mạng - Internet Control Message Protocol (ICMP) hoạt động ở lớp Internet trong mô hình TCP/IP. ICMP giúp thông báo trạng thái của đường truyền hỗ trợ cho giao thức IP.



Trong tấn công ICMP, kẻ tấn công gửi gói tin ping đến địa chỉ quảng bá của mạng, điều này khiến tất cả những thiết bị trong mạng phải gửi gói tin "ICMPecho replies" đáp lại. Khi đó, một lượng lớn các luồng dữ liệu được tạo ra, nó sẽ làm tiêu tốn rất nhiều băng thông mạng. Ngoài ra, kẻ tấn công còn có thể sử dụng các gói tin có độ dài bất thường. Cách tấn công này ảnh hưởng đến cả khả năng xử lý của CPU và băng thông mạng.



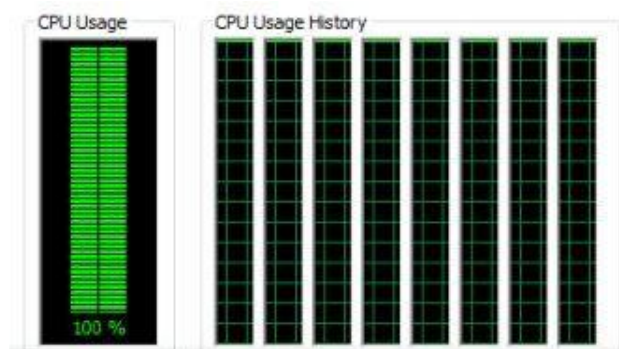
Hình 6-6: Tấn công ICMP

Mô tả: Tin tặc có thể lợi dụng điểm yếu của giao thức bảo trì hệ thống mạng thông qua lệnh Ping để thực hiện tấn công vào máy chủ có địa chỉ IP là 200.201.10.10 bằng cách sử dụng phần mềm hoặc vào môi trường DOS của Windows để liên tục gửi các gói tin ICMP đến máy có địa chỉ IP là: 200.201.10.10 như sau:

c>Ping -L 65500 200.201.10.10 -t (câu lệnh này được thực hiện trên DOS, cứ 1s máy 200.201.10.10 sẽ nhận được 1 gói tin có kích thước là 65500)

Máy bị tấn công liên tục nhận được các gói tin ICMP, liên tục phải trả lời, giành bộ nhớ để chờ đợi gói tin trả lời (reply). Đến một lúc nào đó CPU của máy 200.201.10.10 sẽ tăng đến 100% và máy chủ không thể hoạt động được, lúc này tin tặc đã thực hiện tấn công thành công.





Hình 6-7 : CPU máy bị tấn công tăng đến 100%

❖ Phòng chống

Biện pháp thường được sử dụng để ngăn ngừa kiểu tấn công này là dùng tường lửa hoặc bộ định tuyến (Router) để ngăn các gói tin ICMP tấn công vào hệ thống và thiết bị cần được bảo vệ.

d) Tấn công từ chối dịch vụ - DoS (Denial of Service)

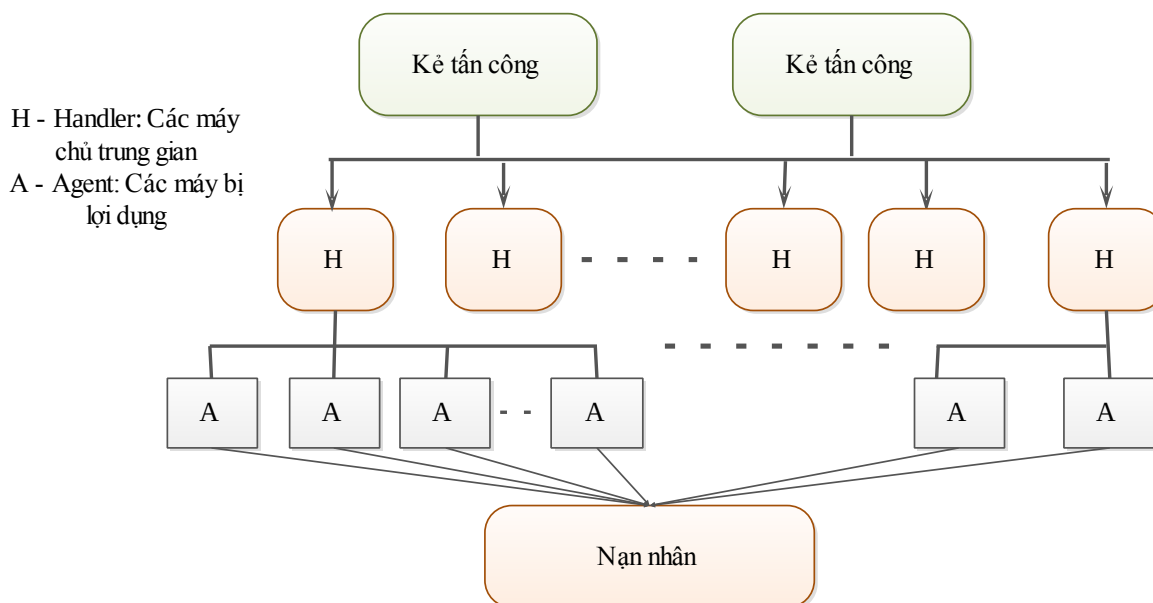
Tấn công từ chối dịch vụ là kiểu tấn công mà kẻ tấn công sẽ cố gắng làm cho máy bị tấn công cạn kiệt tài nguyên và không còn khả năng phục vụ những người dùng hợp lệ khác.

Hiện nay có 2 kiểu tấn công từ chối dịch vụ là tấn công từ chối dịch vụ DoS và tấn công từ chối dịch vụ phân tán DDoS.

Sự khác nhau cơ bản của DoS và DDoS là số lượng các máy được huy động để thực hiện tấn công. Số lượng các máy tham gia vào tấn công DoS là rất ít trong khi DDoS số lượng các máy tham gia vào là rất lớn.

Ngày nay, hầu hết các cuộc tấn công từ chối dịch vụ thường tập trung vào các máy chủ website của các cơ quan và doanh nghiệp. Những kẻ tấn công thường chọn kỹ thuật tấn công từ chối dịch vụ phân tán (DDoS - Distributed Denial Of Service) để tấn công các máy chủ, các cuộc tấn công phân tán thường diễn ra nhanh và rất khó chống đỡ. Trong các cuộc tấn công DDoS, máy chủ dịch vụ sẽ bị "lụt" bởi hàng loạt các lệnh truy cập từ rất nhiều máy tấn công khác nhau. Khi số lệnh truy cập quá lớn, máy chủ sẽ quá tải và không còn khả năng xử lý các yêu cầu. Hậu quả là người dùng không thể truy cập vào các dịch vụ trên các trang website bị tấn công DDoS.

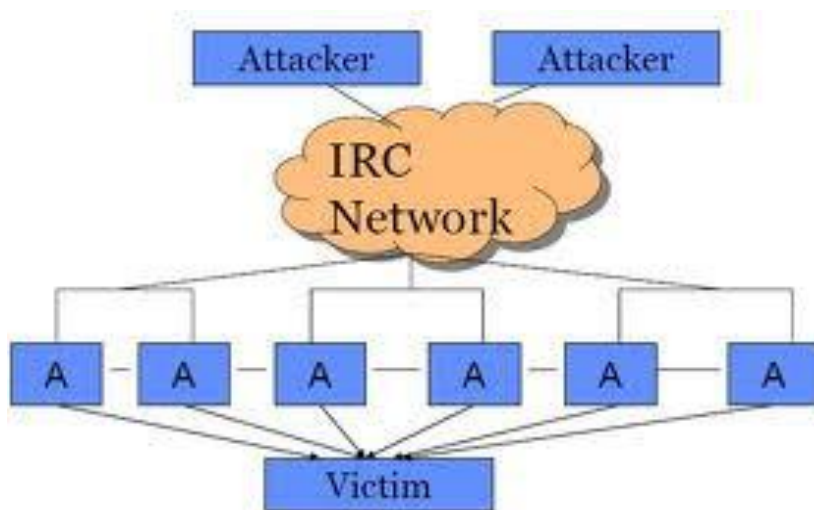
- Các mô hình tấn công DDoS



Hình 6-8: Mô hình tấn công Agent Handler Model

Kẻ tấn công sẽ cài đặt phần mềm gián điệp trên các máy chủ có số lượng người dùng truy cập nhiều, thông qua máy tính của mình kẻ tấn công sẽ giao tiếp với các máy chủ trung gian để xác định số lượng máy bị lây nhiễm đang hoạt động, điều chỉnh thời điểm tấn công và cập nhật thêm máy bị lây nhiễm để từ đó thực hiện các cuộc tấn công từ chối dịch vụ.

Chính vì hoạt động như vậy nên kẻ tấn công thường rất khó bị phát hiện do các giao tiếp giữa kẻ tấn công, máy trung gian và máy bị lây nhiễm khó bị phát hiện. Các máy bị lợi dụng tham gia vào cuộc tấn công mà không hề hay biết, địa chỉ IP của máy bị tấn công thường khó phát hiện.



Hình 6-9: Mô hình tấn công DDoS dựa trên nền tảng IRC



IRC (Internet Relay Chat) là một hệ thống cho phép kẻ tấn công tạo một kết nối đến nhiều người dùng bị lợi dụng tham gia và tấn công tại một thời điểm nhất định. Kiến trúc của một mạng IRC bao gồm nhiều máy chủ IRC trên Internet. Các máy chủ IRC này sẽ giao tiếp với nhau trên nhiều kênh và tạo lên một hệ thống mạng vô cùng lớn.

Mô hình tấn công từ chối dịch vụ dựa trên nền tảng IRC cũng tương tự như mô hình máy bị lây nhiễm – máy trung gian nhưng mô hình này sử dụng các kênh giao tiếp IRC làm phương tiện giao tiếp giữa các máy trung gian. Sử dụng mô hình này, kẻ tấn công còn có thêm một số lợi thế khác như:

- + Kẻ tấn công khó bị phát hiện hơn.
- + Dễ dàng tấn công hơn do số lượng lớn mà không bị nghi ngờ. Không cần phải duy trì danh sách các máy bị lợi dụng, tin tặc chỉ cần Login vào máy chủ IRC là đã có thể nhận được thông báo về trạng thái các máy có thể huy động để tấn công do các kênh truyền gửi về.
- Phòng chống DDoS điển hình

Các cuộc tấn công DDoS thường rất nguy hiểm và khó có thể ngăn chặn hoàn toàn do đó khi có tấn công xảy ra cần bình tĩnh và thực hiện 3 giai đoạn sau để phòng chống tấn công:

Giai đoạn 1: Giảm số lượng các máy tính tấn công bằng cách phát hiện và ngăn chặn. Tìm và ngăn chặn các máy phát động tấn công

Giai đoạn 2: Đối đầu với cuộc tấn công bằng cách phát hiện và ngăn chặn các cuộc tấn công, làm suy giảm các cuộc tấn công, chuyển cuộc tấn công.

Giai đoạn 3: Thu tập các chứng cứ của cuộc tấn công thông qua việc phân tích để rút kinh nghiệm và có biện pháp đề phòng về sau

Để có thể ngăn chặn và hạn chế được tấn công từ chối dịch vụ thì đòi hỏi sự cộng tác và kết hợp từ nhiều người, nhiều phía:

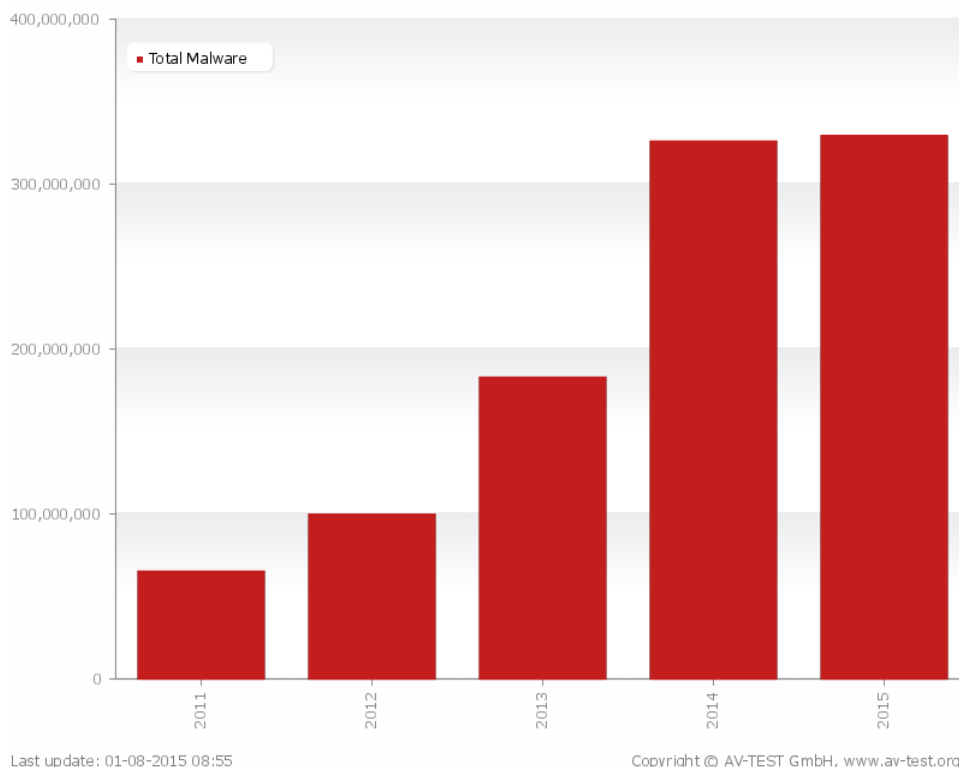
- + Người sử dụng mạng cần được cung cấp các kiến thức và kỹ năng an toàn để tránh bị lợi dụng
- + Các ISP cần giám sát bằng thông bất thường để cảnh báo về cuộc tấn công
- + Sử dụng các giao thức bảo mật như: SSL, Ipsec
- + Nghiên cứu và phát triển các công cụ, các thuật toán có khả năng tự động phát hiện và ngăn chặn các cuộc tấn công

- + Phát triển và sử dụng các hệ điều hành bảo mật hơn
- + Xây dựng các hệ thống có khả năng giám sát, đưa ra cảnh báo, ngăn chặn tấn công.

6.2 Phần mềm độc hại – Malware

6.2.1 Khái niệm

Malware hay “Malicious Software” còn được gọi là phần mềm độc hại, nó được xem như là một chương trình được chèn một cách bí mật vào hệ thống với mục đích làm tổn hại đến tính bí mật, tính toàn vẹn hoặc tính sẵn sàng của hệ thống.



Hình 6-10: Thống kê tổng số lượng phần mềm mã độc

Theo thống kê của AV-TEST, trung bình mỗi ngày có khoảng 390.000 phần mềm mã độc mới ra đời. Từ năm 2011 đến nay số lượng phần mềm mã độc tăng lên từng năm theo cấp số cộng. Năm 2011 số lượng phần mềm độc hại khoảng 700.000.000 loại nhưng đến năm số lượng phần mềm mã độc đã tăng lên con số là hơn 325.000.000.

6.2.2 Trojan và Backdoor

a) Giới thiệu về Trojans và Backdoor:



Trojan Horse gọi tắt Trojans: là loại mã độc hại được đặt theo truyện cổ tích “Con ngựa thành Troy”. Trojan là một chương trình nhỏ chạy chế độ ẩn và gây hại cho máy tính. Với sự trợ giúp của Trojan, một kẻ tấn công có thể dễ dàng truy cập vào máy tính của nạn nhân để thực hiện một số việc nguy hại như lấy cắp dữ liệu, xóa tệp, và nhiều khả năng khác. Trojans là chương trình có khả năng:

- Lấy thông tin của Credit Card...
- Lấy thông tin của các tài khoản cá nhân như: Email, Password, Usernames, thông tin về tài khoản ngân hàng ... bằng cách sử dụng keylogger, phần mềm gián điệp – Spyware...
- Sinh ra những lưu lượng giả mạo để tạo ra các cuộc tấn công DoS.
- Tải các phần mềm như phần mềm gián điệp – spyware, hay những tệp độc hại khác về máy tính nạn nhân.
- Sử dụng máy tính nạn nhân như một botnet để thực hiện các cuộc tấn công DDoS.
- Sử dụng máy tính của nạn nhân để thực hiện một tác vụ nào đó như gửi các thư rác, phát tán thư quảng cáo ...
- Biến máy nạn nhân thành một Proxy Server cho các mục đích xấu.
- Backdoor còn được gọi là "cửa sau" cũng là một loại Trojan. Khi Backdoor được cài đặt trên máy tính nạn nhân thì nó luôn lắng nghe và mở sẵn ra một "cửa" trên máy tính đó để kẻ tấn công có thể dễ dàng truy cập hoặc kết nối tới bất cứ lúc nào mà không cần phải sử dụng nhiều kỹ thuật "tấn công" máy nạn nhân.

b) Phân loại và cách hoạt động của Trojan

- Phân loại Trojan

Tùy theo mục đích của người viết ra Trojan mà người ta chia thành một số loại trojan phổ biến sau:

- + Remote Access Trojans – Cho kẻ tấn công kiểm soát toàn bộ hệ thống từ xa.
- + Data-Sending Trojans – Gửi những thông tin nhạy cảm cho kẻ tấn công.
- + Destructive Trojans – Trojan phá hủy hệ thống.
- + Denied-of-Service – DoS Attack Trojan: Trojans cho tấn công DoS.
- + Proxy Trojans: Biến máy nạn nhân thành Proxy Server để kẻ tấn công lợi dụng thực hiện những ý đồ xấu.



- + HTTP, FTP Trojans: Trojan tự tạo thành HTTP hay FTP server để kẻ tấn công khai thác lỗi ở trên máy bị nhiễm.
- + Security Software Disable Trojan – Có tác dụng tắt những tính năng bảo mật trong máy tính của nạn nhân...



Hình 6-11: Một số dạng Trojans (nguồn: www.Eccouncil.com)

- Những biểu hiện của một máy tính khi bị nhiễm Trojans
- Khi máy tính bị nhiễm Trojan, thông thường sẽ có một số biểu hiện như sau:
- + Ổ CD-ROM tự động mở ra đóng vào;
 - + Có những dấu hiệu lạ trên màn hình (màn hình desktop bị thay đổi, font chữ hoặc một số biểu tượng bị thay đổi ...)
 - + Màn hình máy tính tự tắt và tự bật;
 - + Tự động in các văn bản;
 - + Máy tính tự động thay đổi font chữ và các thiết lập khác;
 - + Hình nền máy tính tự động thay đổi và không thể đổi lại;
 - + Chuột trái, chuột phải lẫn lộn..;
 - + Chuột không hiển thị trên màn hình;
 - + Nút Start không hiển thị;
 - + Một vài cửa sổ chat bật ra;



- + Chương trình diệt virus bị tắt hay hoạt động không đúng....
- Hoạt động của Trojan

Bất cứ một chương trình Trojan nào khi hoạt động đều có 3 đặc điểm sau:

- + Một Trojan muốn hoạt động phải lắng nghe các yêu cầu(Request) trên một cổng nào đó (có nghĩa là Trojan luôn mở một cổng và lắng nghe lệnh điều khiển của kẻ tấn công thông qua cổng đó).
- + Một chương trình đang chạy sẽ phải có tên trong danh sách tiến trình “process List”.
- + Một chương trình Trojan sẽ luôn chạy cùng lúc khi máy tính khởi động.

Có rất nhiều con đường để một Trojan có thể lây nhiễm vào trong máy tính. Sau đây là những con đường lây nhiễm phổ biến thường gặp:

- + Qua các ứng dụng CHAT trực tuyến như "IRC – Internet Relay Chat".
- + Qua các tệp được đính kèm trên Mail...
- + Qua tầng vật lý như trao đổi dữ liệu qua USB, CD, HDD...
- + Khi thực thi một tệp bị nhiễm Trojan.
- + Qua NetBIOS – Chia sẻ tệp.
- + Qua những chương trình nguy hiểm có nguồn gốc không rõ ràng.
- + Từ những trang web không tin tưởng hay những website cung cấp phần mềm miễn phí.
- + Trojan có khả năng ẩn trong các ứng dụng bình thường, khi chạy ứng dụng đó lập tức cũng chạy luôn Trojan...

c) Phương pháp phát hiện và phòng chống Trojan

- Phương pháp phát hiện ra Trojan và Backdoor

Dựa vào nguyên lý hoạt động của Trojan, để phát hiện ra Trojan có đang "hoạt động" trên máy tính hay không thì ta nên:

- + Quét các cổng nghi ngờ đang mở.
- + Quét để phát hiện các chương trình lạ đang chạy trên hệ điều hành (một số loại Trojan có khả năng tự ẩn mình trong những trình quản lý mặc định của hệ thống. Trong trường hợp này ta nên sử dụng những chương trình



kiểm tra được cả những tiến trình đang ẩn của hệ thống vd: process explorer...).

+ Kiểm tra các chương trình chạy lúc khởi động cùng hệ điều hành.

– ***Phương thức phòng chống Trojans và Backdoor***

Để hạn chế nguy cơ bị Trojan lây nhiễm thì người dùng nên:

Không sử dụng các phần mềm không tin tưởng, đặc biệt là các phần mềm miễn phí được chia sẻ tại những nguồn không tin cậy.

Không vào các trang web nguy hiểm, không tùy tiện cài các ActiveX và JavaScript trên các trang web đó bởi có thể sẽ dính kèm Trojans.

Phải cập nhật các bản vá lỗi cho hệ điều hành, các chương trình phần mềm thường xuyên.

Cài phần mềm diệt Virus uy tín như: Kaspersky Internet Security, Norton Internet Security, McAfee Total Security... và một số phần mềm diệt Virus và chống Trojan khác. Sau khi cài các phần mềm này cần phải cập nhật cơ sở dữ liệu thường xuyên và nên có lịch quét định kỳ...

6.2.3 Virus và Worm

a) Khái niệm

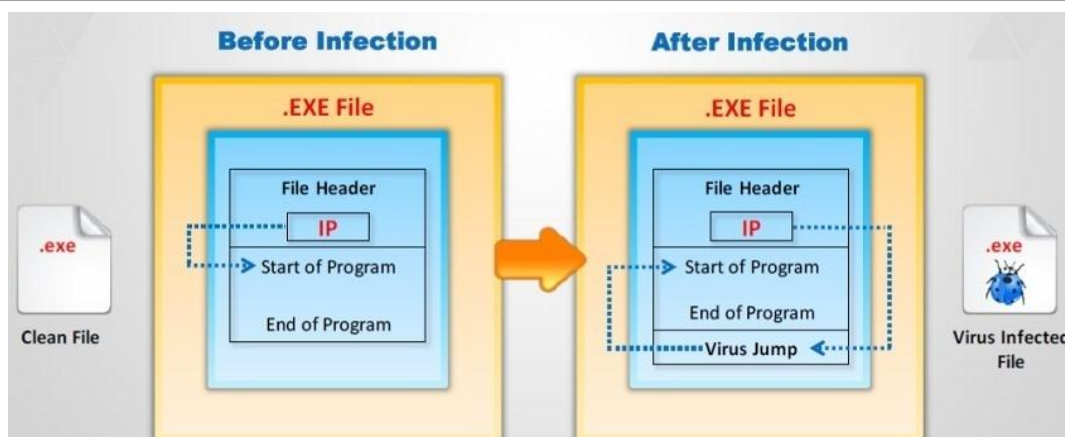
Virus máy tính (thường được người sử dụng gọi tắt là virus) là những chương trình hay đoạn mã được thiết kế để có khả năng tự nhân bản và sao chép chính nó vào các đối tượng khác (tệp, ổ đĩa, máy tính,...). Trước đây, virus thường được viết bởi một số người am hiểu về lập trình muốn chứng tỏ khả năng của mình nên thường virus có các hành động như: cho một chương trình không hoạt động đúng, xóa dữ liệu, làm hỏng ổ cứng,... hoặc gây ra những trò đùa khó chịu. Chiếm trên 90% số virus đã được phát hiện là nhắm vào hệ thống sử dụng hệ điều hành họ Windows chỉ đơn giản bởi hệ điều hành này được sử dụng nhiều nhất trên thế giới. Do tính thông dụng của Windows nên các tin tặc thường tập trung hướng vào chúng nhiều hơn là các hệ điều hành khác.

Worm (sâu máy tính) cũng là một loại virus máy tính nhưng nó có khả năng lây lan bằng cách tự phát tán qua hệ thống mạng và dựa vào các lỗ hổng của hệ điều hành, chương trình ứng dụng để lây nhiễm vào máy tính.

b) Phương thức hoạt động của virus

Giai đoạn lây nhiễm: Virus tự nhân bản và sao chép chính nó và đính kèm vào một tệp có khả năng thực thi trong hệ thống.





Hình 6-12 : Giai đoạn trước và sau khi lây nhiễm của virus

(nguồn: www.Eccouncil.com) (tệp thực thi _Executable)

Giai đoạn tấn công: Virus được lập trình với các sự kiện để kích hoạt và làm lỗi tệp hoặc chương trình của hệ thống. Có loại virus sẽ lây nhiễm sau mỗi lần hoạt động, có loại virus sẽ lây nhiễm khi có một sự kiện đặc biệt nào đó xảy ra như: người dùng sử dụng một tác vụ nào đó, hoặc vào một thời gian hay một sự kiện nào đó xảy ra....

c) Những dấu hiệu khi bị virus tấn công

Khi máy tính bị nhiễm virus thì thường có một số biểu hiện sau:

- Máy tính chạy chậm khác bình thường
- Các chương trình mất nhiều thời gian để thực thi;
- Ổ cứng thường xuyên bị đầy kể cả khi không cài thêm chương trình nào;
- Các ổ đĩa hay ổ cứng đều chạy cả khi không được sử dụng;
- Bàn phím hoặc máy tính có những biểu hiện hoặc tiếng kêu lạ;
- Màn hình máy tính có những hình ảnh lạ;
- Bộ nhớ máy tính thường xuyên bị đầy hoặc hệ thống chạy chậm;
- Có một số tiến trình lạ được thực thi ở trong “Task manager”....
- Có rất nhiều cách thức để Virus có thể lây nhiễm vào trong hệ thống máy tính. Sau đây là một số con đường phổ biến nhất:
- Khi người dùng chấp nhận và tải một tệp về mà không kiểm tra chính xác nguồn gốc của tệp đó;
- Kẻ tấn công thường gửi tệp lây nhiễm virus như là đính kèm vào email và gửi tới nạn nhân. Khi nạn nhân mở tệp đó thì virus sẽ lây nhiễm vào trong máy nạn nhân;



- Kẻ tấn công thường “gắn” kèm virus vào những phần mềm thông dụng và tải phần mềm đã lây nhiễm đó lên website cho người dùng tải về. Khi nạn nhân tải và cài đặt tệp bị lây nhiễm thì máy tính của nạn nhân sẽ bị nhiễm virus;
- Khi kẻ tấn công “tạo” ra một virus mới, các chương trình phần mềm diệt virus chưa có bản cập nhật để diệt virus đó...

d) Một số cách phòng chống và hạn chế

Mỗi người dùng, doanh nghiệp hay công ty phải có biện pháp phòng ngừa và hạn chế ảnh hưởng của việc lây nhiễm virus và mất mát dữ liệu sao cho tác hại đối với người dùng và doanh nghiệp là thấp nhất. Sau đây là một số khuyến cáo đối với người dùng:

- Cài đặt phần mềm Antivirus để phát hiện và xóa bỏ những tệp bị nhiễm virus;
- Thường xuyên cập nhật phần mềm Antivirus và quét máy tính theo định kỳ;
- Tạo ra một chính sách sử dụng máy tính an toàn và phân phối đến các nhân viên trong công ty, doanh nghiệp;
- Tải và cài đặt các phần mềm trên Internet từ những nguồn tin cậy;
- Tránh mở những tệp đính kèm từ những người gửi không biết rõ ràng;
- Thường xuyên và có chiến lược sao lưu dữ liệu để tránh bị mất hoàn toàn dữ liệu khi hệ thống bị lây nhiễm virus;
- Không chấp nhận, cài đặt, thực thi một chương trình nào mà chưa kiểm tra chúng với phiên bản mới nhất của chương trình Antivirus;
- Chắc chắn rằng các mã thực thi trên được gửi từ một tổ chức tin cậy;
- Mở tường lửa sẵn có ở trên hệ điều hành đang sử dụng;
- Kiểm tra ổ đĩa di động trước khi sử dụng và thực thi các chương trình trong ổ đĩa di động đó...

6.3 Các hình thức tấn công WLAN

6.3.1 Một số khái niệm về WLAN

WLAN (Wireless Local Area Network) hay còn gọi là mạng cục bộ không dây. WLAN là một mạng máy tính trong phạm vi nhỏ hẹp không sử dụng cáp mạng để truyền dữ liệu từ thiết bị này tới thiết bị khác.

Điểm truy cập (AP): có chức năng và nhiệm vụ giống như Hub ở trong môi trường mạng có dây.

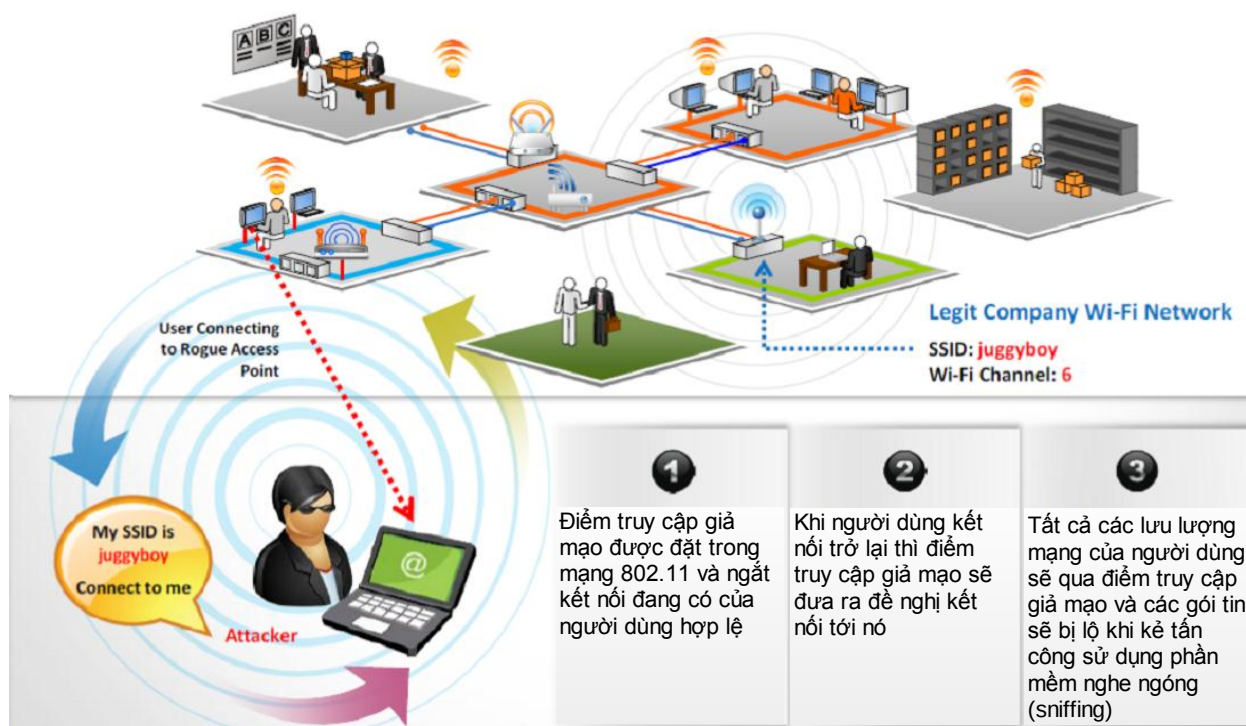


Định danh thiết lập dịch vụ - Services Set Identification (SSID): Được sử dụng như là định danh duy nhất của mạng cục bộ không dây. SSID sẽ do người dùng thiết lập trực tiếp vào trong điểm truy cập và thường được biết đến như là tên mạng.

Khung báo hiệu: Là một khung quản lý trong chuẩn IEEE 802.11. Khung báo hiệu chứa tất cả các thông tin về hệ thống mạng và được truyền một cách định kỳ từ điểm truy cập để thông báo về sự hiện diện của mạng cục bộ không dây.

6.3.2 Tấn công giả mạo điểm truy cập

Mạng 802.11 cho phép điểm truy cập không dây kết nối tới giao tiếp mạng (NIC) của người dùng bằng cách chứng thực với định danh thiết lập dịch vụ. Một điểm truy cập không cần chứng thực có thể cho phép bất cứ thiết bị nào thuộc chuẩn 802.11 kết nối tới nó. Với sự giúp đỡ của các công cụ nghe lén đường truyền không dây, kẻ tấn công có thể dễ dàng xác định được: địa chỉ vật lý của điểm truy cập hợp lệ, tên nhà sản xuất, cấu hình bảo mật. Kẻ tấn công sẽ tạo ra danh sách các địa chỉ vật lý của các điểm truy cập cần xác thực rồi kiểm tra lại với các địa chỉ MAC được tìm bởi phần mềm nghe ngóng đường truyền.



Hình 6-13: Tấn công giả mạo điểm truy cập (nguồn: www.Eccouncil.com)

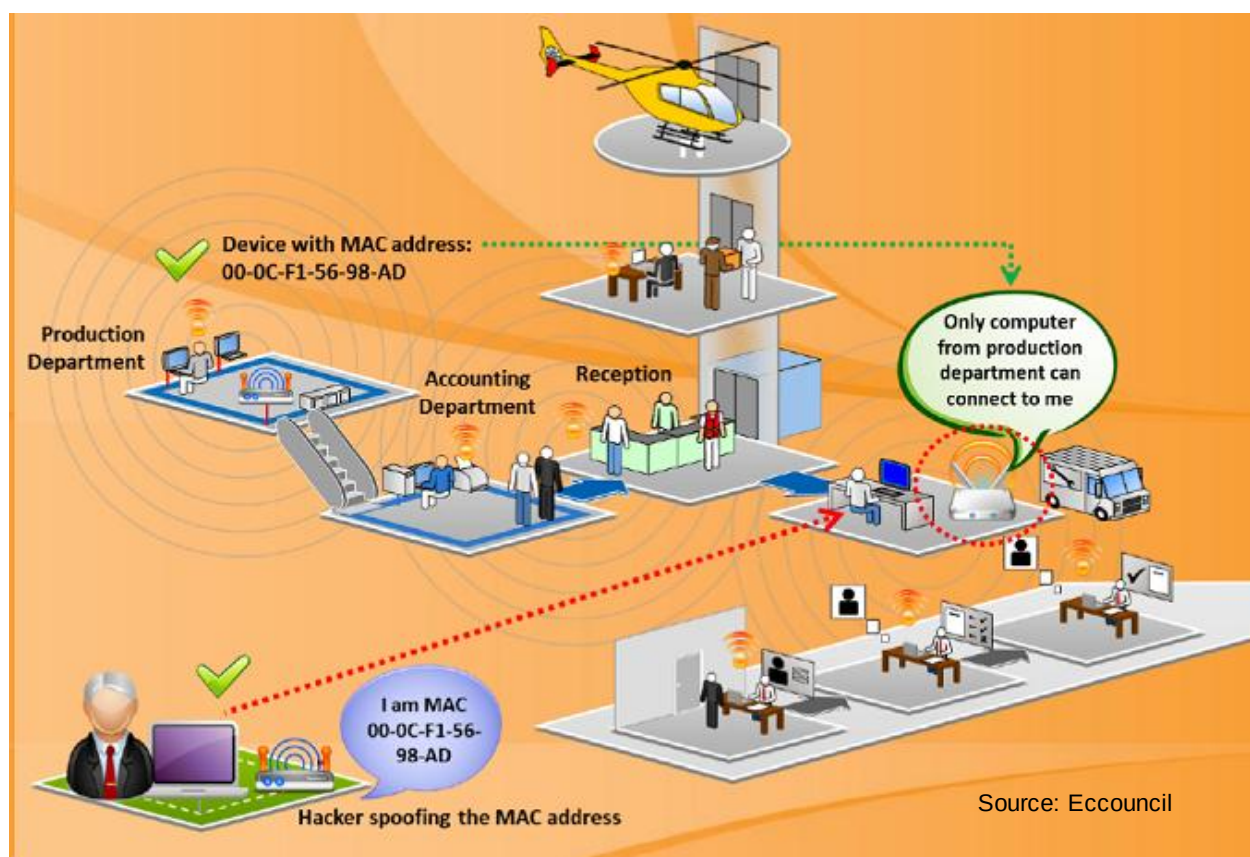
Kẻ tấn công tạo ra một điểm truy cập giả mạo và đặt gần với mạng của người dùng. Điểm truy cập không dây giả mạo theo chuẩn 802.11 có thể được sử dụng để ngắt kết nối đang có của người dùng. Khi người dùng kết nối trở lại mạng thì kẻ tấn



công sẽ như người dùng kết nối tới điểm truy cập giả mạo bằng cách gửi định danh thiết lập dịch vụ tới người dùng. Nếu đồng ý, người sẽ kết nối tới điểm truy cập giả mạo mà tưởng rằng mình đang kết nối tới điểm truy cập hợp lệ của mạng. Khi đó, tất cả lưu lượng mạng của người dùng sẽ đi qua điểm truy cập giả mạo. Bằng cách sử dụng những phần mềm nghe ngóng kẻ tấn công có thể lấy được những gói tin chứa thông tin sử dụng trên mạng của người dùng.

6.3.3 Giả mạo địa chỉ vật lý

Một trong những phương thức bảo mật trong mạng không dây là sử dụng bộ lọc địa chỉ vật lý (MAC Filter) trên điểm truy cập. Khi người dùng sử dụng bộ lọc này thì chỉ những địa chỉ vật lý nào được phép mới có thể kết nối tới điểm truy cập. Bằng cách sử dụng một phần mềm nghe ngóng trên mạng không dây, kẻ tấn công có thể xác định được địa chỉ vật lý hợp lệ có thể kết nối tới điểm truy cập.



Hình 66-14: Tấn công giả mạo địa chỉ vật lý (nguồn: www.Eccouncil.com)

Khi đó, kẻ tấn công sẽ sử dụng phần mềm kết nối tới mạng không dây để thay đổi địa chỉ vật lý của mình thành địa chỉ vật lý hợp lệ và có thể kết nối tới mạng như người dùng của mạng.



6.3.4 Tấn công yêu cầu xác thực lại

Trong phương thức tấn công yêu cầu xác thực lại, kẻ tấn công xác định mục tiêu tấn công là các người dùng trong mạng không dây và các kết nối không dây hợp lệ của họ. Sau đó kẻ tấn công sẽ chen các “khung” yêu cầu xác thực lại vào mạng không dây bằng cách giả mạo địa chỉ MAC nguồn và đích lần lượt của điểm truy cập và các người dùng. Khi người dùng nhận được khung yêu cầu xác thực lại thì nghĩ rằng chúng do điểm truy cập hợp lệ gửi đến. Máy tính người dùng sẽ gửi lại những gói tin yêu cầu kết nối và xác thực đến AP. Mục tiêu của tấn công yêu cầu xác thực lại thường là để:

- Hiện thị một định danh thiết lập dịch vụ ẩn (trong trường hợp người dùng cấu hình ẩn không quảng bá SSID).
- Thu thập những gói tin bắt tay của WEP/WPA/WPA2 (để tiến hành bẻ khóa WEP/WPA/WPA2).

6.3.5 Tấn công dựa trên sự cảm nhận sóng mang lớp vật lý

Một số tài liệu gọi kiểu tấn công này là tấn công tín hiệu gây tắc nghẽn (Jamming Signal Attack). Đây là một kiểu tấn công DoD trong mạng cục bộ không dây. Theo phương thức tấn công này, kẻ tấn công lợi dụng giao thức truy nhập đường truyền cảm nhận sóng mang tránh đụng độ CSMA/CA, tức là kẻ tấn công sẽ sử dụng một thiết bị phần cứng đặc biệt. Thiết bị phần cứng này sẽ phát ra tín hiệu gây nghẽn (Jamming Signal) và khi đó tất cả người dùng trong mạng sẽ nghĩ rằng lúc nào mạng cũng bị nghẽn và không kết nối vào trong mạng.

6.3.6 Tấn công ngắt kết nối

Mục đích của phương thức tấn công này giống với tấn công sử dụng gây nhiễu đó là ngăn không cho người dùng sử dụng mạng không dây. Kẻ tấn công xác định mục tiêu và mối liên kết giữa điểm truy cập với người dùng.

- Kẻ tấn công gửi khung tin yêu cầu ngắt kết nối bằng cách giả mạo địa chỉ vật lý nguồn và đích đến AP và các người dùng tương ứng.
- Client sẽ nhận và nghĩ rằng khung tin này để hủy kết nối đến từ điểm truy cập. Điểm truy cập cũng nhận được các khung tin và nghĩ rằng đó là yêu cầu ngắt kết nối từ client.
- Sau khi đã ngắt kết nối của một người dùng, kẻ tấn công tiếp tục thực hiện tương tự với các client còn lại làm cho các client tự động ngắt kết nối với điểm truy cập.



- Khi các người dùng bị ngắt kết nối sẽ thực hiện kết nối lại với điểm truy cập ngay lập tức. Kẻ tấn công tiếp tục gửi các khung tin yêu cầu ngắt kết nối với mục đích phá hoại kết nối giữa người dùng và điểm truy cập.

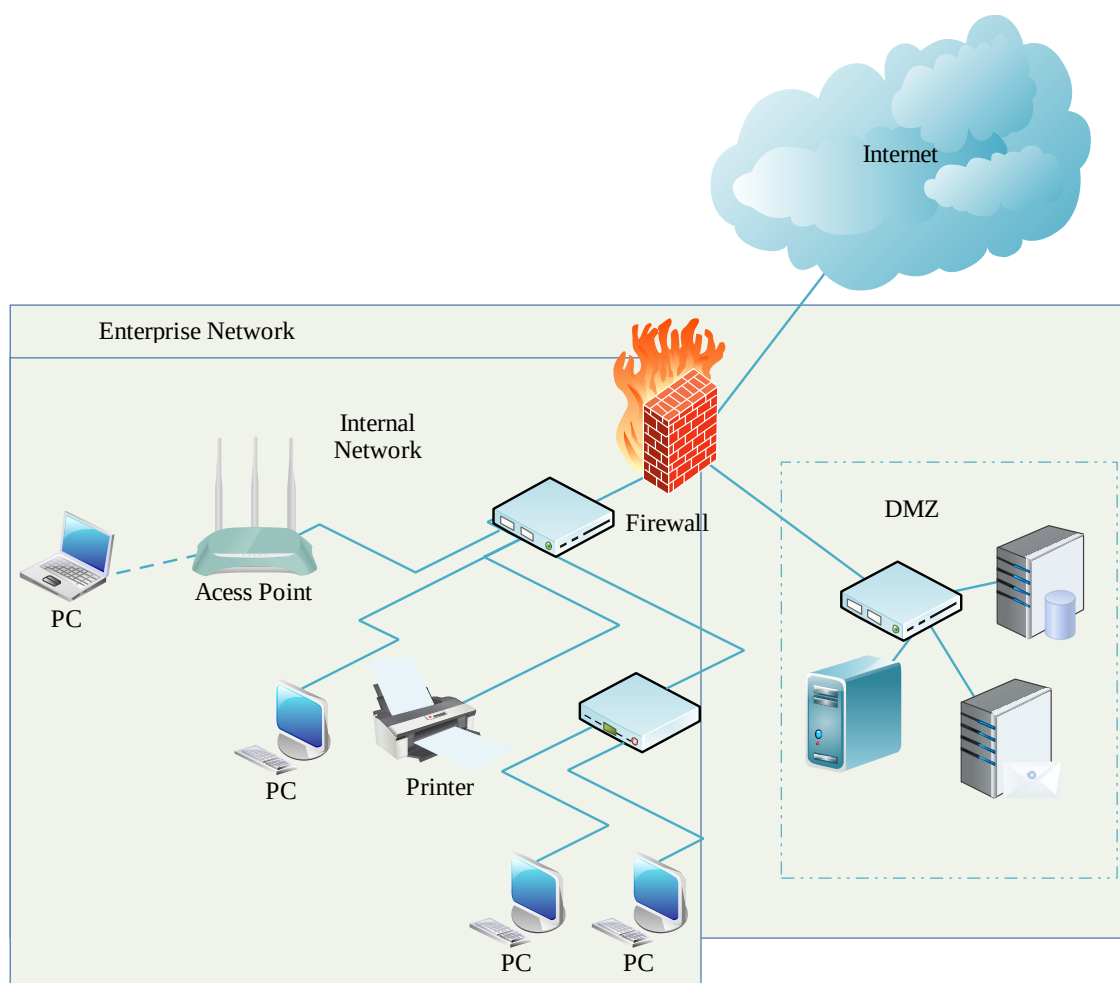
6.4 Firewall

6.4.1 Khái niệm

Tường lửa (Firewall) là một kỹ thuật được tích hợp vào hệ thống mạng nhằm kiểm soát luồng dữ liệu đi qua nó.

Trên thực tế, tường lửa có thể là một thiết bị phần cứng hoặc một phần mềm hoạt động trong một môi trường máy tính nối mạng để ngăn chặn một số liên lạc bị cấm bởi chính sách an ninh của cá nhân hay tổ chức, việc này tương tự với hoạt động của các tường ngăn lửa trong các tòa nhà.

Thông thường trong một hệ thống mạng doanh nghiệp sử dụng tường lửa được chia thành 3 loại mạng: Internet, mạng nội bộ (LAN) và mạng DMZ (Demilitarized Zone).



Hình 6-15: Mô hình mạng sử dụng tường lửa

Tường lửa sẽ thực hiện các công việc:

- Cấm hoặc cho phép các dịch vụ hoạt động truy cập giữa 3 vùng (từ mạng trong ra ngoài và từ ngoài vào trong);
- Theo dõi luồng dữ liệu qua lại giữa 3 vùng;
- Cấm hoặc cho phép địa chỉ nào được truy cập, truy cập dịch vụ gì giữa 3 vùng;
- Kiểm soát thông tin qua lại giữa 3 vùng.

6.4.2 Nguyên lý hoạt động của tường lửa

Trên tường lửa, người quản trị cấu hình các luật (Rules) lọc gói tin để dựa vào đó tường lửa kiểm tra và đưa ra các hành động (Actions) tương ứng. Các luật lọc gói tin được tạo dựa theo thông tin phần tiêu đề (Header) ở mỗi gói tin. Các thông tin đó thường bao gồm:

- Địa chỉ IP nguồn, cổng nguồn;
- Địa chỉ IP đích, cổng đích;
- Kiểu giao thức (TCP, UDP, ICMP....);
- Chiều vào của gói tin;
- Chiều ra của gói tin.

Những gói tin thỏa mãn luật lọc sẽ được tường lửa áp dụng các hành động tương ứng đối với luật đó (cho phép đi qua hoặc loại bỏ gói tin đó), nếu không thỏa mãn một luật nào gói tin đó sẽ bị loại bỏ.

Cấu trúc luật của tường lửa thông thường gồm các thông tin: Cho phép hay không cho phép, giao thức gì, từ đâu, đến đâu và đối tượng áp dụng là ai.

Oder	Name	Action	Protocol	From	Listner To	Conditions
2	Deny	Deny	All Outbound traffics	All Networks (and LocalHost)	All Networks (and LocalHost)	Dungnt
1	Access All	Allow	All Outbound traffics	All Networks (and LocalHost)	All Networks (and LocalHost)	All Users



Last	Default rule	Deny	All Outbound traffics	All Networks (and LocalHost)	All Networks (and LocalHost)	All Users
------	--------------	------	-----------------------	------------------------------	------------------------------	-----------

Hình 6-16: Cấu trúc lọc của tường lửa trên ISA 2006

6.4.3 Giải pháp tường lửa cho doanh nghiệp

Trên thực tế, việc lựa chọn loại tường lửa nào cho phù hợp với mục đích của doanh nghiệp phụ thuộc vào rất nhiều yếu tố, cần phải đặc biệt chú ý đến những yếu tố sau:

- Chi phí mà doanh nghiệp bỏ ra để triển khai hệ thống tường lửa: Đây là yếu tố quan trọng nhất để có thể lựa chọn được “loại” hoặc công nghệ tường lửa sẽ triển khai vào hệ thống mạng của công ty, doanh nghiệp;
- Lưu lượng mạng mà tường lửa sẽ phải xử lý;
- Mô hình tường lửa mà công ty sẽ triển khai;
- Các loại lưu lượng mà tường lửa có thể xử lý: thông thường các loại tường lửa trên thị trường bây giờ đều có tính năng lọc gói, lọc giao thức và lọc ứng dụng;
- Các công nghệ mà tường lửa tích hợp thêm: hiện nay, hầu hết các tường lửa đều có tích hợp thêm một số công nghệ để tăng cường khả năng “bảo vệ” cho hệ thống mạng như: VPN Server, IDS, IPS, Proxy ...
- Các công nghệ đang được sử dụng tại công ty, doanh nghiệp.

Dưới đây là một số mô hình và giải pháp tường lửa thường sử dụng cho các công ty, doanh nghiệp:

a) Sử dụng tường lửa mềm TMG/ISA 2006, IP tables/IP Cop ...

TMG/ISA 2006 hoặc IP tables/IP Cop là loại tường lửa mềm (chương trình phần mềm được cài đặt trên hệ điều hành windows/linux có tính năng tường lửa) được sử dụng phổ biến cho các doanh nghiệp vừa và nhỏ chi phí đầu tư ít tốn kém mà vẫn đáp ứng được các yêu cầu cơ bản như: bảo vệ được các cuộc tấn công từ bên ngoài, giám sát được hoạt động của hệ thống, quản lý được việc truy cập Internet của người dùng bên trong.

b) Sử dụng tường lửa cứng PIX515, ASA505, NetScreen 5200...

Với các mô hình mạng của các doanh nghiệp lớn như các nhà cung cấp dịch vụ, các ngân hàng, các công ty nước ngoài thì tường lửa cứng là sự lựa chọn tối ưu. Tường



lửa cứng hoạt động ổn định hơn, bảo vệ được hệ thống mạng khỏi các cuộc tấn công từ bên ngoài tốt hơn, có đầy đủ các tính năng của tường lửa mềm và hoạt động hiệu quả hơn tường lửa mềm.

6.5 Chính sách an toàn và bảo mật thông tin trong doanh nghiệp

6.5.1 Các chính sách an toàn và bảo mật

a) Mục đích

Để doanh nghiệp có thể tồn tại và phát triển với quy mô rộng hơn, lợi nhuận thu được nhiều hơn thì việc đưa ra các chính sách an toàn và bảo mật thông tin trong doanh nghiệp là điều hết sức quan trọng và cần thiết. Bạn hãy hình dung, điều gì sẽ xảy ra nếu các tài liệu liên quan đến kế hoạch phát triển và sản xuất của doanh nghiệp mình bị lộ ra bên ngoài và rơi vào tay đối thủ cạnh tranh hay một ngày nào đó hệ thống mạng của bạn bị tấn công làm cho các máy chủ và hệ thống mạng của bạn bị tê liệt không thể hoạt động. Hậu quả sẽ thật khó tưởng tượng, đó là lý do mà hầu hết các doanh nghiệp đều cố gắng đưa ra những “quy tắc, quy trình và những hướng dẫn cụ thể trong việc vận hành và khai thác thông tin trên mạng” nhằm:

- Đảm bảo tính bí mật thông tin cho doanh nghiệp;
- Đảm bảo tính an toàn thông tin cho doanh nghiệp;
- Xây dựng một môi trường thông tin an toàn trong doanh nghiệp.

b) Một số chính sách quan trọng

Để xây dựng được một môi trường thông tin an toàn cho doanh nghiệp mình thì doanh nghiệp đó phải đưa ra các chính sách bảo mật tối ưu, phù hợp. Ngoài ra cần sự kết hợp, hỗ trợ toàn diện và triệt để từ phía nhiều phía trong tổ chức doanh nghiệp từ người dùng đến người quản lý.

- Chính sách nhà quản trị

Người quản trị phải là người hiểu rõ những rủi ro và là người trực tiếp chịu trách nhiệm về vấn đề bảo mật và an toàn của thông tin trong doanh nghiệp mình. Chính vì vậy mà nhà quản trị cần đưa ra các quy tắc, quy trình cụ thể cho việc quản lý, theo dõi, sao lưu và nâng cấp hạ tầng công nghệ thông tin của doanh nghiệp mình một cách kịp thời và phù hợp với từng hoàn cảnh và giai đoạn phát triển của doanh nghiệp cụ thể.

- Yêu cầu thiết kế

Doanh nghiệp cần xây dựng cho mình một hạ tầng hệ thống công nghệ thông tin phục vụ tốt các nhu cầu của người dùng đồng thời thúc đẩy được sự phát triển của công ty. Bên cạnh đó hệ thống cần có khả năng đối phó được với các rủi ro về khả

năng mất an toàn của thiết bị và dữ liệu. Do đó ngay từ khâu thiết kế hạ tầng công nghệ thông tin ban đầu, doanh nghiệp cần đưa ra các yêu cầu bảo mật cụ thể và nghiêm ngặt nhất để vừa đảm bảo hệ thống hoạt động ổn định vừa đảm bảo tính an toàn của thông tin, đưa ra các quy trình vận hành và khai thác hệ thống công nghệ thông tin cụ thể, xây dựng các hệ thống có tính bảo mật cao.

- Kế hoạch khôi phục sau một biến cố

Không doanh nghiệp nào muốn hệ thống của mình gặp sự cố, họ càng không muốn dữ liệu của mình bị mất nhưng những rủi ro đó luôn luôn có nguy cơ xảy ra.

Có rất nhiều doanh nghiệp đã gặp các sự cố như hệ thống của mình bị tấn công, dữ liệu của mình bị mất và họ đã phải tốn rất nhiều tiền để khôi phục lại hệ thống cũng như lấy lại dữ liệu của mình.

Việc khôi phục lại hoạt động của toàn bộ hệ thống cũng như khôi phục lại toàn bộ dữ liệu ban đầu là một thách thức lớn đối với các chuyên gia công nghệ thông tin và không phải lúc nào cũng thành công

Các công ty lớn đề sẵn sàng đầu tư một số tiền lớn để thực hiện việc kiểm tra sao lưu, thiết lập hệ thống dự phòng với mong muốn hệ thống mạng của mình hoạt động liên tục, có khả năng dự phòng và các thông tin trên hệ thống được đảm bảo sự an toàn và bảo mật.

- Chính sách thông tin

Bên cạnh việc bảo mật thông tin thì việc phân loại, đánh dấu và lưu trữ thông tin trong doanh nghiệp là việc hết sức cần thiết. Cần phân loại những thông tin quan trọng và không quan trọng ra. Những thông tin nhạy cảm có thể tiêu hủy để đảm bảo tính bí mật. Việc phân loại, đánh dấu và lưu trữ thông tin thông qua các chính sách càng tốt thì thông tin sẽ càng an toàn hơn.

- Chính sách về cách sử dụng

Đưa ra các quy định về sự riêng tư, quyền sở hữu và những hậu quả khi có những hành động không hợp pháp.

Hướng dẫn người dùng sử dụng máy tính an toàn như: đặt mật khẩu bảo mật cho máy tính, không truy cập vào những trang website không tin tưởng....

Hướng dẫn người dùng sử dụng Internet và truy cập Mail an toàn

- Chính sách quản lý người dùng

Chia người dùng ra thành nhóm người dùng và giới hạn quyền cho từng nhóm người dùng cụ thể.



Đưa ra các luật và chính sách cho người dùng để tránh các rủi ro và nguy cơ mất an toàn của hệ thống.

- Chính sách bảo mật

Cấu hình các chính sách bảo mật cho hệ thống mạng để hệ thống được bảo mật và tối ưu nhất như:

- + Lắp đặt thêm các thiết bị phần cứng có chức năng bảo mật;
- + Sử dụng các phần mềm an toàn, có bản quyền;
- + Cài đặt các phần mềm diệt virus;
- + Sử dụng các công nghệ và cài đặt các giao thức mạng có tính bảo mật cao;
- + Sử dụng các thuật toán và phương pháp mã hóa.

6.5.2 Quản lý rủi ro

a) Vấn đề rủi ro của thông tin trong doanh nghiệp

Hệ thống của các doanh nghiệp luôn phải đối diện với các nguy cơ về bảo mật như các cuộc tấn công từ bên ngoài hoặc thậm chí là những nguy cơ bảo mật đối với hệ thống mạng bên trong của mình do đó việc các doanh nghiệp xác định được các rủi ro có thể xảy ra, đưa ra độ rủi ro có thể chấp nhận được với từng rủi ro đối với hệ thống mạng của mình là việc hết sức cần thiết. Có như vậy họ mới có cơ sở để từ đó đưa ra các giải pháp bảo toàn bộ hệ thống thông tin của mình.

Bất kỳ hệ thống của doanh nghiệp nào cũng có những rủi ro nhất định. Chúng ta có thể đánh giá độ an toàn của hệ thống mạng doanh nghiệp thông qua cơ sở hạ tầng thông tin mà doanh nghiệp đã xây dựng hoặc thông qua có sự cố mà hệ thống gặp phải thông qua quá trình vận hành

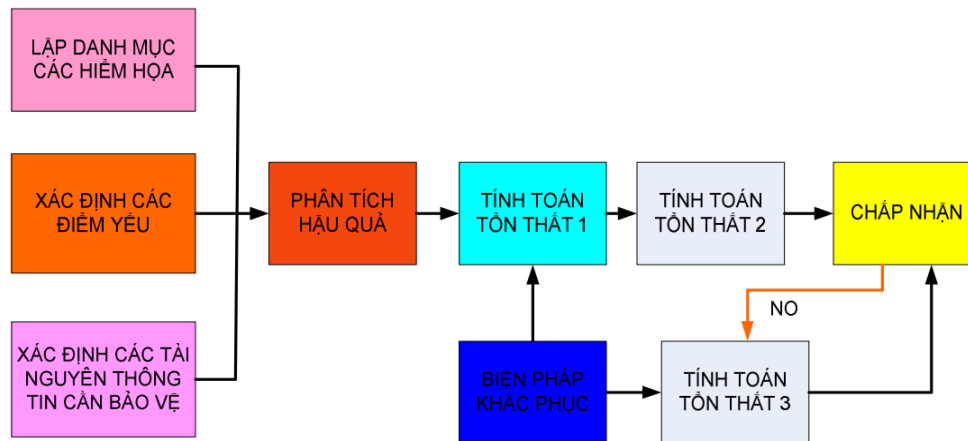
Thông thường hệ thống thông tin của các doanh nghiệp lớn thường:

- Được đầu tư nhiều tiền của cho các thiết bị, công nghệ để xây dựng lên được một môi trường an toàn thông tin nhằm ngăn ngừa tối đa các rủi ro có thể gặp phải;
- Đưa ra các chính sách an toàn thông tin cụ thể và yêu cầu tất cả các đối tượng đều phải tuân thủ nghiêm ngặt;
- Được quản lý bởi các chuyên gia, họ là người trực tiếp vận hành, theo dõi hoạt động của hệ thống từ đó phân tích để tìm ra các điểm yếu của hệ tầng công nghệ thông tin trên cơ sở đó lựa chọn các giải pháp tối ưu nhằm ngăn chặn hoặc giảm thiểu rủi ro đến mức có thể chấp nhận được.



b) Quy trình phân tích rủi ro

Để có thể xây dựng được một hệ thống thông tin đảm bảo tính an toàn và bảo mật và hạn chế được những rủi ro đến mức có thể chấp nhận được thì các doanh nghiệp cần đưa ra quy trình phân tích rủi ro phù hợp và phải tuân thủ một cách nghiêm ngặt có như vậy độ bảo mật và an toàn của hệ thống sẽ cao hơn.



Hình 6-17: Quy trình phân tích rủi ro

- Xác định các hiểm họa có thể xảy ra với hệ thống thông tin của mình đặc biệt là các thông tin có giá trị để tránh rủi ro như mất thông tin, thông tin bị lộ ra bên ngoài;
- Xác định các điểm yếu của hệ thống và đề xuất các thiết bị phần cứng và phần mềm cần thiết;
- Xác định các tài nguyên thông tin cần bảo vệ: Đánh giá phân loại các thông tin quan trọng để xây dựng kế hoạch bảo vệ và giảm thiểu rủi ro đến mức có thể chấp nhận được;
- Phân tích hậu quả: Từ các hiểm họa và điểm yếu của hạ tầng phân tích các hậu quả để biết được những tổn thất về mất an toàn và bảo mật thông tin có thể gặp phải để có giải pháp ngăn chặn kịp thời. Nếu tổn thất là quá lớn và ảnh hưởng nghiêm trọng đến doanh nghiệp mình thì cần có biện pháp khắc phục ngay, các tổn thất không nghiêm trọng và không ảnh hưởng nhiều thì tiếp tục theo dõi và khắc phục nếu cần.

Các chuyên gia thường dựa vào quy trình phân tích rủi ro này để phân tích hậu quả và tính toán những tổn thất, mất mát an toàn thông tin từ đó đưa ra những giải pháp kịp thời chẳng hạn như chuyên gia an ninh mạng sẽ:



- Xác định các hiểm họa bằng cách tìm ra những lỗ hổng bảo mật, các phần mềm độc hại, các chính sách không hợp lý trên hệ thống mạng mà kẻ tấn công có thể lợi dụng;
- Xác định các điểm yếu của các giao thức, các thiết bị phần cứng, phần mềm mà kẻ tấn công có thể thông qua đó thực hiện tấn công từ đó đề các chính sách, biện pháp cần thiết;
- Các tài nguyên thông tin cần được bảo vệ thường là các tài nguyên quan trọng như các máy chủ, hệ thống cơ sở dữ liệu của doanh nghiệp.

Sau đó sẽ tiến hành phân tích hậu quả có thể xảy ra để tính toán những tổn thất kéo theo nếu nghiêm trọng sẽ phải có biện pháp khắc phục ngay, nếu tổn thất ít chấp nhận được thì tiếp tục theo dõi. Ví dụ một doanh nghiệp bán hàng qua website mà website đó có các lỗ hổng mà kẻ tấn công có thể chiếm quyền điều khiển thì doanh nghiệp đó sẽ bị ảnh hưởng nghiêm trọng đến uy tín và công việc kinh doanh của mình thì cần phải tìm lỗ hổng và khắc phục ngay.

6.6 Câu hỏi và bài tập

6.6.1 Câu hỏi

6.1) Phần mềm độc hại là gì? Virus tin học là gì? Có những chủng loại virus nào? Hãy nêu rõ cách tấn công của các loại virus thường gặp và biện pháp phòng chống.

6.2) Tấn công DoS và DDoS là loại tấn công như thế nào? Có thể phòng chống được không và như thế nào?

6.3) Tường lửa là gì? Hãy nêu các nguyên lý hoạt động của tường lửa.



Phụ lục 1. Các hoán vị và hộp S của DES

Hoán vị khởi tạo IP

IP							
58	50	42	34	26	18	10	2
60	52	44	36	28	20	12	4
62	54	46	38	30	22	14	6
64	56	48	40	32	24	16	8
57	49	41	33	25	17	9	1
59	51	43	35	27	19	11	3
61	53	45	37	29	21	13	5
63	55	47	39	31	23	15	7

Hoán vị kết thúc $FP = IP^{-1}$

IP^{-1}							
40	8	48	16	56	24	64	32
39	7	47	15	55	23	63	31
38	6	46	14	54	22	62	30
37	5	45	13	53	21	61	29
36	4	44	12	52	20	60	28
35	3	43	11	51	19	59	27
34	2	42	10	50	18	58	26
33	1	41	9	49	17	57	25



Phép mở rộng 32 bits thành 48 bits

E					
32	1	2	3	4	5
4	5	6	7	8	9
8	9	10	11	12	13
12	13	14	15	16	17
16	17	18	19	20	21
20	21	22	23	24	25
24	25	26	27	28	29
28	29	30	31	32	1

Các hộp S

Cột	Hàng															
	[0]	[1]	[2]	[3]	[4]	[5]	[6]	[7]	[8]	[9]	[10]	[11]	[12]	[13]	[14]	[15]
S_1																
[0]	14	4	13	1	2	15	11	8	3	10	6	12	5	9	0	7
[1]	0	15	7	4	14	2	13	1	10	6	12	11	9	5	3	8
[2]	4	1	14	8	13	6	2	11	15	12	9	7	3	10	5	0
[3]	15	12	8	2	4	9	1	7	5	11	3	14	10	0	6	13
S_2																
[0]	15	1	8	14	6	11	3	4	9	7	2	13	12	0	5	10
[1]	3	13	4	7	15	2	8	14	12	0	1	10	6	9	11	5
[2]	0	14	7	11	10	4	13	1	5	8	12	6	9	3	2	15
[3]	13	8	10	1	3	15	4	2	11	6	7	12	0	5	14	9
S_3																
[0]	10	0	9	14	6	3	15	5	1	13	12	7	11	4	2	8
[1]	13	7	0	9	3	4	6	10	2	8	5	14	12	11	15	1
[2]	13	6	4	9	8	15	3	0	11	1	2	12	5	10	14	7
[3]	1	10	13	0	6	9	8	7	4	15	14	3	11	5	2	12
S_4																
[0]	7	13	14	3	0	6	9	10	1	2	8	5	11	12	4	15
[1]	13	8	11	5	6	15	0	3	4	7	2	12	1	10	14	9
[2]	10	6	9	0	12	11	7	13	15	1	3	14	5	2	8	4
[3]	3	15	0	6	10	1	13	8	9	4	5	11	12	7	2	14



S ₅																
[0]	2	12	4	1	7	10	11	6	8	5	3	15	13	0	14	9
[1]	14	11	2	12	4	7	13	1	5	0	15	10	3	9	8	6
[2]	4	2	1	11	10	13	7	8	15	9	12	5	6	3	0	14
[3]	11	8	12	7	1	14	2	13	6	15	0	9	10	4	5	3
S ₆																
[0]	12	1	10	15	9	2	6	8	0	13	3	4	14	7	5	11
[1]	10	15	4	2	7	12	9	5	6	1	13	14	0	11	3	8
[2]	9	14	15	5	2	8	12	3	7	0	4	10	1	13	11	6
[3]	4	3	2	12	9	5	15	10	11	14	1	7	6	0	8	13
S ₇																
[0]	4	11	2	14	15	0	8	13	3	12	9	7	5	10	6	1
[1]	13	0	11	7	4	9	1	10	14	3	5	12	2	15	8	6
[2]	1	4	11	13	12	3	7	14	10	15	6	8	0	5	9	2
[3]	6	11	13	8	1	4	10	7	9	5	0	15	14	2	3	12
S ₈																
[0]	13	2	8	4	6	15	11	1	10	9	3	14	5	0	12	7
[1]	1	15	13	8	10	3	7	4	12	5	6	11	0	14	9	2
[2]	7	11	4	1	9	12	14	2	0	6	10	13	15	3	5	8
[3]	2	1	14	7	4	10	8	13	15	12	9	0	3	5	6	11



Ví dụ về mã hóa DES

Sử dụng DES để mã hóa:

Bản rõ: "0123456789ABCDEF"

Khoá (ở dạng thập phân): "133457799BBCDFFI".

Các bước thực hiện

16 vòng mã hoá được thực hiện như sau:

Chuyển khóa sang nhị phân (không có bit kiểm tra):

0001001001101001010110111100100110110111101101111111000

Hoán vị khởi tạo IP, chia thành hai nửa trái và phải L_0 và R_0 :

$L_0 =$ 11001100000000001100110011111111

$L_0 = R_0 =$ 11110000101010101111000010101010

Vòng 1

$E(R_0)$ 011110100001010101010101011110100001010101010101

K_1 00011011000000101110111111111000111000001110010

$E(R_0) \oplus K_1$ 011000010001011110111010100001100110010100100111

Đầu ra S-Box 01011100100000101011010110010111

$F(R_0, K_1)$ 00100011010010101010100110111011

$L_2 = R_1$ 11101111010010100110010101000100

Vòng 2

$E(R_1)$ 011101011110101001010100001100001010101000001001

K_2 011110011010111011011001110110111100100111100101

$E(R_1) \oplus K_2$ 000011000100010010001101111010110110001111101100

Đầu ra S-Box 11111000110100000011101010101110

$F(R_1, K_2)$ 00111100101010111000011110100011

$L_3 = R_2$ 11001100000000010111011100001001

Vòng 3

$E(R_2)$ 111001011000000000000010101110101110100001010011

K_3 010101011111110010001010010000101100111110011001

$E(R_2) \oplus K_3$ 101100000111110010001000111110000010011111001010

Đầu ra S-Box 00100111000100001110000101101111

$F(R_2, K_3)$ 01001101000101100110111010110000

$L_4 = R_3$ 101000100101111000000101111110100



Vòng 4

$E(R_3)$	01010000010000101111100000000101011111110101001
K_4	011100101010110111010110110110011010100011101
$E(R_3) \oplus K_4$	0010001011101111001011101101111001001010110100
Đầu ra S-Box	00100001111011011001111100111010
$F(R_3, K_4)$	10111011001000110111011101001100
$L_5 = R_4$	01110111001000100000000001000101

Vòng 5

$E(R_4)$	101110101110100100000100000000000000000001000001010
K_5	011111001110110000000111111010110101001110101000
$E(R_4) \oplus K_5$	110001100000010100000011111010110101000110100010
Đầu ra S-Box	01010000110010000011000111101011
$F(R_4, K_5)$	00101000000100111010110111000011
$L_6 = R_5$	10001010010011111010011000110111

Vòng 6

$E(R_5)$	11000101010000100101111110100001100000110101111
K_6	011000111010010100111110010100000111101100101111
$E(R_5) \oplus K_6$	101001101110011101100001100000001011101010000000
Đầu ra S-Box	01000001111100110100110000111101
$F(R_5, K_6)$	10011110010001011100110100101100
$L_7 = R_6$	11101001011001111100110101101001

Vòng 7

$E(R_6)$	11110101001010110000111111001011010101101010011
K_7	11101100100001001011011111101100001100010111100
$E(R_6) \oplus K_7$	000110011010111110111000000100111011001111101111
Đầu ra S-Box	00010000011101010100000010101101
$F(R_6, K_7)$	10001100000001010001110000100111
$L_8 = R_7$	00000110010010101011101000010000

Vòng 8

$E(R_7)$	000000001100001001010101010111110100000010100000
K_8	111101111000101000111010110000010011101111111011
$E(R_7) \oplus K_8$	111101110100100001101111100111100111101101011011
Đầu ra S-Box	01101100000110000111110010101110
$F(R_7, K_8)$	00111100000011101000011011111001
$L_9 = R_8$	11010101011010010100101110010000



Vòng 9

$E(R_8)$	011010101010101101010010101001010111110010100001
K_9	111000001101101111101011111011011110011110000001
$E(R_8) \oplus K_9$	100010100111000010111001010010001001101100100000
Đầu ra S-Box	00010001000011000101011101110111
$F(R_8, K_9)$	00100010001101100111110001101010
$L_{10} = R_9$	00100100011111001100011001111010

Vòng 10

$E(R_9)$	000100001000001111111001011000001100001111110100
K_{10}	101100011111001101000111101110100100011001001111
$E(R_9) \oplus K_{10}$	101000010111000010111110110110101000010110111011
Đầu ra S-Box	11011010000001000101001001110101
$F(R_9, K_{10})$	01100010101111001001110000100010
$L_{11} = R_{10}$	10110111110101011101011110110010

Vòng 11

$E(R_{10})$	010110101111111010101011111010101111110110100101
K_{11}	001000010101111111010011110111101101001110000110
$E(R_{10}) \oplus K_{11}$	011110111010000101111000001101000010111000100011
Đầu ra S-Box	01110011000001011101000100000001
$f(R_{10}, K_{11})$	11100001000001001111101000000010
$L_{12} = R_{11}$	11000101011110000011110001111000

Vòng 12

$E(R_{11})$	011000001010101111110000000111111000001111110001
K_{12}	011101010111000111110101100101000110011111101001
$E(R_{11}) \oplus K_{12}$	000101011101101000000101100010111110010000011000
Đầu ra S-Box	01111011100010110010011000110101
$F(R_{11}, K_{12})$	11000010011010001100111111101010
$L_{13} = R_{12}$	01110101101111010001100001011000

Vòng 13

$E(R_{12})$	001110101011110111111010100011110000001011110000
K_{13}	100101111100010111010001111110101011101001000001
$E(R_{12}) \oplus K_{13}$	101011010111100000101011011101011011100010110001
Đầu ra S-Box	10011010110100011000101101001111
$F(R_{12}, K_{13})$	11011101101110110010100100100010
$L_{14} = R_{13}$	00011000110000110001010101011010



Vòng 14

$E(R_{13})$	0000111100010110000001101000101010101011110100
K_{14}	010111110100001110110111111100101110011100111010
$E(R_{13}) \oplus K_{14}$	010100000101010110110001011110000100110111001110
Đầu ra S-Box	01100100011110011001101011110001
$F(R_{13}, K_{14})$	10110111001100011000111001010101
$L_{15} = R_{14}$	11000010100011001001011000001101

Vòng 15

$E(R_{14})$	111000000101010001011001010010101100000001011011
K_{15}	101111111001000110001101001111010011111100001010
$E(R_{14}) \oplus K_{15}$	01011111110001011101010001110111111111101010001
Đầu ra S-Box	10110010111010001000110100111100
$F(R_{14}, K_{15})$	01011011100000010010011101101110
$L_{16} = R_{15}$	01000011010000100011001000110100

Vòng 16

$E(R_{15})$	001000000110101000000100000110100100000110101000
K_{16}	110010110011110110001011000011100001011111110101
$E(R_{15}) \oplus K_{16}$	111010110101011110001111000101000101011001011101
Đầu ra S-Box	10100111100000110010010000101001
$F(R_{15}, K_{16})$	11001000110000000100111110011000
R_{16}	00001010010011001101100110010101

Cuối cùng, sử dụng hoán vị FP (IP^{-1}) để hoán vị $R_{16}L_{16}$, bản mã (ở dạng Hecxa) của bản rõ “0123456789ABCDEF” là “85E813540F0AB405”.



Phụ lục 2. Ví dụ về hàm băm SHA512

Sử dụng hàm băm SHA512 băm một thông điệp đơn giản chỉ gồm 3 ký tự "abc"

Bảng PL2-1 liệt kê 80 hằng số K_t được sử dụng trong SHA512. Các hằng số này là 64 bits đầu tiên thuộc phần thập phân của căn bậc ba của số nguyên tố thứ t trong 80 số nguyên tố đầu tiên.

Bảng PL2-1: Các hằng số K_t ($t=0, 1, \dots, 79$) trong SHA512

428a2f98d728ae22 7137449123ef65cd b5c0fbcfec4d3b2f e9b5dba58189dbbc	3956c25bf348b538 59f111f1b605d019 923f82a4af194f9b ab1c5ed5da6d8118	d807aa98a3030242 12835b0145706fbe 243185be4ee4b28c 550c7dc3d5ffb4e2	72be5d74f27b896f 80deb1fe3b1696b1 9bdc06a725c71235 c19bf174cf692694
e49b69c19ef14ad2 efbe4786384f25e3 0fc19dc68b8cd5b5 240ca1cc77ac9c65	2de92c6f592b0275 4a7484aa6ea6e483 5cb0a9dcdb41fbd4 76f988da831153b5	983e5152ee66dfab a831c66d2db43210 b00327c898fb213f bf597fc7beef0ee4	c6e00bf33da88fc2 d5a79147930aa725 06ca6351e003826f 142929670a0e6e70
27b70a8546d22ffc 2e1b21385c26c926 4d2c6dfc5ac42aed 53380d139d95b3df	650a73548baf63de 766a0abb3c77b2a8 81c2c92e47edae6 92722c851482353b	a2bfe8a14cf10364 a81a664bbc423001 c24b8b70d0f89791 c76c51a30654be30	d192e819d6ef5218 d69906245565a910 f40e35855771202a 106aa07032bbd1b8
19a4c116b8d2d0c8 1e376c085141ab53 2748774cdf8eeb99 34b0bcb5e19b48a8	391c0cb3c5c95a63 4ed8aa4ae3418acb 5b9cca4f7763e373 682e6ff3d6b2b8a3	748f82ee5defb2fc 78a5636f43172f60 84c87814a1f0ab72 8cc702081a6439ec	90befffa23631e28 a4506cebd82bde9 bef9a3f7b2c67915 c67178f2e372532b
ca273eceeaa26619c d186b8c721c0c207 eada7dd6cde0eb1e f57d4f7fee6ed178	06f067aa72176fba 0a637dc5a2c898a6 113f9804bef90dae 1b710b35131c471b	28db77f523047d84 32caab7b40c72493 3c9ebe0a15c9bebc 431d67c49c100d4c	4cc5d4becb3e42b6 597f299cfc657e2a 5fcb6fab3ad6faec 6c44198c4a475817

Sau khi nhồi thêm, thông điệp "abc" trở thành một khối dữ liệu 1024 bits được viết dưới dạng hexa như trong Bảng PL2-2. Trong đó, từ 32 bits thứ nhất chứa các chữ abc (mã hexa của a là 61, của b là 62 và của c là 63), sau đó đến hai số hexa 80_H = 1000 0000, nghĩa là ngay sau thông điệp sẽ chèn thêm 1 bit 1, theo sau là các bits 0 cho đến khi còn lại 64 bits cuối cùng sẽ dùng để chứa độ dài của thông điệp. 64 bits



cuối cùng trong Bảng 5.2 là $00000000\ 00000018_H = 24$. Đây chính là độ dài tính theo bit của thông điệp gồm 3 chữ ($3\ \text{chữ} * 8\ \text{bit/chữ} = 24\ \text{bits}$).

Bảng PL2-2: Thông điệp "abc" được nhồi thêm thành 1024 bits

```
61626380 00000000 00000000 00000000 00000000 00000000 00000000 00000000
00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000018
```

Bảng PL2-3 là giá trị của các thanh ghi được khởi tạo ban đầu ($t=0$) và được tính bằng các bước lặp trong qui trình băm khối dữ liệu $M_0 = 1024$ bits. Trong đó, hai dòng đầu là giá trị khởi tạo của các thanh ghi a, b, c, d (dòng thứ nhất) và e, f, g, h (dòng thứ hai). Tiếp theo, với mỗi $t = (0, 1, \dots, 79)$ là các giá trị trung gian tương ứng của các thanh ghi ở bước t .

Bảng PL2-3 Các bước lập tính giá trị của các thanh ghi a, b, ..., h

	a/e	b/f	c/g	d/h
Khởi tạo	6a09e667f3bcc908	bb67ae8584caa73b	3c6ef372fe94f82b	a54ff53a5f1d36f1
t= 0	510e527fade682d1	9b05688c2b3e6c1f	1f83d9abfb41bd6b	5be0cd19137e2179
t= 1	f6afceb8bcfcddf5	6a09e667f3bcc908	bb67ae8584caa73b	3c6ef372fe94f82b
t= 2	58cb02347ab51f91	510e527fade682d1	9b05688c2b3e6c1f	1f83d9abfb41bd6b
t= 3	1320f8c9fb872cc0	f6afceb8bcfcddf5	6a09e667f3bcc908	bb67ae8584caa73b
t= 4	c3d4ebfd48650ffa	58cb02347ab51f91	510e527fade682d1	9b05688c2b3e6c1f
t= 5	ebcfff07203d91f3	1320f8c9fb872cc0	f6afceb8bcfcddf5	6a09e667f3bcc908
t= 6	dfa9b239f2697812	c3d4ebfd48650ffa	58cb02347ab51f91	510e527fade682d1
t= 7	5a83cb3e80050e82	ebcfff07203d91f3	1320f8c9fb872cc0	f6afceb8bcfcddf5
t= 8	0b47b4bb1928990e	dfa9b239f2697812	c3d4ebfd48650ffa	58cb02347ab51f91
t= 9	b680953951604860	5a83cb3e80050e82	ebcfff07203d91f3	1320f8c9fb872cc0
t= 10	745aca4a342ed2e2	0b47b4bb1928990e	dfa9b239f2697812	c3d4ebfd48650ffa
t= 11	af573b02403e89cd	b680953951604860	5a83cb3e80050e82	ebcfff07203d91f3
t= 12	96f60209b6dc35ba	745aca4a342ed2e2	0b47b4bb1928990e	dfa9b239f2697812
t= 13	c4875b0c7abc076b	af573b02403e89cd	b680953951604860	5a83cb3e80050e82
t= 14	5a6c781f54dcc00c	96f60209b6dc35ba	745aca4a342ed2e2	0b47b4bb1928990e
t= 15	8093d195e0054fa3	c4875b0c7abc076b	af573b02403e89cd	b680953951604860
t= 16	86f67263a0f0ec0a	5a6c781f54dcc00c	96f60209b6dc35ba	745aca4a342ed2e2
t= 17	f1eca5544cb89225	8093d195e0054fa3	c4875b0c7abc076b	af573b02403e89cd
t= 18	d0403c398fc40002	86f67263a0f0ec0a	5a6c781f54dcc00c	96f60209b6dc35ba
t= 19	81782d4a5db48f03	f1eca5544cb89225	8093d195e0054fa3	c4875b0c7abc076b
t=20	00091f460be46c52	d0403c398fc40002	86f67263a0f0ec0a	5a6c781f54dcc00c
t=21	69854c4aa0f25b59	81782d4a5db48f03	f1eca5544cb89225	8093d195e0054fa3
t=22	d375471bde1ba3f4	00091f460be46c52	d0403c398fc40002	86f67263a0f0ec0a
t=23	db0a9963f80c2eaa	69854c4aa0f25b59	81782d4a5db48f03	f1eca5544cb89225
t=24	475975b91a7a462c	d375471bde1ba3f4	00091f460be46c52	d0403c398fc40002
t=25	5e41214388186c14	db0a9963f80c2eaa	69854c4aa0f25b59	81782d4a5db48f03
t=26	cdf3bfff2883fc9d9	475975b91a7a462c	d375471bde1ba3f4	00091f460be46c52
t=27	44249631255d2ca0	5e41214388186c14	db0a9963f80c2eaa	69854c4aa0f25b59
t=28	860acf9effba6f61	cdf3bfff2883fc9d9	475975b91a7a462c	d375471bde1ba3f4
t=29	fa967eed85a08028	44249631255d2ca0	5e41214388186c14	db0a9963f80c2eaa
t=30	874bfe5f6aae9f2f	860acf9effba6f61	cdf3bfff2883fc9d9	475975b91a7a462c
t=31	0ae07c86b1181c75	fa967eed85a08028	44249631255d2ca0	5e41214388186c14
t=32	a77b7c035dd4c161	874bfe5f6aae9f2f	860acf9effba6f61	cdf3bfff2883fc9d9



Giáo trình An toàn và bảo mật trong mạng máy tính

	a/e	b/f	c/g	d/h
t=16	caf81a425d800537 2deecc6b39d64d78	0ae07c86b1181c75 a77b7c035dd4c161	fa967eed85a08028 874bfe5f6aae9f2f	44249631255d2ca0 860acf9effba6f61
t=17	4725be249ad19e6b f47e8353f8047455	caf81a425d800537 2deecc6b39d64d78	0ae07c86b1181c75 a77b7c035dd4c161	fa967eed85a08028 874bfe5f6aae9f2f
t=18	3c4b4104168e3edb 29695fd88d81dbd0	4725be249ad19e6b f47e8353f8047455	caf81a425d800537 2deecc6b39d64d78	0ae07c86b1181c75 a77b7c035dd4c161
t=19	9a3fb4d38ab6cf06 f14998dd5f70767e	3c4b4104168e3edb 29695fd88d81dbd0	4725be249ad19e6b f47e8353f8047455	caf81a425d800537 2deecc6b39d64d78
t=20	8dc5ae65569d3855 4bb9e66d1145bfdc	9a3fb4d38ab6cf06 f14998dd5f70767e	3c4b4104168e3edb 29695fd88d81dbd0	4725be249ad19e6b f47e8353f8047455
t=21	da34d6673d452dcf 8e30ff09ad488753	8dc5ae65569d3855 4bb9e66d1145bfdc	9a3fb4d38ab6cf06 f14998dd5f70767e	3c4b4104168e3edb 29695fd88d81dbd0
t=22	3e2644567b709a78 0ac2b11da8f571c6	da34d6673d452dcf 8e30ff09ad488753	8dc5ae65569d3855 4bb9e66d1145bfdc	9a3fb4d38ab6cf06 f14998dd5f70767e
t=23	4f6877b58fe55484 c66005f87db55233	3e2644567b709a78 0ac2b11da8f571c6	da34d6673d452dcf 8e30ff09ad488753	8dc5ae65569d3855 4bb9e66d1145bfdc
t=24	9aff71163fa3a940 d3ecf13769180e6f	4f6877b58fe55484 c66005f87db55233	3e2644567b709a78 0ac2b11da8f571c6	da34d6673d452dcf 8e30ff09ad488753
t=25	0bc5f791f8e6816b 6ddf1fd7edccea336	9aff71163fa3a940 d3ecf13769180e6f	4f6877b58fe55484 c66005f87db55233	3e2644567b709a78 0ac2b11da8f571c6
t=26	884c3bc27bc4f941 e6e48c9a8e948365	0bc5f791f8e6816b 6ddf1fd7edccea336	9aff71163fa3a940 d3ecf13769180e6f	4f6877b58fe55484 c66005f87db55233
t=27	eab4a9e5771b8d09 09068a4e255a0dac	884c3bc27bc4f941 e6e48c9a8e948365	0bc5f791f8e6816b 6ddf1fd7edccea336	9aff71163fa3a940 d3ecf13769180e6f
t=28	e62349090f47d30a 0fcdf99710f21584	eab4a9e5771b8d09 09068a4e255a0dac	884c3bc27bc4f941 e6e48c9a8e948365	0bc5f791f8e6816b 6ddf1fd7edccea336
t=29	74bf40f869094c63 f0aec2fe1437f085	e62349090f47d30a 0fcdf99710f21584	eab4a9e5771b8d09 09068a4e255a0dac	884c3bc27bc4f941 e6e48c9a8e948365
t=30	4c4fbbb75f1873a6 73e025d91b9efea3	74bf40f869094c63 f0aec2fe1437f085	e62349090f47d30a 0fcdf99710f21584	eab4a9e5771b8d09 09068a4e255a0dac
t=31	ff4d3f1f0d46a736 3cd388e119e8162e	4c4fbbb75f1873a6 73e025d91b9efea3	74bf40f869094c63 f0aec2fe1437f085	e62349090f47d30a 0fcdf99710f21584
t=32	a0509015ca08c8d4 e1034573654a106f	ff4d3f1f0d46a736 3cd388e119e8162e	4c4fbbb75f1873a6 73e025d91b9efea3	74bf40f869094c63 f0aec2fe1437f085



	a/e	b/f	c/g	d/h
t=33	60d4e6995ed91fe6 efabbd8bf47c041a	a0509015ca08c8d4 e1034573654a106f	ff4d3f1f0d46a736 3cd388e119e8162e	4c4fbbb75f1873a6 73e025d91b9efea3
t=34	2c59ec7743632621 0fbae670fa780fd3	60d4e6995ed91fe6 efabbd8bf47c041a	a0509015ca08c8d4 e1034573654a106f	ff4d3f1f0d46a736 3cd388e119e8162e
t=35	1a081afc59fdbc2c f098082f502b44cd	2c59ec7743632621 0fbae670fa780fd3	60d4e6995ed91fe6 efabbd8bf47c041a	a0509015ca08c8d4 e1034573654a106f
t=36	88df85b0bbe77514 8fbfd0162bbf4675	1a081afc59fdbc2c f098082f502b44cd	2c59ec7743632621 0fbae670fa780fd3	60d4e6995ed91fe6 efabbd8bf47c041a
t=37	002bb8e4cd989567 66adcfa249ac7bbd	88df85b0bbe77514 8fbfd0162bbf4675	1a081afc59fdbc2c f098082f502b44cd	2c59ec7743632621 0fbae670fa780fd3
t=38	b3bb8542b3376de5 b49596c20feba7de	002bb8e4cd989567 66adcfa249ac7bbd	88df85b0bbe77514 8fbfd0162bbf4675	1a081afc59fdbc2c f098082f502b44cd
t=39	8e01e125b855d225 0c710a47ba6a567b	b3bb8542b3376de5 b49596c20feba7de	002bb8e4cd989567 66adcfa249ac7bbd	88df85b0bbe77514 8fbfd0162bbf4675
t=40	b01521dd6a6be12c 169008b3a4bb170b	8e01e125b855d225 0c710a47ba6a567b	b3bb8542b3376de5 b49596c20feba7de	002bb8e4cd989567 66adcfa249ac7bbd
t=41	e96f89dd48cbd851 f0996439e7b50cb1	b01521dd6a6be12c 169008b3a4bb170b	8e01e125b855d225 0c710a47ba6a567b	b3bb8542b3376de5 b49596c20feba7de
t=42	bc05ba8de5d3c480 639cb938e14dc190	e96f89dd48cbd851 f0996439e7b50cb1	b01521dd6a6be12c 169008b3a4bb170b	8e01e125b855d225 0c710a47ba6a567b
t=43	35d7e7f41defcbd5 cc5100997f5710f2	bc05ba8de5d3c480 639cb938e14dc190	e96f89dd48cbd851 f0996439e7b50cb1	b01521dd6a6be12c 169008b3a4bb170b
t=44	c47c9d5c7ea8a234 858d832ae0e8911c	35d7e7f41defcbd5 cc5100997f5710f2	bc05ba8de5d3c480 639cb938e14dc190	e96f89dd48cbd851 f0996439e7b50cb1
t=45	021fbadbabab5ac6 e95c2a57572d64d9	c47c9d5c7ea8a234 858d832ae0e8911c	35d7e7f41defcbd5 cc5100997f5710f2	bc05ba8de5d3c480 639cb938e14dc190
t=46	f61e672694de2d67 c6bc35740d8daa9a	021fbadbabab5ac6 e95c2a57572d64d9	c47c9d5c7ea8a234 858d832ae0e8911c	35d7e7f41defcbd5 cc5100997f5710f2
t=47	6b69fc1bb482feac 35264334c03ac8ad	f61e672694de2d67 c6bc35740d8daa9a	021fbadbabab5ac6 e95c2a57572d64d9	c47c9d5c7ea8a234 858d832ae0e8911c
t=48	571f323d96b3a047 271580ed6c3e5650	6b69fc1bb482feac 35264334c03ac8ad	f61e672694de2d67 c6bc35740d8daa9a	021fbadbabab5ac6 e95c2a57572d64d9
t=49	ca9bd862c5050918 dfe091dab182e645	571f323d96b3a047 271580ed6c3e5650	6b69fc1bb482feac 35264334c03ac8ad	f61e672694de2d67 c6bc35740d8daa9a



Giáo trình An toàn và bảo mật trong mạng máy tính

	a/e	b/f	c/g	d/h
t=50	813a43dd2c502043 07a0d8ef821c5e1a	ca9bd862c5050918 dfe091dab182e645	571f323d96b3a047 271580ed6c3e5650	6b69fc1bb482feac 35264334c03ac8ad
t=51	d43f83727325dd77 483f80a82eaae23e	813a43dd2c502043 07a0d8ef821c5e1a	ca9bd862c5050918 dfe091dab182e645	571f323d96b3a047 271580ed6c3e5650
t=52	03df11b32d42e203 504f94e40591cffa	d43f83727325dd77 483f80a82eaae23e	813a43dd2c502043 07a0d8ef821c5e1a	ca9bd862c5050918 dfe091dab182e645
t=53	d63f68037ddf06aa a6781efelaa1ce02	03df11b32d42e203 504f94e40591cffa	d43f83727325dd77 483f80a82eaae23e	813a43dd2c502043 07a0d8ef821c5e1a
t=54	f650857b5babda4d 9ccfb31a86df0f86	d63f68037ddf06aa a6781efelaa1ce02	03df11b32d42e203 504f94e40591cffa	d43f83727325dd77 483f80a82eaae23e
t=55	63b460e42748817e c6b4dd2a9931c509	f650857b5babda4d 9ccfb31a86df0f86	d63f68037ddf06aa a6781efelaa1ce02	03df11b32d42e203 504f94e40591cffa
t=56	7a52912943d52b05 d2e89bbd91e00be0	63b460e42748817e c6b4dd2a9931c509	f650857b5babda4d 9ccfb31a86df0f86	d63f68037ddf06aa a6781efelaa1ce02
t=57	4b81c3aec976ea4b 70505988124351ac	7a52912943d52b05 d2e89bbd91e00be0	63b460e42748817e c6b4dd2a9931c509	f650857b5babda4d 9ccfb31a86df0f86
t=58	581ecb3355dcd9b8 6a3c9b0f71c8bf36	4b81c3aec976ea4b 70505988124351ac	7a52912943d52b05 d2e89bbd91e00be0	63b460e42748817e c6b4dd2a9931c509
t=59	2c074484ef1eac8c 4797cde4ed370692	581ecb3355dcd9b8 6a3c9b0f71c8bf36	4b81c3aec976ea4b 70505988124351ac	7a52912943d52b05 d2e89bbd91e00be0
t=60	3857dfd2fc37d3ba a6af4e9c9f807e51	2c074484ef1eac8c 4797cde4ed370692	581ecb3355dcd9b8 6a3c9b0f71c8bf36	4b81c3aec976ea4b 70505988124351ac
t=61	cfcd928c5424e2b6 09aee5bda1644de5	3857dfd2fc37d3ba a6af4e9c9f807e51	2c074484ef1eac8c 4797cde4ed370692	581ecb3355dcd9b8 6a3c9b0f71c8bf36
t=62	a81dedbb9f19e643 84058865d60a05fa	cfcd928c5424e2b6 09aee5bda1644de5	3857dfd2fc37d3ba a6af4e9c9f807e51	2c074484ef1eac8c 4797cde4ed370692
t=63	ab44e86276478d85 cd881ee59ca6bc53	a81dedbb9f19e643 84058865d60a05fa	cfcd928c5424e2b6 09aee5bda1644de5	3857dfd2fc37d3ba a6af4e9c9f807e51
t=64	5a806d7e9821a501 aa84b086688a5c45	ab44e86276478d85 cd881ee59ca6bc53	a81dedbb9f19e643 84058865d60a05fa	cfcd928c5424e2b6 09aee5bda1644de5
t=65	eeb9c21bb0102598 3b5fed0d6a1f96e1	5a806d7e9821a501 aa84b086688a5c45	ab44e86276478d85 cd881ee59ca6bc53	a81dedbb9f19e643 84058865d60a05fa
t=66	46c4210ab2cc155d 29fab5a7bff53366	eeb9c21bb0102598 3b5fed0d6a1f96e1	5a806d7e9821a501 aa84b086688a5c45	ab44e86276478d85 cd881ee59ca6bc53



	a/e	b/f	c/g	d/h
t=67	54ba35cf56a0340e 1c66f46d95690bcf	46c4210ab2cc155d 29fab5a7bff53366	eeb9c21bb0102598 3b5fed0d6a1f96e1	5a806d7e9821a501 aa84b086688a5c45
t=68	181839d609c79748 0ada78ba2d446140	54ba35cf56a0340e 1c66f46d95690bcf	46c4210ab2cc155d 29fab5a7bff53366	eeb9c21bb0102598 3b5fed0d6a1f96e1
t=69	fb6aaae5d0b6a447 e3711cb6564d112d	181839d609c79748 0ada78ba2d446140	54ba35cf56a0340e 1c66f46d95690bcf	46c4210ab2cc155d 29fab5a7bff53366
t=70	7652c579cb60f19c aff62c9665ff80fa	fb6aaae5d0b6a447 e3711cb6564d112d	181839d609c79748 0ada78ba2d446140	54ba35cf56a0340e 1c66f46d95690bcf
t=71	f15e9664b2803575 947c3dfafee570ef	7652c579cb60f19c aff62c9665ff80fa	fb6aaae5d0b6a447 e3711cb6564d112d	181839d609c79748 0ada78ba2d446140
t=72	358406d165aee9ab 8c7b5fd91a794ca0	f15e9664b2803575 947c3dfafee570ef	7652c579cb60f19c aff62c9665ff80fa	fb6aaae5d0b6a447 e3711cb6564d112d
t=73	20878dcd29cdfaf5 054d3536539948d0	358406d165aee9ab 8c7b5fd91a794ca0	f15e9664b2803575 947c3dfafee570ef	7652c579cb60f19c aff62c9665ff80fa
t=74	33d48dabb5521de2 2ba18245b50de4cf	20878dcd29cdfaf5 054d3536539948d0	358406d165aee9ab 8c7b5fd91a794ca0	f15e9664b2803575 947c3dfafee570ef
t=75	c8960e6be864b916 995019a6ff3ba3de	33d48dabb5521de2 2ba18245b50de4cf	20878dcd29cdfaf5 054d3536539948d0	358406d165aee9ab 8c7b5fd91a794ca0
t=76	654ef9abec389ca9 ceb9fc3691ce8326	c8960e6be864b916 995019a6ff3ba3de	33d48dabb5521de2 2ba18245b50de4cf	20878dcd29cdfaf5 054d3536539948d0
t=77	d67806db8b148677 25c96a7768fb2aa3	654ef9abec389ca9 ceb9fc3691ce8326	c8960e6be864b916 995019a6ff3ba3de	33d48dabb5521de2 2ba18245b50de4cf
t=78	10d9c4c4295599f6 9bb4d39778c07f9e	d67806db8b148677 25c96a7768fb2aa3	654ef9abec389ca9 ceb9fc3691ce8326	c8960e6be864b916 995019a6ff3ba3de
t=79	73a54f399fa4b1b2 d08446aa79693ed7	10d9c4c4295599f6 9bb4d39778c07f9e	d67806db8b148677 25c96a7768fb2aa3	654ef9abec389ca9 ceb9fc3691ce8326

Tiếp theo, Bảng PL2-4 là các giá trị của giá trị băm khối dữ liệu M_0 . Đây cũng chính là giá trị băm của thông điệp $M = "abc"$. Trong đó, phép $+$ được hiểu là phép cộng modulo 2^{64} .

Bảng PL2-4: Giá trị băm của $M = "abc"$

$$\begin{aligned}
 H(1) &= H^{(0)}(1) + a = 6a09e667f3bcc908 + 73a54f399fa4b1b2 = ddaf35a193617aba \\
 H(2) &= H^{(0)}(2) + b = bb67ae8584caa73b + 10d9c4c4295599f6 = cc417349ae204131 \\
 H(3) &= H^{(0)}(3) + c = 3c6ef372fe94f82b + d67806db8b148677 = 12e6fa4e89a97ea2
 \end{aligned}$$



$$H(4) = H^{(0)}(4) + d = a54ff53a5f1d36f1 + 654ef9abec389ca9 = 0a9eeee64b55d39a$$

$$H(5) = H^{(0)}(5) + e = 510e527fade682d1 + d08446aa79693ed7 = 2192992a274fc1a8$$

$$H(6) = H^{(0)}(6) + f = 9b05688c2b3e6c1f + 9bb4d39778c07f9e = 36ba3c23a3feebbd$$

$$H(7) = H^{(0)}(7) + g = 1f83d9abfb41bd6b + 25c96a7768fb2aa3 = 454d4423643ce80e$$

$$H(8) = H^{(0)}(8) + h = 5be0cd19137e2179 + ceb9fc3691ce8326 = 2a9ac94fa54ca49f$$

Cuối cùng, giá trị băm của thông điệp "abc" bằng hàm băm SHA512 là:

ddaf35a193617aba cc417349ae204131 12e6fa4e89a97ea2 0a9eeee64b55d39a

2192992a274fc1a8 36ba3c23a3feebbd 454d4423643ce80e 2a9ac94fa54ca49f



TÀI LIỆU THAM KHẢO

- [1] William Stallings. (2003) *Cryptography and Network Security: Principles and Practice*. Prentice Hall, Inc.
- [2] John E. Canavan, (2000) *Fundamentals of Network Security*, Copyright © 2001 ARTECH HOUSE, INC.
- [3] Stinson, D. *Cryptography: Theory and Practice*, CRC Press, 1995.
- [4] Stallings, W. *Cryptography and Network Security Principles and Practices*, Prentice Hall, 2005.
- [5] Henk C. A. van Tilborg, *Encyclopedia of Cryptography and Security*, Springer Science Business Media, 2005.
- [6] Salil P. Vadhan, *Theory of Cryptography*, Proceedings of 4th Theory of Cryptography Conference, Amsterdam, The Netherlands, 2007.
- [7] Nguyễn Duy Tân, *Đề cương Bảo mật máy tính và mạng*
- [8] Khoa CNTT, Đại học SP KT HY, *Bảo mật máy tính và mạng*

